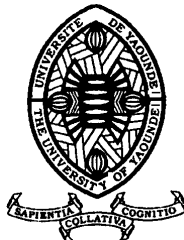


UNIVERSITÉ DE YAOUNDÉ I

ÉCOLE NATIONALE SUPÉRIEURE
POLYTECHNIQUE DE YAOUNDÉ

DÉPARTEMENT DU GÉNIE
INFORMATIQUE

HUMANITÉS NUMÉRIQUES



THE UNIVERSITY OF YAOUNDE I

NATIONAL ADVANCED SCHOOL OF
ENGINEERING OF YAOUNDE

DEPARTMENT OF COMPUTER
ENGINEERING

DIGITAL HUMANITIES

CONTRIBUTION A UNE METHODE D'AUDIT DE SECURITE APPLICATIVE (MUSA)
POUR LES PME CAMEROUNAISES : CAS DE SOLTEC

Mémoire de fin d'études / End of course dissertation

Présenté et soutenu par :

TOMI OLAMA GABRIELLE SOLANGE

En vue de l'obtention du :

Diplôme d'Ingénieur de Conception en Humanités Numériques

Option **Cybersécurité et Investigation Numérique**

Sous la supervision de :

**DR TIOGNING DJIOGUE LAURINE, CHARGÉ DE COURS UYI
MBOULE PATRICK, RSSI, SOLTEC**

Devant le jury composé de :

Président :

Rapporteur : **Dr TIOGNING DJIOGUE LAURINE, Chargé de Cours
UYI**

Examineur :

Année académique 2025 - 2026

Mémoire soutenu le 18 Septembre 2026



**CONTRIBUTION A UNE METHODE D'AUDIT DE SECURITE APPLICATIVE (MUSA)
POUR LES PME CAMEROUNAISES : CAS DE SOLTEC**

Mémoire de fin d'études / End of course dissertation

Présenté et soutenu par

TOMI OLAMA GABRIELLE SOLANGE

En vue de l'obtention du :

Diplôme d'Ingénieur de Conception en Humanités Numériques

Option Cybersécurité et Investigation Numérique

Sous la supervision de :

**DR TIOGNING DJIOGUE LAURINE, CHARGÉ DE COURS UYI, DÉPARTEMENT
GÉNIE INFORMATIQUE
ING. MBOULE PATRICK, RSSI, SOLTEC**

Année académique 2025 - 2026

DÉDICACE



REMERCIEMENTS

« La reconnaissance est un devoir que l'on devrait rendre, mais que l'on ne peut exiger. » -

Jean-Jacques Rousseau

C'est dans cet esprit que je prends un moment pour reconnaître ceux qui sont l'inspiration silencieuse derrière chaque page, chaque mot et chaque idée de ce mémoire.

- ♦ **Président du jury**, pour l'honneur qu'il m'a fait en acceptant de présider ce jury.
- ♦ **Examineur**, pour l'attention portée à ce mémoire. Son regard critique constitue pour moi une source d'enrichissement scientifique.
- ♦ **Dr. TIOGNING DIOGUE Lauraine**, Chargé de cours à UY1, pour son accompagnement attentif, la pertinence de ses orientations et son soutien tout au long de ce travail.
- ♦ **M. Patrick MBOULE**, Ingénieur en informatique et encadreur professionnel, pour sa disponibilité et son accompagnement au sein de SOLTEC.
- ♦ **M. LEKEUFACK Albert**, Ingénieur en informatique, Directeur Adjoint de SOLTEC : qui a facilité mon insertion et a permis le déroulement harmonieux de mon stage.
- ♦ **M. MINKA MI NGUIDJOI Thierry Emmanuel**, Ingénieur en informatique, Sous - Directeur au CONSUPE : pour l'attention qu'il a portée à ce travail et pour son accompagnement tout au long de cette recherche.
- ♦ **M. NJEI CHECK**, Directeur du Département d'Audit de Sécurité de l'ANTIC, pour m'avoir permis d'assister à la conférence du 29 avril 2026.
- ♦ **À toute l'équipe de SOLTEC** : merci pour cet espace où la passion pour l'audit se vit pleinement.
- ♦ **Tout le personnel enseignant du Département de Génie Informatique** de l'ENSPY. Vos conseils et votre encadrement ont été essentiels tout au long de ces cinq années.



- ◆ **Mes aînés académiques** en particulier **NGONGANG Wilfried** et **Yves ZANG**, pour le temps consacré à m'accompagner dans la rédaction de ce mémoire.
- ◆ **Mes frères et sœurs**, Larissa, Frida, Christiane, Berthold, Essola, Archange et Raphaëlle ; les grandes familles **TOMI FRANÇOIS** et **OLAMA APPOLINAIRE** : merci pour votre soutien sans faille.
- ◆ **Ma tante OLAMA NSIA Marthe Solange** : merci pour les encouragements et d'avoir toujours cru en moi.
- ◆ **NZIE IHOUE Noëlle Lagrande**, et **MENYEM BIS Bruno Manuella**, **BIENDE Franck**, **AVA Cyrille**, **FANMEGNE SIDJE Mandela**, **MFONO Evrard** pour notre amitié exceptionnelle et les moments partagés.
- ◆ **La promotion AHN 2026**, famille choisie, qui a rythmé et marqué ces années à Polytechnique.

Avec toute ma gratitude,

RÉSUMÉ

LA digitalisation croissante des activités, notamment des opérations comptables des établissements publics, s'accompagne d'une exposition accrue aux risques de sécurité informatique. Ces dix dernières années, le Cameroun a connu une accélération de la digitalisation de ses entreprises, et les Petites et Moyennes Entreprises (PME) n'y échappent pas. Cette transformation renforce leur dépendance aux systèmes d'information et fait de la fiabilité de ces derniers une condition essentielle à la continuité et à la qualité de leurs activités. Toutefois, les PME spécialisées dans la conception, le développement et la maintenance de solutions informatiques, à l'instar de SOLTEC, disposent généralement de ressources limitées, rendant difficile la réalisation systématique de l'ensemble des audits nécessaires à une évaluation complète de leurs applications. Face à cette contrainte, ce travail propose la Méthode Unifiée d'Audit de Sécurité Applicative (MUSA), une démarche permettant de regrouper, au sein d'une même mission, l'évaluation de la sécurité et de la conformité fonctionnelle d'une application. MUSA combine ainsi les principes de l'audit de sécurité et de l'audit des applications en service, tout en intégrant une approche de mesure fondée sur l'entropie afin de favoriser la reproductibilité et la mesurabilité des résultats. Structurée autour de sept outils (L00 à L06) couvrant les différentes phases d'une mission d'audit, la méthode a été appliquée à GIDOCEP, une application développée par SOLTEC pour la gestion des opérations comptables des établissements publics camerounais. Les résultats obtenus permettent de produire, au cours d'un seul audit, une cartographie globale de l'état de l'application intégrant à la fois ses dimensions sécuritaires et sa conformité fonctionnelle. MUSA démontre ainsi qu'il est possible de proposer aux PME de taille comparable à SOLTEC une approche d'audit spécialisée, réutilisable et mesurable, susceptible de contribuer au renforcement de la fiabilité de leurs systèmes d'information tout en tenant compte de leurs contraintes organisationnelles et opérationnelles.

Mots-clés : MUSA, Audit de sécurité, Audit des applications en service, Entropie, Outil réutilisable.

ABSTRACT

THE increasing digitalisation of activities, particularly accounting operations within public institutions, is accompanied by growing exposure to information security risks. Over the past decade, Cameroon has experienced an acceleration in the digitalisation of its businesses, and Small and Medium-sized Enterprises (SMEs) are no exception. This transformation has increased their dependence on information systems, making their reliability essential to the continuity and quality of their operations. However, SMEs specialising in the design, development and maintenance of IT solutions, such as SOLTEC, generally have limited resources, making it difficult to systematically conduct all the audits required for a comprehensive assessment of their applications. To address this constraint, this work proposes the Unified Method for Application Security Auditing (MUSA), an approach that brings together, within a single audit engagement, the assessment of an application's security and functional compliance. MUSA combines the principles of security auditing and application auditing while incorporating an entropy-based measurement approach to promote the reproducibility and measurability of results. Structured around seven tools (L00 to L06) covering the different phases of an audit engagement, the method was applied to GIDOCEP, an application developed by SOLTEC for managing the accounting operations of Cameroonian public institutions. The results obtained make it possible to produce, through a single audit, a comprehensive overview of the application's state, encompassing both its security aspects and functional compliance. MUSA thus demonstrates that it is possible to provide SMEs comparable in size to SOLTEC with a specialised, reusable and measurable auditing approach capable of contributing to the strengthening of the reliability of their information systems while taking into account their organisational and operational constraints.

Keywords : MUSA, Security auditing, Application auditing, Entropy, Reusable tool.

TABLE DES MATIÈRES

	Page No
Dédicace	i
Remerciements	ii
Résumé	iv
Abstract	v
Table des matières	viii
Table des figures	ix
Liste des tableaux	xi
abréviations	xiii
Introduction Générale	1
1 Concepts Généraux et État de l'art	6
1.1 Concepts généraux dans l'audit des systèmes d'information	7
1.1.1 Définitions des concepts clés	7
1.1.2 Typologie des audits selon le CHAI	9
1.1.3 Intérêt pour l'audit	10
1.1.4 Distinction et convergence des audits de sécurité et des applications en service	10
1.1.5 Application aux PME de type SOLTEC	11
1.1.6 Fondements de la standardisation en cybersécurité	12
1.1.7 Normes et standards d'usage commun en audit :	12
1.1.8 Outils utilisés dans une mission d'audit	14
1.2 Etat de l'art de la pratique de l'audit des SI dans les PME Camerounaises . . .	15
1.2.1 La démarche d'audit de l'ANTIC (D'après la dernière mise à jour dispo- nible en ligne)	15

1.2.2	La démarche du CONSUPE et l'innovation de l'entropie de Shannon en audit	16
1.2.3	Analyse croisée des démarches ANTIC et CONSUPE	18
1.2.4	Synthèse et positionnement de la méthode	20
2	Méthodologie	21
2.1	Principes directeurs de MUSA	22
2.1.1	Principe 1 : Optimisation par la fusion sécurité + applicatif	22
2.1.2	Principe 2 : Objectivation de l'incertitude par domaine	22
2.1.3	Principe 3 : Formalisation complète des procédures	22
2.1.4	Principe 4 : Gouvernance rigoureuse	23
2.1.5	Principe 5 : Réutilisabilité systématique	23
2.1.6	Principe 6 : Ancrage local	23
2.1.7	Principe 7 : Capture de l'incertitude	23
2.2	Structure globale de la méthode	23
2.2.1	Les cinq phases de la mission	23
2.2.2	Les outils de la méthode	24
2.2.3	Risques préliminaires et cotation dans le TDR	25
2.3	Les cinq phases d'une mission d'audit dans la méthode	26
2.3.1	Phase 1 : Travaux préparatoires	27
2.3.2	Phase 2 : Planification	28
2.3.3	Phase 3 : Exécution (Terrain)	28
2.3.4	Phase 4 : Communication des résultats	36
2.3.5	Phase 5 : Suivi des recommandations	36
3	Implémentation et Résultats	39
3.1	Présentation de GIDOCEP	40
3.1.1	Description générale	40
3.1.2	Architecture technique	40
3.1.3	Données manipulées	41
3.1.4	Chaîne d'exécution du budget	41
3.1.5	Niveau de criticité	42
3.1.6	Antécédents d'audit	42
3.1.7	Justification du cas d'étude	42
3.2	Déroulement de l'audit	42
3.2.1	Phase 1 : Travaux préparatoires	44
3.2.2	Phase 2 : Planification	49
3.2.3	Phase 3 : Exécution (Terrain)	51
3.2.4	Phase 4 : Communication des résultats	68

TABLE DES MATIÈRES



3.2.5	Phase 5 : Suivi des recommandations	73
3.3	Synthèse des résultats de l'audit	75
	Synthèse des résultats de l'audit	75
3.4	Discussion	76
3.4.1	Limites de l'étude	76
3.4.2	Perspectives	76
	Conclusion	78
	Bibliographie	79
	Annexe	83

TABLE DES FIGURES

FIGURE	Page No
2.1 Matrice visuelle des risques $R = P \times I$, Version MUSA avec seuil critique 9	34
3.1 Page d'accueil et tableau de bord de GIDOCEP	40
3.2 Planning détaillé de l'audit MUSA - GIDOCEP	43
3.3 Délimitation du périmètre d'audit (L01)	45
3.4 Grille de détermination du niveau d'audit (L01)	46
3.5 Liste des documents sollicités (L03)	46
3.6 Documents reçus en Phase 1	47
3.7 Grille d'évaluation de la faisabilité (L01)	47
3.8 Grille de compétences de l'équipe d'audit (L01)	48
3.9 Déclarations d'indépendance des auditeurs (L01)	48
3.10 Procès-verbal de la réunion de lancement (L01)	49
3.11 Résultat du scan réseau Nmap	52
3.12 Résultat du scan de vulnérabilités Nuclei	52
3.13 Tableau de bord des alertes OWASP ZAP	53
3.14 Page d'accueil et tableau de bord de GIDOCEP	54
3.15 Mot de passe faible accepté	55
3.16 Mot de passe robuste possible	55
3.17 Politique de mots de passe dans GIDOCEP	55
3.18 Message d'expiration de session après 10 minutes d'inactivité	56
3.19 Vérification de l'installation de Nmap	58
3.20 Vérification de l'installation de Nuclei	58
3.21 Lancement de l'interface OWASP ZAP	58
3.22 Résultat du scan réseau Nmap	59
3.23 Résultat du scan de vulnérabilités Nuclei	60
3.24 Tableau de bord des alertes OWASP ZAP	61
3.25 Export du rapport OWASP ZAP au format HTML	62
3.26 Mot de passe faible accepté	63
3.27 Mot de passe robuste possible	63



3.28 Changement de mot de passe dans GIDOCEP	63
3.29 Message d'expiration de session après 10 minutes d'inactivité	64
3.30 Résultat de la tentative de modification du paramètre d'accès	64
3.31 Tableau consolidé des constats de sécurité	68
3.32 Métriques de conformité fonctionnelle	69
3.33 Tableau consolidé des constats (L04)	70
3.34 Calcul des métriques MUSA (L04)	71
3.35 Plan d'actions correctives (L04)	72
3.36 Plan de suivi post-audit (L06)	75

LISTE DES TABLEAUX

TABLEAU	Page No
1.1 Les quatre piliers de la sécurité	9
1.2 Typologie des audits selon le CHAI	9
1.3 Distinction et convergence entre audit de sécurité et audit applicatif	11
1.4 Normes IIA intégrées dans MUSA	13
1.5 Les trois niveaux de l'OWASP ASVS	13
1.6 Comparaison des normes et standards d'audit	14
1.7 Les cinq phases de la démarche d'audit ANTIC (Conférence 29 avril 2026)	16
1.8 Les cinq phases de la démarche d'audit du CONSUPE pour l'audit des SI (ISO 19011 :2018) ¹	17
1.9 Les trois états de réponse	18
1.10 Analyse croisée des démarches ANTIC et CONSUPE	20
2.1 Les cinq phases de notre méthode	24
2.2 Le dossier de mission MUSA - sept outils standardisés	25
2.3 Risques préliminaires identifiés dans le TDR	26
2.4 Phase 1 : Travaux préparatoires	27
2.5 Phase 2 : Planification	28
2.6 Phase 3 : Exécution (Terrain)	29
2.7 Profils d'entretien et thèmes abordés	29
2.8 Types de tests de l'audit technique MUSA	30
2.9 Les cinq domaines de l'Outil tableur	31
2.10 Dérivation de la réponse fusionnée O/N/PAS	32
2.11 Lecture de l'entropie par domaine	32
2.12 Niveaux de maturité CMMi selon le taux de conformité	33
2.13 Échelles de probabilité et d'impact	34
2.14 Classification des risques $R = P \times I$ et actions associées	35
2.15 Grille de criticité de l'Outil tableur	35
2.16 Phase 4 : Communication des résultats	36
2.17 Phase 5 : Suivi des recommandations	37



3.1	Caractéristiques techniques de GIDOCEP	41
3.2	Acteurs de la chaîne d'exécution du budget	41
3.3	Niveau d'audit de GIDOCEP	42
3.4	Applications utilisées pour l'audit technique	59
3.5	Ports ouverts détectés par Nmap	60
3.6	Répartition des alertes OWASP ZAP par niveau de criticité	61
3.7	Résultats du test de blocage de compte	62
3.8	Vulnérabilités confirmées et scores de risque	65
3.9	Répartition des vulnérabilités par niveau de risque	66
3.10	Évaluation de la maturité de GIDOCEP par domaine	66
3.11	Calcul de l'entropie par domaine	67
3.12	Métriques globales de l'audit	70
3.13	Extrait du plan d'actions correctives	72
3.14	Jalons de la Phase 5	74

ABRÉVIATIONS

2

AC : Agent Comptable

AFD : Agence Française de Développement

AHN : Arts et Humanités Numériques

ANSSI : Agence Nationale de la Sécurité des Systèmes d'Information (France)

API : *Application Programming Interface*

ART : Agence de Régulation des Télécommunications

ASVS : *Application Security Verification Standard*

AWP : *Active Web Pages*

BDD : Base de Données

CF : Contrôleur Financier

CHAI : Comité d'Harmonisation de l'Audit Interne

CIA : Confidentialité, Intégrité, Disponibilité

CMMI : *Capability Maturity Model Integration*

COBAC : Commission Bancaire de l'Afrique Centrale

CORS : *Cross-Origin Resource Sharing*

CSP : *Content Security Policy*

CSRF : *Cross-Site Request Forgery*

CVE : *Common Vulnerabilities and Exposures*

CVSS : *Common Vulnerability Scoring System*

DAAF : Direction des Affaires Administratives et Financières

DAST : *Dynamic Application Security Testing*

DevSecOps : *Development, Security and Operations*

DG : Direction Générale

DGA : Directeur Général Adjoint

DGB : Direction Générale du Budget

DSI : Directeur des Systèmes d'Information

EBIOS : Expression des Besoins et Identification des Objectifs de Sécurité

ENSPY : École Nationale Supérieure Polytechnique de Yaoundé

EPA : Établissement Public Administratif

GIDOCEP : Gestion Informatisée des Opérations Comptables des Établissements Publics



HFSQL : *Hyper File SQL*
HSTS : *HTTP Strict Transport Security*
HTTP : *HyperText Transfer Protocol*
HTTPS : *HyperText Transfer Protocol Secure*
IDOR : *Insecure Direct Object Reference*
IIS : *Internet Information Server*
IIA : *Institute of Internal Auditors*
IPPF : *International Professional Practices Framework*
ISACA : *Information Systems Audit and Control Association*
ISSAI : *International Standards of Supreme Audit Institutions*
ISO : *Organisation Internationale de Normalisation*
JWT : *JSON Web Token*
MFA : *Multi-Factor Authentication*
MINFI : *Ministère des Finances (Cameroun)*
MINPOSTEL : *Ministère des Postes et Télécommunications*
MUSA : *Méthode Unifiée d'Audit de Sécurité Applicative*
NA : *Non Applicable*
NAP : *Net À Payer*
NC : *Non Conforme*
NDA : *Non-Disclosure Agreement*
NIST : *National Institute of Standards and Technology*
NTP : *Network Time Protocol*
OP : *Ordre de Paiement*
ORM : *Object-Relational Mapping*
OTP : *One-Time Password*
OWASP : *Open Web Application Security Project*
PC : *Partiellement Conforme*
PII : *Personally Identifiable Information*
PoC : *Proof of Concept*
PRA : *Plan de Reprise d'Activité*
PT : *Papier de Travail (MUSA)*
REST : *Representational State Transfer*
SAST : *Static Application Security Testing*
SCA : *Software Composition Analysis*
SDLC : *Software Development Life Cycle*
SI : *Système d'Information*
SLA : *Service Level Agreement*
SMSI : *Système de Management de la Sécurité de l'Information*



SOLTEC : Solutions Techniques

SP : *Special Publication* (NIST)

SQL : *Structured Query Language*

SSI : Sécurité des Systèmes d'Information

TIC : Technologies de l'Information et de la Communication

TLS : *Transport Layer Security*

UA : Unité Administrative

UI : *User Interface*

UPS : *Uninterruptible Power Supply*

URL : *Uniform Resource Locator*

USB : *Universal Serial Bus*

WWUSR : *World Wide Web User* (groupe Windows)

XSS : *Cross-Site Scripting*

GLOSSAIRE

2

Artefact. Preuve brute ou élément collecté lors d'une mission d'audit, tel qu'une capture d'écran, un extrait de code, un fichier de log ou une image système. Les artefacts servent à étayer les constats des auditeurs et sont archivés pour garantir la traçabilité et la reproductibilité des conclusions. Ils se distinguent des *outils*, qui sont les supports standardisés développés pour conduire l'audit.

Audit de sécurité. Examen méthodique et indépendant visant à évaluer la protection des actifs informationnels d'une organisation contre la perte, l'altération, la divulgation et l'indisponibilité (politique de sécurité, gestion des accès, sauvegarde, conformité réglementaire, sensibilisation).

Audit des applications en service. Examen méthodique et indépendant visant à évaluer la fiabilité, la sécurité, l'efficacité et la performance des applications informatiques en production, selon deux visées : la fiabilité/sécurité (contrôle interne, validité des données, pistes d'audit) et l'efficacité/performance (adéquation aux besoins, contribution à la valeur, évolutivité).

Authentification forte (2FA). Méthode combinant deux facteurs indépendants pour renforcer la sécurité d'accès (ex. : mot de passe + code envoyé sur mobile).

Chiffrement. Transformation de données lisibles en données illisibles sans clé de déchiffrement appropriée.

Cloud computing. Modèle d'accès à la demande à des ressources informatiques partagées via un réseau.

CONSUPE. Contrôle Supérieur de l'État. Organisme camerounais réalisant des audits des systèmes d'information des entreprises publiques. Il a introduit l'entropie de Shannon dans sa méthodologie d'audit.

Correctif (Patch). Mise à jour logicielle corrigeant une vulnérabilité ou un dysfonctionnement.



Cybersécurité. Ensemble des mesures techniques, organisationnelles et juridiques protégeant les systèmes d'information.

DAST. Test de sécurité d'une application en cours d'exécution.

DevSecOps. Intégration de la sécurité à toutes les phases du cycle de développement logiciel.

Entropie de Shannon. Mesure quantitative de l'incertitude dans un système d'information.

Intranet. Réseau privé utilisant les technologies Internet, accessible uniquement aux membres d'une organisation.

Journalisation (Logging). Enregistrement chronologique des événements d'un système, essentiel pour la traçabilité.

Matrice des risques. Outil de visualisation et de priorisation des risques basé sur deux dimensions : la probabilité (P) et l'impact (I). Le score de risque est $R = P \times I$.

Maturité. Niveau de formalisation et de maîtrise des processus de sécurité d'une organisation. Dans MUSA, évaluée sur 5 niveaux (0%, 25%, 50%, 75%, 100%).

Modélisation des menaces. Identification et analyse des menaces potentielles pour anticiper les contre-mesures.

One-size-fits-all. Expression anglaise signifiant littéralement « une taille convient à tous ». Elle désigne une approche ou une solution standardisée et générique, conçue pour s'appliquer à toutes les situations sans tenir compte des spécificités de chaque cas.

Outils (MUSA). Ensemble des documents et supports standardisés développés pour structurer et harmoniser la conduite d'une mission d'audit. Ceux-ci incluent les checklists Excel, les papiers de travail, les guides d'entretien, la matrice des risques et les modèles de rapport.

Papiers de travail (PT). Documents standardisés utilisés par les auditeurs pour consigner leurs observations, preuves et conclusions.

Plan de reprise d'activité (PRA). Procédures de restauration des systèmes après sinistre.

Reproductibilité. Capacité à obtenir des résultats identiques lorsqu'un même audit est répété par différents auditeurs.

SAST. Analyse de sécurité du code source sans exécution.

Test d'intrusion (Pentest). Simulation d'attaques autorisées pour évaluer la sécurité.

Vulnérabilité. Faiblesse dans un système pouvant être exploitée par une menace.





ZG. Situation où l’audité ne peut pas se prononcer clairement sur la conformité ou la non-conformité d’une assertion. Dans MUSA, une zone grise est signalée par une entropie $H \geq 0,5$.

INTRODUCTION GÉNÉRALE

Contexte

LA transformation numérique des administrations publiques camerounaises s'accompagne d'une digitalisation croissante des entreprises. Même les PME n'y échappent pas. Si cette évolution améliore l'efficacité administrative, elle expose les systèmes d'information (SI) à des risques de sécurité de plus en plus grands [1]. Cette situation pose donc un problème de fiabilité de ces systèmes dont dépendent les données financières des établissements et entreprises publiques. L'audit de ces systèmes d'information apparaît donc comme une articulation indispensable de la solution à cette nouvelle réalité [2].

Au Cameroun, la sécurisation des systèmes d'information repose sur deux institutions complémentaires mais distinctes : l'ANTIC (Agence Nationale des Technologies de l'Information et de la Communication) et le CONSUPE (Contrôle Supérieur de l'État).

L'ANTIC, créée par décret n°2002/092 du 08 Avril 2002 [3], est chargée entre autres des audits de sécurité des systèmes d'information. Elle a développé une démarche d'audit structurée en cinq phases [4], couvrant les dimensions organisationnelle, humaine, physique et technologique. Cette démarche, ancrée localement et bénéficiant d'une bonne acceptation, constitue un référentiel solide pour l'évaluation de la sécurité des applications.

Le CONSUPE, créé par décret n°2013/287 du 04 septembre 2013 portant organisation des services du Contrôle supérieur de l'État [5], est placé sous l'autorité directe du Président de la République et constitue l'institution supérieure de contrôle (ISC) du Cameroun, chargée de l'audit externe. Il réalise entre autres des audits fonctionnels des systèmes d'information des entreprises publiques et parapubliques. Cette institution a réalisé une innovation et une avancée majeure en audit en introduisant une troisième possibilité de réponses dans l'univers de l'audit traditionnellement restreint à deux choix (OUI, NON), puis en mesurant l'incertitude qui en découle par l'entropie de Shannon [6]. Un développement approprié en sera fait plus loin dans le document.

Une application informatique de gestion est souvent l'aboutissement de l'informatisation d'un Système d'Information (SI). Dans la suite de ce travail, nous considérerons que les deux termes (application et SI) sont interchangeable. Dès lors, nous pouvons donc reformuler en disant que l'ANTIC s'occupe de l'audit de sécurité des applications et le CONSUPE de l'audit fonctionnel de ces applications.



Cette séparation, prescrite par le CHAI (Comité d'Harmonisation de l'Audit Interne) [7], conduit à une vision fragmentée de la sécurité des applications. Dans le contexte d'une PME comme SOLTEC, cette séparation pose un problème concret : une entreprise de cette taille ne peut financer deux missions d'audit distinctes sur un même cycle budgétaire portant sur le même objet (la même application informatique).

C'est dans ce contexte que s'inscrit la présente recherche, qui propose la Méthode Unifiée d'Audit de Sécurité Applicative (MUSA). Cette méthode vise à réunir, au sein d'une démarche unique, les exigences relatives à la sécurité et à l'évaluation fonctionnelle des applications, tout en intégrant une approche quantitative fondée notamment sur l'entropie de Shannon afin d'apprécier l'incertitude et la reproductibilité des résultats.

Problématique

La digitalisation croissante des organisations impose une évaluation régulière de la fiabilité et de la sécurité des applications informatiques. Cependant, les approches actuelles tendent à dissocier l'audit de sécurité de l'audit des applications en service ou de leur fonctionnement.

Cette séparation entraîne une fragmentation du processus d'évaluation. Dans le cas d'une PME comme SOLTEC, elle peut nécessiter la mobilisation de ressources distinctes pour examiner différents aspects d'une même application, ce qui augmente les coûts et la complexité des missions d'audit.

Par ailleurs, la diversité des référentiels et des démarches d'audit soulève également la question de l'harmonisation des procédures, de la reproductibilité des résultats et de la capacité à mesurer l'incertitude liée aux réponses et aux appréciations formulées par les auditeurs.

Question

Comment concevoir une méthode d'audit unifiée permettant de couvrir à la fois les exigences de sécurité et d'évaluation des applications en service, tout en garantissant la reproductibilité, la mesurabilité et la réutilisabilité des résultats dans le contexte d'un éditeur de logiciels comme SOLTEC ?

Hypothèse

Pour répondre à cette question, nous posons l'hypothèse qu'une démarche unifiée, s'appuyant sur des standards reconnus et intégrant des outils de mesure de l'incertitude, peut



apporter une solution adaptée aux contraintes des PME. De cette hypothèse générale découlent deux hypothèses principales :

- ☞ **Hypothèse 1** : La fusion des audits de sécurité et fonctionnels en une démarche unifiée (MUSA) permet de couvrir l'intégralité du périmètre des deux types d'audit tout en réduisant les coûts pour les PME, grâce à une mutualisation des phases préparatoires, des entretiens et des analyses.
- ☞ **Hypothèse 2** : La conception et l'utilisation d'outils d'aide à l'audit formalisés (grilles d'évaluation, questionnaires standardisés, calculateur d'entropie de Shannon, tableaux de bord de résultats) permettent de garantir la reproductibilité de la méthode MUSA, d'en faciliter l'appropriation par les auditeurs et d'assurer une mesure objective et fiable de la sécurité et de la conformité fonctionnelle des applications.

Objectif générale

L'objectif Principale de notre projet est de proposer une méthode d'audit unifiée (MUSA) qui fusionne l'audit de sécurité et l'audit fonctionnel des applications en une seule démarche, intégrant l'entropie de Shannon pour quantifier l'incertitude et proposant des outils d'aide à l'audit formalisés, le tout validé sur un cas concret (GIDOCEP).

Objectifs spécifiques

À partir de l'objectif général de notre travail, nous pouvons définir plusieurs objectifs spécifiques :

Objectif 1

Analyser les référentiels existants (ANTIC, CONSUPE, ISO 27001, OWASP ASVS, NIST SP 800-115, ISO 19011, normes IIA).

Cette première étape consiste à examiner en profondeur les différents référentiels d'audit et de sécurité applicative utilisés au Cameroun et à l'international. Il s'agit d'identifier leurs forces, leurs limites, leurs domaines de couverture respectifs ainsi que leurs éventuelles redondances, afin de jeter les bases d'une méthode unifiée qui puisse s'appuyer sur les bonnes pratiques de chacun tout en comblant leurs lacunes.

Objectif 2

Proposer la méthode MUSA s'appuyant sur quatre piliers : standards de contenu, standards de conduite, entropie de Shannon, outils réutilisables.



Cette étape vise à élaborer la méthode MUSA en s'appuyant sur quatre piliers fondamentaux : les standards de contenu qui définissent les domaines d'audit à couvrir, les standards de conduite qui encadrent le déroulement de la mission, l'entropie de Shannon qui permet de quantifier l'incertitude des réponses, et des outils réutilisables qui garantissent la reproductibilité de la démarche.

Objectif 3

Appliquer la méthode à GIDOCEP (application de gestion comptable développée par SOLTEC) pour valider son opérationnalité.

Il s'agit de mettre en œuvre la méthode MUSA sur un cas concret : GIDOCEP (Gestion Informatisée des Opérations Comptables des Établissements Publics), l'application de gestion comptable développée par SOLTEC. Cette application permettra de tester l'opérationnalité de la méthode, de valider sa capacité à couvrir à la fois les aspects sécurité et fonctionnels, et d'identifier d'éventuels ajustements nécessaires.

Objectif 4

Évaluer les résultats et identifier les perspectives d'amélioration et de généralisation.

Cette dernière étape consiste à analyser les résultats obtenus lors de l'application de la méthode à GIDOCEP, à évaluer la pertinence et l'efficacité de la méthode au regard des objectifs fixés, à identifier ses limites et les axes d'amélioration possibles, ainsi qu'à envisager les perspectives de généralisation de la méthode à d'autres types d'applications et d'organisations.

Ce mémoire est structuré en trois chapitres pour aborder de manière exhaustive la problématique posée :

- **Chapitre 1 : Concepts généraux et état de l'art.** Dans ce chapitre, nous présenterons les concepts fondamentaux liés à l'audit des systèmes d'information, à la sécurité applicative et à l'entropie de Shannon. Nous dresserons ensuite un état de l'art des référentiels existants (ANTIC, CONSUPE, ISO 27001, OWASP ASVS, NIST SP 800-115, ISO 19011, normes IIA) avant de justifier les choix retenus pour l'élaboration de notre méthode unifiée.
- **Chapitre 2 : Méthodologie.** Ce chapitre sera dédié à la présentation de la méthode MUSA (Méthode Unifiée d'Audit de Sécurité Applicative), en détaillant ses quatre piliers fondateurs : les standards de contenu, les standards de conduite, l'entropie de Shannon et les outils réutilisables. Nous y présenterons également la démarche de fusion des audits de sécurité et fonctionnels ainsi que la conception des outils d'aide à l'audit.



- **Chapitre 3 : Implémentation et résultats.** Dans ce chapitre, nous appliquerons la méthode MUSA à GIDOCEP (Gestion Informatisée des Opérations Comptables des Établissements Publics), l'application de gestion comptable développée par SOLTEC. Nous présenterons les résultats de cette application, analyserons la pertinence et l'efficacité de la méthode, et identifierons ses apports et ses limites.

Nous clôturerons par une conclusion générale qui aura pour but de rappeler le problème posé, de faire une synthèse de la solution apportée par la méthode proposée et de présenter les limites ainsi que les perspectives d'amélioration et de généralisation de la méthode.

CONCEPTS GÉNÉRAUX ET ÉTAT DE L'ART

Ce chapitre pose les bases conceptuelles et méthodologiques nécessaires à la compréhension de la proposition MUSA. Il poursuit quatre objectifs : définir les concepts clés de l'audit des systèmes d'information, dresser un état de l'art des démarches de l'ANTIC et du CONSUPE, analyser leurs forces et limites, et justifier la fusion des audits de sécurité et des applications en service dans le contexte d'une PME comme SOLTEC.



1.1 Concepts généraux dans l'audit des systèmes d'information

1.1.1 Définitions des concepts clés

Audit : L'audit est un examen méthodique, indépendant et documenté permettant d'évaluer la conformité d'un système, d'un processus ou d'une organisation par rapport à des référentiels établis. Il vise à formuler une opinion motivée et à formuler des recommandations pour améliorer la performance, la sécurité ou la conformité.

Audit de sécurité au sens du CHAI : L'audit de sécurité est un examen méthodique et indépendant visant à évaluer la protection des actifs informationnels d'une organisation. Il poursuit plusieurs objectifs :

- ◆ **Protection des actifs** : évaluer les mesures de sécurité techniques, organisationnelles et physiques en place.
- ◆ **Gestion des accès** : vérifier le principe de moindre privilège et la revue périodique des droits.
- ◆ **Continuité d'activité** : analyser les procédures de sauvegarde, de reprise et de gestion des incidents.
- ◆ **Conformité** : s'assurer du respect des exigences légales et réglementaires.

Il répond à la question fondamentale : « *L'application est-elle suffisamment protégée ?* »

Audit des applications en service au sens du CHAI : L'audit des applications en service est un examen méthodique et indépendant visant à évaluer la performance, la fiabilité et la conformité d'une application par rapport à son objectif fonctionnel. Il poursuit plusieurs objectifs :

- ◆ **Évaluer la fiabilité** : s'assurer de l'exactitude et l'intégrité des traitements et des données.
- ◆ **Analyser la performance** : s'assurer de l'efficacité et l'efficience de l'application.
- ◆ **Vérifier la conformité fonctionnelle** : s'assurer que l'application répond au cahier des charges issus des besoins des utilisateurs.
- ◆ **Évaluer l'évolutivité** : s'assurer de la capacité de l'application à s'adapter et à intégrer les mises à jour au niveau des besoins de l'organisation.

Il répond à la question fondamentale : « *L'application fait-elle ce qu'elle doit ?* »



Audit de sécurité applicative unifié (*Proposition de définition*) : Un audit de sécurité applicative unifié est un examen méthodique et indépendant qui évalue simultanément la conformité fonctionnelle d'une application et l'adéquation de ses contrôles de sécurité, à partir d'outils standardisés et réutilisables. Il fusionne l'audit de sécurité et l'audit des applications en service en une seule démarche cohérente.

Entropie de Shannon : L'entropie de Shannon[6], issue de la théorie de l'information développée par Claude Shannon en 1948, est une mesure quantitative de l'incertitude associée à une variable aléatoire. Dans le contexte de l'audit[8], elle permet de quantifier le niveau de dispersion de réponse.

La formule de l'entropie de Shannon s'écrit :

$$H = - \sum_{i=1}^n p_i \cdot \log_2(p_i) \quad (1.1)$$

Où :

- ♦ n est le nombre d'états possibles (Oui, Non, Pas)
- ♦ p_i est la probabilité de l'état i

Risque : Le risque est la combinaison de la probabilité qu'une menace exploitant une vulnérabilité se réalise et de l'impact que cet événement aurait sur l'organisation. Selon la norme ISO 31000 :2018, le risque est défini comme l'effet de l'incertitude sur les objectifs. Dans le domaine de la sécurité de l'information, l'ISO/IEC 27000 :2018 le définit comme la combinaison de la probabilité d'un événement et de ses conséquences.

Matrice des risques $P \times I$: La matrice des risques est un outil de visualisation et de priorisation des risques basé sur deux dimensions :

- ♦ **Probabilité (P)** : évaluée de 1 (très faible) à 4 (élevée)
- ♦ **Impact (I)** : évalué de 1 (négligeable) à 4 (critique)

Le score de risque est calculé par la formule : $R = P \times I$. Il permet de classer les vulnérabilités par niveau de priorité (Faible, Modéré, Élevé, Critique).

Maturité : La maturité est le niveau de formalisation et de maîtrise des processus d'une organisation. Selon le modèle CMMI (Capability Maturity Model Integration), la maturité se définit comme le degré auquel une organisation applique de manière systématique des processus définis, gérés, mesurés et contrôlés[9]. Le modèle CMMI distingue cinq niveaux de maturité, allant du niveau 1 (Initial) où les processus sont imprévisibles et peu maîtrisés, au niveau 5 (Optimisé) où l'amélioration continue est systématique.



Les piliers de la sécurité : la triade CIA (Confidentiality, Integrity, Availability) . La sécurité de l'information repose sur trois piliers fondamentaux : la confidentialité, l'intégrité et la disponibilité, communément désignés par l'acronyme CIA. À ces trois piliers s'ajoute la traçabilité, qui constitue un quatrième pilier essentiel dans le contexte de l'audit.

TABLE 1.1 – Les quatre piliers de la sécurité

Pilier	Définition	Application à GIDOCEP
Confidentialité	Accès réservé aux autorisés	Agents habilités uniquement
Intégrité	Données non altérées	Toute modification est tracée
Disponibilité	Système accessible	Fonctionnel en période de clôture
Traçabilité	Enregistrement des actions	Horodatage sur chaque opération

1.1.2 Typologie des audits selon le CHAI

Le CHAI, une des instances faisant autorité en matière de l'audit interne dans le monde francophone. Dans son guide d'audit des systèmes d'information publié en 2014[7], distingue plusieurs types d'audit selon l'objet de la mission. Cette typologie permet à l'auditeur de situer sa mission et d'adapter sa démarche en conséquence. le tableau suivant présente un résumé de ces différents types d'audit :

TABLE 1.2 – Typologie des audits selon le CHAI

Type d'audit	Objectif	Description
Audit de sécurité	Évaluer la protection des actifs informationnels	Vérifie la politique de sécurité, la gestion des accès, la protection des données, la continuité d'activité et la conformité réglementaire
Audit des applications en service	Évaluer la fiabilité et la performance des applications	Analyse la sécurité, la fiabilité, l'efficacité, la performance et l'évolutivité des applications informatiques en production
Audit de la production informatique	Analyser l'exploitation des systèmes	Évalue la disponibilité, l'intégrité et la confidentialité des systèmes, ainsi que la qualité de service
Audit du support utilisateurs	Évaluer l'assistance aux utilisateurs	Analyse le help-desk, la gestion du parc matériel et logiciel, et la satisfaction des utilisateurs
Audit de la fonction Étude	Analyser le développement et la maintenance	Évalue la capacité à assurer la maintenance du patrimoine applicatif et à conduire les évolutions
Audit des projets	Évaluer la conduite des projets informatiques	Analyse l'étude d'opportunité, la planification, les instances de pilotage, les méthodes et outils, la qualification et la mise en production
Audit des marchés informatiques	Examiner les marchés spécifiques au domaine	Analyse les marchés d'assistance technique, d'infogérance, de TMA, de fourniture d'applications hébergées, etc.

Dans la suite de notre travail, nous nous attarderons sur deux types :





a) L'audit de sécurité : Il a pour objectif d'évaluer la protection des actifs informationnels de l'organisation contre la perte, l'altération, la divulgation et l'indisponibilité. Il vérifie :

- ◆ L'existence et la pertinence d'une politique de sécurité
- ◆ La gestion des identifiants et des mots de passe
- ◆ Le contrôle des accès physiques et logiques
- ◆ Les procédures de sauvegarde et de reprise d'activité
- ◆ La conformité à la législation (CNIL, propriété intellectuelle, etc.)
- ◆ La sensibilisation et la formation des utilisateurs

b) L'audit des applications informatiques en service : Il a pour objectif d'évaluer la fiabilité, la sécurité, l'efficacité et la performance des applications informatiques en production. Il peut avoir deux visées distinctes :

- ◆ **L'audit de fiabilité et de sécurité** : évalue la qualité du contrôle interne de l'application, la validité des données traitées, les contrôles programmés et les pistes d'audit.
- ◆ **L'audit d'efficacité et de performance** : apprécie l'adéquation de l'application aux besoins, sa contribution à la création de valeur, sa performance, sa rentabilité et sa capacité d'évolution.

1.1.3 Intérêt pour l'audit

La connaissance de cette typologie permet à l'auditeur de :

- ◆ **Adapter sa démarche** : chaque type d'audit présente des objectifs, des méthodes et des points de contrôle spécifiques
- ◆ **Délimiter son périmètre** : identifier clairement l'objet de la mission
- ◆ **Identifier les risques** : chaque type d'audit est associé à des risques particuliers
- ◆ **Formuler des recommandations appropriées** : adaptées à la nature de l'audit réalisé

1.1.4 Distinction et convergence des audits de sécurité et des applications en service

Le tableau 1.3 présente de manière synthétique les différences et les points communs entre l'audit de sécurité et l'audit applicatif.



TABLE 1.3 – Distinction et convergence entre audit de sécurité et audit applicatif

Dimension	Audit de sécurité	Audit applicatif
Distinction		
Question centrale	L'application est-elle protégée?	Fait-elle ce qu'elle doit?
Référentiel	ISO 27001, OWASP, NIST	COBIT, ISO 27005, expression des besoins utilisateurs, manuel de procédure métier
Profil auditeur	Expert cybersécurité	Expert métier
Livrables	Rapport de vulnérabilités	Rapport de conformité fonctionnelle
Convergence		
Objectif final	Assurer la fiabilité du SI	
Méthodologie	Basée sur les risques de sécurité	Basée sur les risques fonctionnels
Référentiel	Standards, politique de sécurité	Standards, cahier des charges fonctionnel, manuel de procédure interne
Collecte de preuves	Entretiens, inspections, tests	
Restitution	Rapport + plan d'actions	

1.1.5 Application aux PME de type SOLTEC

Conformément à la loi n°2010/001 du 13 avril 2010 portant promotion des Petites et Moyennes Entreprises au Cameroun, modifiée par la loi n°2015/010 du 16 juillet 2015 [10], SOLTEC est classée parmi les petites et moyennes entreprises (PME) au sens de la réglementation camerounaise. Cette qualification est déterminante pour comprendre les contraintes qui ont motivé ce travail : des ressources humaines, techniques et financières limitées qui ne permettent pas à SOLTEC de financer deux missions d'audit distinctes sur un même cycle budgétaire. C'est précisément pour répondre à cette contrainte que la présente recherche propose une méthode unifiée, permettant de réaliser en une seule mission l'équivalent de deux audits distincts.

Par ailleurs, SOLTEC est un éditeur de logiciel parmi lesquels GIDOCEP. De ce fait, elle a l'obligation légale de se soumettre à des audits annuels. Cette situation pose une question centrale : quelle méthode choisir pour réaliser en une seule mission d'audit les besoins d'un tel établissement? Il nous est donc paru évident de proposer l'unification de ces deux types d'audit, que nous développerons au chapitre 2.

Les principales raisons qui ont guidé ce choix sont :

- ◆ **L'inséparabilité technique.** Une vulnérabilité n'a pas le même impact selon l'endroit où elle se trouve . Par exemple, une injection SQL qui permet de voir des données dans un module de recherche n'est pas aussi grave qu'une injection SQL qui permet de modifier des ordres de paiement. Dans le premier cas, on peut consulter des informations. Dans le



second, on peut voler de l'argent. C'est la différence entre une fuite d'informations et un vol pur et simple. On ne peut donc pas évaluer la sécurité d'une application sans comprendre son fonctionnement : une même vulnérabilité technique peut avoir des conséquences très différentes selon l'endroit où elle se trouve.

- ◆ **L'assurance globale attendue.** Les établissements publics qui utilisent GIDOCEP attendent une seule garantie : que l'application gère et protège correctement leurs données financières. Un audit unifié répond à cette attente en produisant une vision complète et cohérente de l'état de l'application.
- ◆ **La contrainte de ressources.** Une PME comme SOLTEC ne peut financer deux missions d'audit séparées sur un même cycle budgétaire. Une méthode unifiée permet de réaliser un audit unique, couvrant les deux dimensions, à un coût maîtrisé.
- ◆ **L'unicité de l'application.** GIDOCEP est une application unique, développée et maintenue par SOLTEC. Elle constitue un périmètre cohérent pour un audit unifié. Séparer les audits conduirait à une vision fragmentée, des recommandations potentiellement contradictoires et des coûts supplémentaires.

1.1.6 Fondements de la standardisation en cybersécurité

La standardisation est le processus de définition et d'application de règles, de normes et de procédures communes pour garantir l'uniformité, la qualité et la reproductibilité des activités[7]. Dans le contexte de l'audit, elle vise à réduire la variabilité liée aux pratiques individuelles des auditeurs et à garantir la comparabilité des résultats.

Selon Fenz et al. [11], la standardisation des processus d'audit poursuit cinq objectifs : reproductibilité, comparabilité, efficience, transparence et professionnalisation. Elle opère sur quatre niveaux : processus, outils, livrables et métriques. Notre méthode opère simultanément sur ces quatre niveaux.

1.1.7 Normes et standards d'usage commun en audit :

a) Celles qui organisent la mission d'audit

- ◆ **L'ISO 19011 :2018** est le standard international qui fournit les lignes directrices pour l'audit des systèmes de management. Elle définit les principes, la gestion des programmes d'audit et la conduite des audits. Ses sept principes directeurs s'appliquent directement à MUSA :

1. Intégrité : L'auditeur doit faire preuve de probité et de sincérité dans l'exercice de ses fonctions.

2. Présentation impartiale : Les constats, conclusions et rapports doivent refléter fidèlement les activités d'audit.





3. Conscience professionnelle : L'auditeur doit faire preuve de diligence et de jugement professionnel.
 4. Confidentialité : Les informations obtenues dans le cadre de l'audit ne doivent pas être divulguées.
 5. Indépendance : L'auditeur doit être libre de tout conflit d'intérêts.
 6. Approche fondée sur les preuves : Les conclusions doivent être basées sur des preuves vérifiables.
 7. Approche fondée sur les risques : L'audit doit prendre en compte les risques pour atteindre ses objectifs.
- ♦ Les normes IIA : gouvernance et déontologie

TABLE 1.4 – Normes IIA intégrées dans MUSA

Norme	Contenu	Intégration notre méthode
1100 - Indépendance	Objectivité de l'auditeur	Déclaration signée avant mission
2200 - Planification	Objectifs SMART	Plan + programme obligatoires
2330 - Documentation	Papiers de travail tracés	PTxx, archivage 5 ans
2340 - Supervision	Revue lead auditor	Revue quotidienne
2500 - Suivi obligatoire	Recommandations suivies	Revue trimestrielles
2600 - Escalade	Risque résiduel	Procédure en 3 niveaux

b) celles qui organisent le déploiement en mission d'audit :

- ♦ ISO/IEC 27001 :2022 : 93 contrôles répartis en 4 domaines : organisationnel (37), humain (8), physique (14) et technologique (34).
- ♦ OWASP ASVS(Application Security Verification Standard) :

TABLE 1.5 – Les trois niveaux de l'OWASP ASVS

Niveau	Type d'application	Contrôles	Profondeur
1 - Basique	Applications internes	40	Tests automatiques
2 - Standard	Données sensibles	100	Tests manuels
3 - Approfondi	Applications critiques	150	Tests exhaustifs

- ♦ NIST SP 800-115(National Institute of Standards and Technology) : Méthodologie en trois phases : planification, exécution et post-exploitation. Recommande l'usage d'au moins deux outils de scan , pratique reprise dans MUSA.

Afin de situer notre méthode par rapport aux référentiels existants, le tableau ci-dessous présente une comparaison synthétique des principales normes et standards utilisés dans





le domaine de l'audit des systèmes d'information, selon leur objet et leur apport à notre méthode.

TABLE 1.6 – Comparaison des normes et standards d'audit

Norme/Standard	Objet	Apport à la méthode
ISO 19011 :2018	Lignes directrices pour l'audit des systèmes de management	Structure en 5 phases, 7 principes directeurs (intégrité, impartialité, professionnalisme, confidentialité, indépendance, preuves, risques)
Normes IIA (IPPF)	Gouvernance et déontologie de l'audit interne	Indépendance (1100), planification SMART (2200), documentation (2330), supervision (2340), suivi obligatoire (2500), escalade (2600)
ISO/IEC 27001 :2022	Management de la sécurité de l'information	93 contrôles répartis en 4 domaines : organisationnel (37), humain (8), physique (14), technologique (34)
OWASP ASVS v4.0.3	Vérification de la sécurité des applications web	3 niveaux (basique, standard, approfondi), 14 catégories de contrôles, 100 contrôles pour le niveau 2
NIST SP 800-115	Tests et évaluations de sécurité	Méthodologie en 3 phases (planification, exécution, post-exploitation), recommandation d'au moins 2 outils de scan

1.1.8 Outils utilisés dans une mission d'audit

Une mission d'audit s'appuie sur un ensemble d'outils permettant de garantir la rigueur, la traçabilité et la reproductibilité des travaux. Les plus courants sont :

Papiers de travail. Les papiers de travail sont des documents structurés utilisés par les auditeurs pour consigner leurs observations, les preuves collectées et leurs conclusions. Ils constituent la base de la traçabilité de l'audit et permettent de justifier les constats et recommandations formulés dans le rapport final. Dans la méthode, les papiers de travail sont organisés en six fichiers L01 à L06, chacun correspondant à une phase spécifique de l'audit.

Grilles d'analyse et checklists. Les grilles d'analyse et checklists sont des outils de contrôle qui garantissent que tous les points prévus ont été examinés. Elles structurent l'évaluation en listant les assertions à vérifier et en prévoyant des colonnes pour les réponses (Conforme, Non Conforme, Zone Grise), les observations et les références aux preuves. Elles sont généralement issues des référentiels normatifs (ISO 27001, OWASP ASVS, etc.).



Guides d'entretien. Les guides d'entretien sont des questionnaires structurés utilisés lors des échanges avec les différents interlocuteurs (direction, responsables techniques, utilisateurs). Ils garantissent que les mêmes thèmes sont abordés avec chaque interlocuteur, ce qui favorise la standardisation et la comparabilité des informations recueillies.

Matrice des risques. La matrice des risques est un outil de visualisation et de priorisation des risques basé sur deux dimensions : la probabilité (P) et l'impact (I). Le score de risque $R = P \times I$ permet de classer les vulnérabilités identifiées par niveau de priorité et de guider les actions correctives. C'est un des outils pour le dimensionnement d'efforts dans une mission d'audit.

Outils techniques de test. L'audit technique mobilise des outils spécifiques pour les tests de sécurité : scanners de vulnérabilités (Nmap, OpenVAS), outils d'analyse dynamique (OWASP ZAP), outils d'analyse statique (SonarQube), etc. Ces outils permettent de détecter les failles techniques et de produire des preuves objectives.

Modèles de rapport. Le rapport d'audit est le livrable final de la mission. Il synthétise les constats, présente les métriques calculées et formule des recommandations. Sa structure est standardisée pour garantir la clarté et la comparabilité des résultats.

Ces outils, lorsqu'ils sont standardisés et réutilisables, constituent un capital méthodologique et une base de connaissance qui s'enrichit à chaque cycle d'audit et contribue à l'amélioration continue de la qualité des missions.

1.2 Etat de l'art de la pratique de l'audit des SI dans les PME Camerounaises

1.2.1 La démarche d'audit de l'ANTIC (D'après la dernière mise à jour disponible en ligne)

1.2.1.1 a) Présentation de l'ANTIC

L'ANTIC a été créée par décret n°2002/092 du 08 avril 2002 [3] et est chargée de l'audit de sécurité des systèmes d'information au sein du territoire. Conformément au décret n°2012/1643/PM du 14 juin 2012 [12], l'audit de sécurité obligatoire s'applique aux opérateurs de communications électroniques, aux autorités de certification, ainsi qu'aux entreprises traitant des données automatisées de leurs clients.



1.2.1.2 b) Phases d'audit exécutées à l'ANTIC

Lors de la Conférence de formation avec les cabinets agréés organisé par l'ANTIC¹, le responsable de la planification a présenté la démarche d'audit de l'ANTIC en **cinq phases**.

TABLE 1.7 – Les cinq phases de la démarche d'audit ANTIC (Conférence 29 avril 2026)

#	Phase	Activités clés	Livrables
1	Correspondence Follow-up	Notification, confirmation, équipe 2 à 4 membres	Lettre de mission
2	Mission Preparation	Collecte documentaire, recon- naissance passive	Charte d'audit
3	On-Site Audit	Audit organisationnel, phy- sique, technologique, risques	Matrice des risques
4	Reporting & Closing	Pré-clôture, rapport transmis le jour même	Rapport + plan d'actions
5	Post-Audit	Suivi recommandations, statis- tiques	Rapports de suivi

1.2.2 La démarche du CONSUE et l'innovation de l'entropie de Shannon en audit

1.2.2.1 a) Présentation du CONSUE et phases d'audit exécutées au CONSUE

Le CONSUE (Contrôle Supérieur de l'État) est l'institution supérieure de contrôle des finances publiques du Cameroun. Il a été régi par décret n°2013/287 du 04 septembre 2013 portant organisation des services du Contrôle supérieur de l'État. Il est placé sous l'autorité directe du Président de la République et constitue l'institution supérieure de contrôle (ISC) du Cameroun, chargée de l'audit externe.

Conformément à l'article 2, alinéa 3 du décret précité, le CONSUE effectue, dans l'exercice de ses attributions, un contrôle de conformité et de régularité, un contrôle financier, un contrôle de performance, un contrôle de l'environnement et un **contrôle des systèmes d'information**. C'est dans le cadre de ce dernier que s'inscrit son action dans le domaine de l'audit des systèmes d'information.

La méthodologie du CONSUE s'inscrit dans le cadre des **Normes internationales des institutions supérieures de contrôle des finances publiques (ISSAI)** établies par l'INTOSAI (Organisation internationale des institutions supérieures de contrôle des finances publiques).

Si le CONSUE opère dans le cadre des normes ISSAI pour la typologie de ses missions (audit financier, de performance et de conformité), sa démarche opérationnelle d'audit des

1. Source primaire non publiée, notes de terrain et enregistrements audio collectés par l'auteure lors de la Conférence des cabinets agréés organisée par l'ANTIC à Yaoundé le 29 avril 2026.



systèmes d'information s'appuie spécifiquement sur **ISSAI 5300 : lignes directrices pour l'audit des SI qui est une internalisation formel de la normes ISO 19011 :2018** au secteur public. C'est pourquoi la conduite d'un audit des SI au CONSUE suit les **cinq phases** définies par cette norme internationale.

TABLE 1.8 – Les cinq phases de la démarche d'audit du CONSUE pour l'audit des SI (ISO 19011 :2018)²

#	Phase ISO 19011	Activités clés	Livrables
1	Travaux préparatoires	Nomination responsable équipe, objectifs, périmètre	Ordre de mission, fiches techniques
2	Planification	Revue documentaire, plan d'audit, répartition tâches	Plan d'audit, matrice des risques
3	Exécution	Réunion d'ouverture, preuves, entretiens, réunion clôture	Pré-observations
4	Élaboration et diffusion du rapport	Rédaction constats, conclusions	Rapport d'audit
5	Suivi	Archivage, vérification re-commandations	Rapports de suivi

Ces phases ont été schématisées dans le cadre d'un document de formation des auditeurs stagiaire au CONSUE visible Annexe 3.4.2

Cette démarche s'applique indifféremment aux trois types d'audit pratiqués par le CONSUE :

- ◆ **L'audit financier** : vérifie si les états financiers reflètent fidèlement la situation financière conformément au référentiel en vigueur (normes ISSAI 200).
- ◆ **L'audit de performance** : évalue l'économie, l'efficacité et l'efficacité de la gestion des ressources publiques (normes ISSAI 300).
- ◆ **L'audit de conformité** : s'assure que les activités et opérations financières respectent les lois, règlements et budgets applicables (normes ISSAI 400).

1.2.2.2 b) L'innovation du CONSUE : l'entropie de Shannon appliqué à l'audit et la zone grise

Au-delà des normes ISSAI, le CONSUE a développé une innovation majeure dans le cadre de ses missions d'audit des systèmes d'information. En effet depuis octobre 2018, les résultats des travaux d'analyse des missions réalisés dans la division audit des SI, ont conduit à l'introduction de l'entropie de Shannon comme outil de mesure de l'incertitude issus des réponses des audités [8].



Traditionnellement, l'audit des systèmes d'information ne connaît que deux états de réponse : Conforme (OUI) ou Non Conforme (NON). Cette dichotomie, héritée des pratiques classiques de vérification, répond à une logique simple : un contrôle existe-t-il ou est appliqué ?.

Cependant, dans les travaux récents conduites dans les missions d'audit du CONSUPE, cette bipolarité ne capture pas l'ensemble des réalités du terrain. Lorsqu'un auditeur interroge un responsable sur l'existence d'une politique de sécurité, ce dernier peut ne pas avoir d'éléments de réponse. Une troisième voie PAS (Pas Assez Savoir) a donc été formalisée et est employé pour capturer la Zone Grise caractérisé par l'absence d'information de l'audit. Ce troisième état, introduit est fondamental. Il ne signifie pas que le contrôle est absent, mais que l'information nécessaire pour conclure n'est pas disponible au moment de l'audit. Les causes peuvent être multiples :

- ◆ **Absence de circulation de l'information** : le document existe mais n'est pas accessible à l'interlocuteur interrogé.
- ◆ **Absence de formation** : l'interlocuteur n'a pas été formé sur le sujet.
- ◆ **Problème de compréhension** : la question posée n'a pas été comprise correctement.
- ◆ **Preuves insuffisantes** : les éléments disponibles ne permettent pas de conclure.

L'introduction de ce troisième état de réponse a une conséquence majeure : elle rend possible la **quantification de l'incertitude**. C'est précisément ce que permet l'entropie de Shannon, qui mesure le degré de dispersion des réponses entre les trois états possibles.

TABLE 1.9 – Les trois états de réponse

État	Signification	Interprétation
Conforme (C)	OUI	Le contrôle existe et est appliqué correctement
Non Conforme (NC)	NON	Le contrôle n'existe pas ou n'est pas appliqué
Zone Grise (ZG)	PAS	Information insuffisante pour conclure ; investigation complémentaire nécessaire

1.2.3 Analyse croisée des démarches ANTIC et CONSUPE

L'ANTIC et le CONSUPE constituent les deux principales institutions étatiques camerounaises intervenant dans l'audit des systèmes d'information. Leurs approches, bien que complémentaires, présentent des différences fondamentales qu'il convient d'analyser pour identifier les forces et lacunes de chacune, et justifier la pertinence de notre unification pour les PME.



1.2.3.1 a) Forces et apports spécifiques

L'ANTIC apporte une démarche structurée couvrant l'ensemble des dimensions d'un audit (organisationnelle, humaine, physique et technologique). Son ancrage réglementaire (loi n°2010/012) confère à ses recommandations une valeur juridiquement opposable. La structure en cinq phases de l'ANTIC garantit une couverture exhaustive de la mission d'audit, depuis la notification jusqu'au suivi post-audit. L'ANTIC assure un accompagnement systématique des structures auditées pendant trois mois après la restitution du rapport, ce qui favorise la mise en œuvre effective des recommandations.

Le CONSUPE, quant à lui, s'appuie sur une démarche structurée en cinq phases, conformément aux normes ISSAI de l'INTOSAI. Il apporte une innovation conceptuelle majeure : l'introduction de la zone grise comme troisième état de réponse et l'utilisation de l'entropie de Shannon pour quantifier l'incertitude dans les réponses des audités. Il intègre également les normes IIA (Institute of Internal Auditors) dans sa pratique, ce qui renforce la dimension éthique et professionnelle de ses missions.

1.2.3.2 b) Limites communes et spécifiques

Malgré leurs forces respectives, les deux approches présentent des lacunes :

- ◆ **Formalisation insuffisante** : les procédures ne sont pas suffisamment détaillées, ce qui laisse place à l'interprétation personnelle des auditeurs.
- ◆ **Différence de formalisation des standards de conduite** : l'ANTIC cite l'ISO 19011 sans le formaliser dans ses procédures internes³ ; le CONSUPE, en revanche, s'appuie sur les lignes directrices de l'ISSAI 5300, qui constituent une internalisation structurée des principes de l'ISO 19011.
- ◆ **Absence d'outils réutilisables à l'ANTIC** : chaque mission d'audit repart de zéro, sans capitalisation des acquis.
- ◆ **Séparation des audits** : l'ANTIC réalise des audits de sécurité, le CONSUPE des audits des applications en service au sens du CHAI.
- ◆ **Suivi non systématique au CONSUPE** : contrairement à l'ANTIC qui assure un accompagnement post-audit systématique, le CONSUPE ne garantit pas un suivi des recommandations. Une personne peut réaliser l'audit et une autre, voire aucune, assurer le suivi, ce qui fragilise la continuité et l'efficacité des actions correctives.⁴

1.2.3.3 c) Complémentarité et séparation

L'ANTIC réalise des audits de sécurité, tandis que le CONSUPE réalise des audits des applications en service. Tous deux s'appuient sur une démarche en cinq phases, mais avec

3. D'après l'exploitation du questionnaire soumis aux auditeurs de l'ANTIC

4. D'après l'exploitation du questionnaire soumis aux auditeurs du CONSUPE





des finalités différentes. Cette séparation conduit à une vision fragmentée de la sécurité des applications : une application peut être sécurisée techniquement (audit ANTIC) mais présenter des failles dans sa logique métier (audit CONSUE), ou inversement.

TABLE 1.10 – Analyse croisée des démarches ANTIC et CONSUE

Dimension	ANTIC	CONSUE
Question centrale	L'application est-elle protégée ?	L'application fait-elle ce qu'elle doit ?
Type d'audit	Audit de sécurité	Audit des applications en service
Démarche	Structurée en 5 phases	Structurée en 5 phases
Couverture	4 dimensions (orga, humain, physique, technique)	Axe fonctionnel principalement
Référentiels	ISO 19011 (citée)	ISSAI 5300, normes IIA
Formalisation	Partielle	Partielle (essentiellement conceptuelle)
Reproductibilité	Non mesurée	Mesurée par l'entropie
Standards de conduite	Non formalisés	Oui (IIA)
Gouvernance	Absente	Partielle (normes IIA)
Suivi post-audit	Systématique (accompagnement 3 mois)	Non systématique (personne différente, voire absence de suivi)
Outils réutilisables	Non formalisés	Oui (outils réutilisables d'une mission à une autre)
Fusion sécurité/applicatif	Non (sécurité uniquement)	Non (applicatif uniquement)

1.2.4 Synthèse et positionnement de la méthode

L'analyse croisée des démarches ANTIC et CONSUE révèle que ces deux approches, s'appuient toutes deux sur cinq phases et sont complémentaires. L'ANTIC apporte la structure et un suivi systématique ; le CONSUE apporte l'innovation conceptuelle (entropie, zone grise) et une gouvernance (IIA).

C'est dans ce contexte que se positionne notre méthode MUSA, elle se base sur des contributions existantes. Elle combine les forces des deux approches : la structure de l'ANTIC (5 phases, 4 axes, suivi systématique) et l'innovation du CONSUE (entropie de Shannon, zone grise, normes IIA) tout en les étendant dans la formalisation d'une méthode unifiée en intégrant les standards de conduite (ISO 19011), d'une gouvernance renforcée (normes IIA), d'outils réutilisables (L01 à L06) et d'un suivi post-audit systématique.

MÉTHODOLOGIE

Ce chapitre présente notre méthode **MUSA** (Méthode Unifiée d'Audit de Sécurité Applicative), une démarche standardisée qui répond point par point à ces lacunes. La présentation suit une progression logique : des principes fondateurs vers les détails opérationnels, des structures générales vers les outils concrets.

Pour garantir son opérationnalité immédiate, la description de MUSA s'appuie sur un dossier de mission type composé de sept outils standardisés : l'aide-mémoire de mission, la fiche technique, les termes de référence (TDR), la liste des documents sollicités, l'outil de collecte (Outil Tableur) et le plan d'audit. Ces outils, conçus pour être génériques et réutilisables sur toute application, constituent le socle méthodologique de la démarche. Le tableau 2.2 présente ces six outils avec leurs formats et leurs fonctions.



2.1 Principes directeurs de MUSA

Les principes de notre méthode sont les règles fondamentales qui gouvernent chaque choix méthodologique de l'outil. Ils sont directement observables dans la conception du dossier de mission : la fusion des grilles, le recours à l'entropie, la formalisation des échanges phase par phase, la réutilisabilité du classeur, l'ancrage réglementaire camerounais et la capture explicite de l'incertitude par un troisième état de réponse.

2.1.1 Principe 1 : Optimisation par la fusion sécurité + applicatif

Problème posé : un audit de sécurité et un audit applicatif menés séparément doublent le nombre de missions, de questionnaires et de cycles budgétaires nécessaires pour couvrir une même application.

Réponse : chaque assertion de l'Outil tableur associe dès sa conception un critère technique et un critère organisationnel, évalués séparément puis fusionnés en une réponse unique. Le classeur Outil Tableur contient d'ailleurs deux onglets de comparaison, *APPLICATIF* et *SECURITE*, qui reconstituent à titre pédagogique ce à quoi ressembleraient les deux audits s'ils étaient menés séparément.

2.1.2 Principe 2 : Objectivation de l'incertitude par domaine

Problème posé : une grille de conformité binaire (Conforme / Non Conforme) ne permet pas de distinguer un domaine où l'auditeur dispose de preuves fermes d'un domaine où l'information fait simplement défaut.

Réponse : chaque sous-réponse (technique et organisationnelle) est saisie sur trois valeurs : OK (preuve obtenue et probante), KO (preuve obtenue et défaillante) ou NSP (preuve insuffisante pour conclure). La réponse fusionnée qui en découle est à son tour tripartite : **O** (Conforme, technique = OK et organisationnel = OK), **N** (Non Conforme, au moins une composante KO) ou **PAS** (Pas Assez de Savoir, zone grise : aucune défaillance avérée mais au moins un NSP). L'entropie est ensuite calculée, pour chacun des cinq domaines, sur la dispersion des réponses OUI/NON/PAS obtenues sur les assertions de ce domaine.

2.1.3 Principe 3 : Formalisation complète des procédures

Problème posé : une procédure d'audit décrite de manière informelle dépend de la compétence individuelle de l'auditeur et n'est pas transférable.

Réponse : l'aide-mémoire de mission adapté à notre méthode décrit et inspirée de l'annexe 3.4.2 chacune des cinq phases selon un triptyque systématique, *inputs*, *activités clés*, *outputs* de sorte qu'un auditeur ne connaissant pas encore le dossier puisse situer précisément ce qu'il doit recevoir, faire et produire à chaque étape.



2.1.4 Principe 4 : Gouvernance rigoureuse

Problème posé : une mission d'audit sans cadre de gouvernance explicite manque de crédibilité et de traçabilité.

Réponse : la fiche technique de mission ancre explicitement la démarche sur l'**ISO 19011 :2018** (lignes directrices pour l'audit des systèmes de management) et sur les **normes IIA 2024** (Institute of Internal Auditors) comme référentiels de conduite de mission, aux côtés des référentiels de contenu (ISO/IEC 27001 :2022, ISO/IEC 27002 :2022, OWASP ASVS v4.0.3).

2.1.5 Principe 5 : Réutilisabilité systématique

Problème posé : un rapport d'audit ponctuel ne capitalise pas l'expérience acquise d'un cycle à l'autre.

Réponse : le dossier de mission (fiche technique, TDR, documents sollicités, Outil Tableur, guide d'entretien, plan d'audit) constitue un **capital méthodologique** conçu pour être réutilisé sur plusieurs applications.

2.1.6 Principe 6 : Ancrage local

Problème posé : un référentiel international importé sans adaptation ignore le cadre réglementaire camerounais.

Réponse : le dossier de mission cite explicitement la **loi n°2010/012 du 21 décembre 2010** relative à la cybersécurité et à la cybercriminalité au Cameroun, le décret n°2019/150 du 22 mars 2019 portant organisation et fonctionnement de l'ANTIC [13], et le **décret n°2013/287** portant organisation des services du Contrôle supérieur de l'État (CONSUPE).

2.1.7 Principe 7 : Capture de l'incertitude

Problème posé : dans l'audit classique en dehors de l'usage de l'innovation du CONSUPE [8], un « NON » peut recouvrir des réalités différentes : absence réelle du contrôle, ou simple manque d'information de l'audité.

Réponse : l'état **PAS** (zone grise) capture spécifiquement cette situation.

2.2 Structure globale de la méthode

2.2.1 Les cinq phases de la mission

Conformément à l'ISO 19011 :18, nous avons conservés les 5 phases d'une mission d'audit. À la différence d'un audit SI classique qui sépare un cycle « applicatif » d'un cycle « sécurité »,



dans chaque phase, la méthode produit des livrables déjà fusionnés, exploitables en un seul passage terrain, une contrainte assumée pour rester compatible avec le budget d'une PME.

TABLE 2.1 – Les cinq phases de notre méthode

#	Phase	Fonction
1	Travaux préparatoires	Prise de connaissance de GIDOCÉP, identification préliminaire des risques par domaine, collecte documentaire (T01-T05, G01-G13)
2	Planification	Cotation des risques préliminaires, construction de la matrice Domaine → Assertion → Question → Papier de travail, finalisation du plan d'audit
3	Exécution (Terrain)	Entretiens par domaine, tests techniques (droits d'accès, chiffrement, configuration, journalisation), tests de restauration de sauvegarde
4	Communication des résultats	Consolidation des constats et du scoring, procédure contradictoire avec l'audité, rédaction du rapport définitif
5	Suivi des recommandations	Vérification des preuves de mise en œuvre, <i>hors cycle de mémoire, à titre indicatif</i>

Les recommandations non levées à l'issue d'un cycle réalimentent, le cas échéant, la Phase 1 du cycle suivant.

2.2.2 Les outils de la méthode

MUSA repose sur un ensemble de sept outils standardisés qui structurent l'ensemble de la mission d'audit. Contrairement à une architecture documentaire qui multiplierait un fichier Excel par phase, la méthode privilégie un **classeur de collecte unique** l'Outil Tableur entouré de six documents Word. Tableau ci-dessous 2.2 :

TABLE 2.2 – Le dossier de mission MUSA - sept outils standardisés

N°	Nom de l'outil	Format	Fonction
1	Aide-mémoire de mission	Document Word	Synthèse des cinq phases, architecture documentaire et rôle de chaque outil dans le cycle d'audit
2	Fiche technique de mission	Document Word	Cadrage synthétique : objectif, périmètre, approche, référentiels, équipe, livrables
3	Termes de Référence (TDR)	Document Word	Contexte, objectifs détaillés, périmètre IN/OUT, registre des risques préliminaires, calendrier
4	Documents sollicités	Document Word	Liste des pièces à obtenir en Phase 1 : 5 documents transversaux (T01 à T05) ¹ et 13 documents spécifiques (G01 à G13) ²
5	Outil Tableur	Classeur Excel	Outil unique de collecte, de scoring et de restitution : 21 assertions, grille O/N/PAS, entropie, maturité CMMi
6	Guide d'entretien fusionné	Document Word	41 questions couvrant simultanément le volet technique et le volet organisationnel de chaque assertion
7	Plan d'audit	Document Word	Objectifs, référentiels, évaluation <i>a priori</i> du contrôle interne, programme de travail par domaine

L'Outil tableur (n°4) est le cœur de la méthode. Il est structuré autour d'une décomposition hiérarchique N8 : chaque assertion fusionnée est décrite par un domaine (N1), un point de contrôle (N2), un objectif de contrôle (N3), un critère technique (N4a) et un critère organisationnel (N4b), un élément de preuve technique (N5a) et un élément de preuve organisationnel (N5b), une question d'évaluation fusionnée (N6), un risque activé si la réponse est N (N7) et une conséquence (N8)¹.

Les preuves collectées sur le terrain sont organisées par domaine (A à E) dans les onglets correspondants de l'Outil tableur, qui tiennent lieu de papiers de travail PT-A à PT-E, en écho direct aux cinq domaines de la décomposition N8.

2.2.3 Risques préliminaires et cotation dans le TDR

En phase de planification (Phase 1), le TDR (Outil n°2) identifie des **risques préliminaires** qui sont cotés selon une échelle simplifiée : **Faible/Modéré/Elevé/Critique** comme dans la figure 2.1. Cette cotation est une évaluation *à priori*, basée sur l'expérience de l'auditeur et la connaissance du domaine. Elle ne repose pas sur une formule mathématique ; elle sert à **guider la priorisation des investigations** en phase terrain.

Le tableau 2.3 présente un exemple de risques préliminaires identifiés pour une application de gestion comptable :

1. Cette décomposition s'inspire du cours d'audit des SI INF3226 [14], HN3-ENSPY.



TABLE 2.3 – Risques préliminaires identifiés dans le TDR

N°	Risque identifié	Domaine	Criticité ²
R01	Absence de séparation stricte des rôles applicatifs	A	ÉLEVÉ
R02	Journalisation non exploitée malgré son existence technique	B	ÉLEVÉ
R03	Absence de politique de classification et de chiffrement	C	ÉLEVÉ
R04	Sauvegardes jamais testées	D	ÉLEVÉ
R05	Absence de propriétaire applicatif désigné	E	MODERE
R06	Écart entre maturité technique et organisationnelle	Transversal	MODERE

Cette cotation préliminaire ne repose pas sur une formule $R = P \times I$; elle s'appuie sur une appréciation qualitative qui sera ensuite **vérifiée et quantifiée** par le score de risque $R = P \times I$ lors de la phase d'exécution. La distinction est fondamentale :

- ◆ **Avant l'audit (Phase 1)** : cotation qualitative **Faible/Modéré/Elevé/Critique**) pour orienter les investigations
- ◆ **Pendant l'audit (Phase 3)** : quantification par $R = P \times I$ (1 à 16) pour chaque vulnérabilité confirmée

2.3 Les cinq phases d'une mission d'audit dans la méthode

MUSA structure toute mission d'audit en **cinq phases séquentielles** conformément à ISO 19011 :18. Chaque phase est décrite selon un triptyque³ systématique : *inputs* (documents entrants), *activités clés* et *outputs* (livrables produits). Cette architecture garantit la traçabilité complète des travaux, depuis la planification jusqu'à la clôture du cycle d'audit.

3. Un triptyque est, dans son sens premier, une œuvre picturale ou graphique composée de trois panneaux articulés autour d'une même thématique. Dans le contexte méthodologique de notre méthode, le triptyque opérationnel désigne la structure systématique en trois éléments qui organise la description de chaque phase d'audit



2.3.1 Phase 1 : Travaux préparatoires

La Phase 1 constitue le fondement de toute la mission. Une préparation insuffisante entraîne invariablement des lacunes dans les phases suivantes : périmètre mal délimité, équipe inadaptée, documents manquants. Cette phase est alignée sur l'**ISO 19011 :2018** §6.2 (déclenchement) et §6.3 (préparation).

TABLE 2.4 – Phase 1 : Travaux préparatoires

Élément	Détail
Inputs	Demande formelle du commanditaire, documentation disponible sur l'application (spécifications, contrats si existants), organigramme simplifié de l'organisation
Activités clés	Prise de connaissance de l'application ; identification des risques inhérents par domaine (A à E), sans présupposer l'existence des contrôles ; collecte des documents transversaux (T01-T05) et spécifiques (G01-G13) ; évaluation de la faisabilité ; constitution de l'équipe d'audit ; signature des déclarations d'indépendance
Outputs	Fiche technique + TDR signés ; cartographie préliminaire des risques ; dossier documentaire collecté

2.3.1.1 a) Cadrage de la mission

La **fiche technique** (Outil n°1) fixe en une page l'intitulé de la mission, le commanditaire, l'objectif général, le périmètre applicatif, l'approche méthodologique et les référentiels retenus. Elle précise la composition de l'équipe d'audit, qui doit réunir les compétences techniques et fonctionnelles nécessaires à la fusion des deux types d'audit.

Les **Termes de Référence (TDR)** (Outil n°2) détaillent le contexte, les objectifs spécifiques par domaine, le périmètre inclus/exclu, un registre de risques préliminaires cotés en **Élevé / Moyen / Faible** et un calendrier indicatif. Ce document est soumis à validation avant tout démarrage de collecte.

2.3.1.2 b) Collecte documentaire (Outil n°3)

La liste des documents sollicités distingue deux catégories :

- ◆ **5 documents transversaux (T01 à T05)** : organigramme, lettre de mission, fiche technique/TDR signés, audits antérieurs, liste des interlocuteurs et planning ;
- ◆ **13 documents spécifiques (G01 à G13)** : spécifications fonctionnelles et techniques, schéma d'architecture, matrice des droits d'accès, politique de mots de passe, configuration et logs de journalisation, politique de chiffrement, règles de validation des entrées/sorties,



documentation des interfaces inter-applicatives, journal de sauvegarde, preuve de désignation du RSSI, rapport de gestion des patches, rapport de conformité de durcissement.

Chaque document collecté alimente une ou plusieurs assertions de l'Outil tableur. Son absence n'est pas traitée comme une simple lacune administrative mais comme un élément de preuve manquant, susceptible de conduire à une réponse **PAS** sur l'assertion concernée.

2.3.2 Phase 2 : Planification

La Phase 2 transforme les éléments collectés en un plan d'action détaillé. Elle est alignée sur l'**ISO 19011 :2018** §6.4 (préparation du plan d'audit) et les normes **IIA 2200** (planification) et **IIA 2210** (objectifs SMART).

TABLE 2.5 – Phase 2 : Planification

Élément	Détail
Inputs	Fiche technique et TDR validés ; cartographie préliminaire des risques ; dossier documentaire collecté
Activités clés	Cotation des risques préliminaires ; construction de la matrice Domaine → Assertion → Question → Papier de travail ; finalisation du plan d'audit ; préparation du guide d'entretien fusionné ; initialisation de l'Outil tableur
Outputs	Plan d'audit validé ; guide d'entretien fusionné finalisé ; Outil tableur (grille O/N/PAS + entropie) initialisé

Le **plan d'audit** (Outil n°6) fixe les référentiels retenus, formule une évaluation *à priori* du contrôle interne de l'organisation et décline un programme de travail par domaine (A à E), préparant directement l'affectation des papiers de travail PT-A à PT-E de la phase suivante.

Le **guide d'entretien** (Outil n°5) traduit chacune des 21 assertions en questions couvrant à la fois le volet technique et le volet organisationnel, il n'existe pas de questionnaire séparé « sécurité » et « applicatif ».

2.3.3 Phase 3 : Exécution (Terrain)

La Phase 3 constitue le cœur de l'audit. Elle se décompose en deux sous-phases menées de manière coordonnée : l'audit organisationnel et physique, puis l'audit technique. Cette phase est alignée sur l'**ISO 19011 :2018** §6.4 - 6.5, les normes **IIA 2300** (réalisation de la mission), **IIA 2310** (collecte des preuves), **IIA 2330** (documentation) et **IIA 2340** (supervision).



TABLE 2.6 – Phase 3 : Exécution (Terrain)

Élément	Détail
Inputs	Plan d'audit validé ; guide d'entretien fusionné ; accès aux documents collectés
Activités clés	Audit organisationnel (entretiens, inspection physique) ; audit technique (tests de sécurité) ; analyse des risques et évaluation de la maturité
Outputs	Papiers de travail par domaine (PT-A à PT-E) renseignés ; Outil tableur complété : réponses O/N/PAS, entropie de Shannon par domaine, maturité CMMi, criticité

2.3.3.1 a) Audit organisationnel et physique

L'audit organisationnel et physique évalue les dimensions organisationnelle, humaine et physique de la sécurité, conformément à la vision globale de l'ANTIC (quatre axes) et aux contrôles **ISO/IEC 27001 :2022** domaines 5 (Politiques de sécurité), 6 (Organisation) et 7 (Ressources humaines).

- ♦ **Entretiens standardisés** : Les entretiens sont menés avec trois catégories d'interlocuteurs, selon des guides d'entretien distincts :

TABLE 2.7 – Profils d'entretien et thèmes abordés

Profil	Thèmes principaux	Durée approximative
Direction / DG	Politique de sécurité, budget, gouvernance, conformité réglementaire	45-60 min
Responsable technique / Devs	Pratiques de codage, gestion des accès, tests de sécurité, architecture	60-90 min
Utilisateurs finaux	Pratiques d'authentification, comportements à risque, sensibilisation	20-30 min

- ♦ **Règle fondamentale de collecte de preuves** : Toute affirmation d'un interlocuteur doit être corroborée par une preuve documentaire, technique ou observationnelle. Par exemple, si un responsable déclare que les mots de passe sont chiffrés, l'auditeur ne valide pas sur cette seule déclaration ; il demande un extrait de code ou examine directement la configuration.
- ♦ **Inspection physique** : L'inspection physique est un examen visuel et documenté des locaux et des équipements. La grille couvre les zones suivantes :



- **Salle serveur / locaux techniques** : contrôle d'accès, climatisation, alimentation électrique (onduleurs), protection incendie, propreté
- **Postes de travail** : verrouillage des écrans, gestion des mots de passe (post-it, carnets), antivirus actif, mises à jour
- **Imprimantes** : documents sensibles non récupérés, contrôle d'accès, politique de conservation
- **Zones d'accès** : contrôle des entrées (badges, registres), visiteurs non accompagnés, affichage des consignes

Chaque point de contrôle est évalué selon l'état : **Conforme (C)** / **Non Conforme (NC)** / **Zone Grise (ZG)**.

2.3.3.2 b) Audit technique

L'audit technique constitue le volet technologique de l'audit. Il a pour objectif d'identifier les vulnérabilités liées au code source, à la configuration des systèmes, aux communications réseau et à la logique métier de l'application. Cette sous-phase s'appuie sur deux référentiels majeurs :

- La **méthodologie NIST SP 800-115**, qui structure les tests de sécurité en trois phases : planification, exécution et post-exploitation
 - L'**OWASP ASVS v4.0.3 niveau 2**, qui définit 100 contrôles répartis en 14 catégories (niveau adapté aux applications manipulant des données sensibles)
- ♦ **Condition préalable obligatoire** : Une autorisation écrite de test signée par le commanditaire est exigée avant tout test intrusif. Ce document précise le périmètre technique autorisé (systèmes, réseaux, applications), la période d'exécution, les techniques autorisées et interdites, ainsi que les contacts d'urgence en cas d'incident.
- ♦ **Types de tests réalisés** :

TABLE 2.8 – Types de tests de l'audit technique MUSA

Type de test	Outils recommandés	Objectif
Scan réseau	Nmap, Masscan	Détection des ports ouverts et services actifs
Scan vulnérabilités	OpenVAS, Nuclei	Détection de vulnérabilités connues (CVE)
Analyse dynamique (DAST)	OWASP ZAP, Burp Suite	Identification des failles applicatives (XSS, SQLi, CSRF)
Analyse statique (SAST)	SonarQube, Semgrep	Analyse du code source (si disponible)
Tests manuels	—	Authentification, contrôle d'accès (IDOR), logique métier





Conformément au **NIST SP 800-115**, MUSA recommande l'utilisation d'au moins deux outils distincts pour chaque type de scan, afin de limiter les faux positifs et faux négatifs.

♦ **Critères de validation des tests** : Pour chaque vulnérabilité identifiée, l'auditeur doit valider :

- **Reproductibilité** : la vulnérabilité est reproductible à volonté
- **Preuve** : capture d'écran, log, ou vidéo de l'exploitation
- **Impact démontré** : la conséquence est démontrée (exfiltration, élévation de privilèges, etc.)
- **Corrélation** : la vulnérabilité est corrélée avec une assertion de la méthode

2.3.3.3 c) Présentation de l'Outil tableur : décomposition, dérivation, entropie, maturité, criticité

L'Outil tableur est un classeur Excel structuré autour d'une **décomposition hiérarchique N8** : chaque assertion fusionnée est décrite par un domaine (N1), un point de contrôle (N2), un objectif de contrôle (N3), un critère technique (N4a) et un critère organisationnel (N4b), un élément de preuve technique (N5a) et un élément de preuve organisationnel (N5b), une question d'évaluation fusionnée (N6), un risque activé si la réponse est N (N7) et une conséquence (N8).

i) **Les 21 assertions et les 5 domaines** : L'Outil tableur compte **21 assertions** réparties sur **5 domaines** mais l'auditeur pourra adapter en fonction de l'application :

TABLE 2.9 – Les cinq domaines de l'Outil tableur

Domaine	Assertions couvertes	Nb
A. Authentification & Contrôle d'accès	Authentification (A1), Gestion des accès applicatifs (A2), Comptes inactifs (A3)	3
B. Journalisation & Traçabilité applicative	Journalisation applicative (B1), Détection d'intrusion (B2), Journalisation des consultations (G3)	3
C. Sécurité des données	Chiffrement (C1), Contrôle des entrées (C2), Contrôle des sorties (C3), Sécurité des interfaces (C4), Contrôle de version (G1), Classification (G2), Droits d'accès par document (G4)	7
D. Continuité & Sauvegarde applicative	Sauvegarde applicative (D1), Disponibilité applicative (D2), Archivage légal (G5)	3
E. Gouvernance & Organisation applicative	Propriétaire applicatif (E1), Politique de sécurité applicative (E2), Protection contre les injections SQL (E3), Configuration sécurisée (E4), Destruction sécurisée (G6)	5
Total		21



Les six assertions préfixées **G** (G1, G2, G3, G4, G5, G6) sont spécifiques à la gestion documentaire d'une application comptable publique **comme notre cas d'étude** (versionnement, classification, journalisation des consultations, granularité des droits par document, archivage légal, destruction sécurisée) et s'ajoutent aux assertions génériques (A1-A3, B1-B2, C1-C4, D1-D2, E1-E4) tirées de *l'outil Audit 8 domaines* disponible sur le dépôt git : <https://github.com/Maletyon/INF3226/tree/chapitre>.

ii) Règle de dérivation de la réponse fusionnée : Chaque assertion reçoit deux sous-réponses indépendantes de l'auditeur : une sous-réponse **TECHNIQUE** et une sous-réponse **ORGANISATIONNELLE**, chacune notée OK (preuve obtenue et probante), KO (preuve obtenue et défaillante) ou NSP (preuve insuffisante pour conclure). La réponse fusionnée en découle mécaniquement :

TABLE 2.10 – Dérivation de la réponse fusionnée O/N/PAS

Réponse	Condition	Score
O Conforme	Technique = OK ET Organisationnel = OK	1
N : Non Conforme	Technique = KO OU Organisationnel = KO (au moins une défaillance avérée)	0
PAS : Zone grise	Aucune défaillance avérée, mais au moins une composante = NSP	0,5

iii) Entropie de Shannon par domaine : L'Outil tableur mesure, **pour chaque domaine**, la **dispersion des réponses fusionnées** (O, N, PAS) obtenues sur l'ensemble des assertions de ce domaine :

$$H = -p_O \log_2(p_O) - p_N \log_2(p_N) - p_{PAS} \log_2(p_{PAS}) \in [0 ; 1,585 \text{ bits}] \quad (2.1)$$

TABLE 2.11 – Lecture de l'entropie par domaine

Valeur	Interprétation
$H = 0$	Certitude complète : toutes les réponses du domaine sont identiques
$H < 0,5$	Certitude dominante : situation lisible
$0,5 \leq H < 1,0$	Incertitude modérée : approfondissement recommandé sur les assertions PAS du domaine
$H \geq 1,0$	Zone grise critique : investigation obligatoire avant toute opinion sur ce domaine
$H = 1,585$	Incertitude maximale (O, N et PAS équiprobables) : aucune conclusion fiable



iv) Maturité CMMi : La maturité est calculée automatiquement, par domaine, à partir du taux de conformité τ_c :

$$M = \tau_c \times 5 \quad \text{avec} \quad \tau_c = \frac{\text{Nb}(O)}{\text{Nb}(\text{assertions fusionnées du domaine})} \quad (2.2)$$

TABLE 2.12 – Niveaux de maturité CMMi selon le taux de conformité

Niveau	Seuil τ_c	Interprétation
1. Initial	< 35 %	Pratiques ad hoc, résultats aléatoires
2. Géré	[35 %, 55 %]	Pratiques documentées, résultats répétables
3. Défini	[55 %, 75 %]	Processus standardisés et diffusés
4. Quantitatif	[75 %, 90 %]	Processus mesurés et contrôlés
5. Optimisation	≥ 90 %	Amélioration continue systématique

v) Matrice des risques $R = P \times I$: La **matrice des risques** $P \times I$ est un outil de visualisation et de priorisation des risques basé sur deux dimensions : la **probabilité (P)** et l'**impact (I)**. P et I sont deux échelles **complètement indépendantes**, chacune cotée de 1 à 4. Le score de risque $R = P \times I$ est **calculé** par l'auditeur pour chaque vulnérabilité identifiée **lors de la phase d'exécution**.

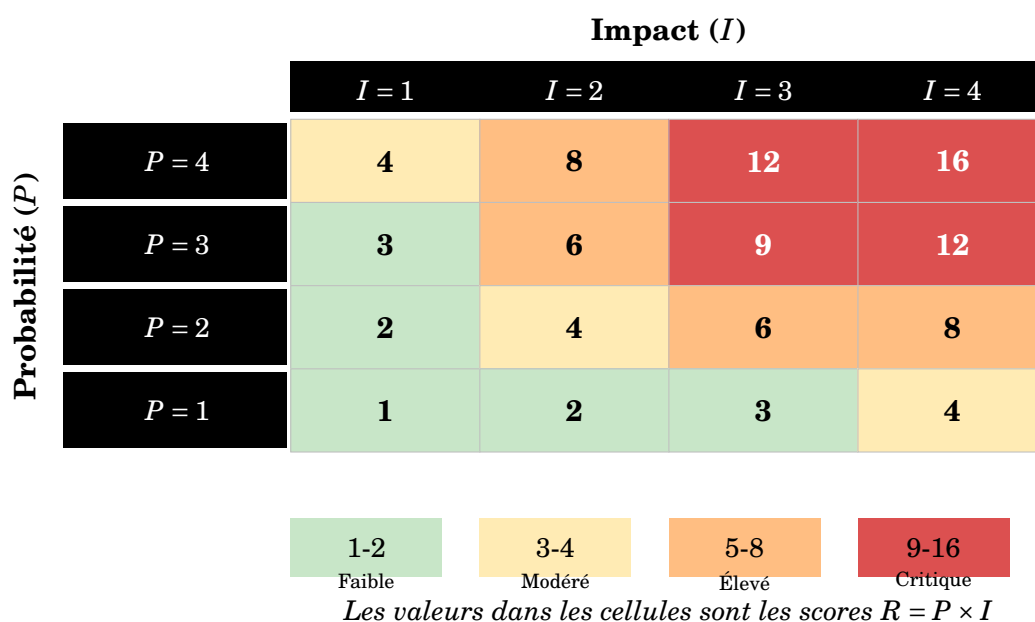
Contrairement à la cotation préliminaire du TDR (Faible, Modéré, Élevé, Critique), cette évaluation est **quantitative** et repose sur des preuves objectives collectées sur le terrain. Les quatre plages [1,2], [3,4], [5,8] et [9,16] ont été définies pour refléter la progression non linéaire du risque : le seuil critique (à partir de 9) correspond nécessairement à une probabilité et un impact tous deux supérieurs ou égaux à 3, signalant une menace concrète et multidimensionnelle nécessitant une action immédiate. Le tableau ci-dessous présente les critères d'évaluation de la probabilité et de l'impact. L'auditeur attribue une valeur de 1 à 4 pour chaque dimension en fonction des critères décrits.



TABLE 2.13 – Échelles de probabilité et d'impact

Valeu	Probabilité	Impact	Critères déterminants
1	Faible	Négligeable	Exploitation très difficile; conditions exceptionnelles; accès privilégié requis
2	Modéré	Limité	Exploitation possible par un attaquant expérimenté; outils spécialisés nécessaires
3	Élevé	Significatif	Exploitation accessible avec des outils courants; techniques documentées
4	Critique	Très élevé	Exploitation triviale; PoC disponible; aucune compétence spéciale requise

La figure 2.1 présente une visualisation colorée de la matrice des risques. Chaque cellule contient le score $R = P \times I$ correspondant à la combinaison de la probabilité (lignes) et de l'impact (colonnes).



Seuil critique **9** : $P \geq 3$ ET $I \geq 3$

Correction immédiate sous 48 heures

FIGURE 2.1 – Matrice visuelle des risques $R = P \times I$, Version MUSA avec seuil critique 9

La couleur de la cellule indique le niveau de risque :

- ◆ **Vert (1-2)** : Faible ; risque acceptable, traitement planifié
- ◆ **Jaune (3-4)** : Modéré ; risque significatif, correction dans le mois
- ◆ **Orange (5-8)** : Élevé ; risque important, correction sous 2 semaines





♦ **Rouge (9-16) : Critique ; risque majeur, **correction immédiate sous 48 h****

Le seuil critique de 9 est matérialisé par la frontière entre les zones orange et rouge. Il correspond aux combinaisons où $P \geq 3$ et $I \geq 3$, c'est-à-dire où la vulnérabilité est à la fois facilement exploitable et susceptible de causer des dommages significatifs. Le tableau 2.14 synthétise les actions à entreprendre en fonction du score de risque. Les risques critiques (9-16) déclenchent une procédure d'urgence :

♦ **Alerte immédiate** au commanditaire dans les 24 h

♦ **Plan d'action d'urgence** dans les 48 h

♦ **Escalade à la direction générale** si $R \geq 12$

TABLE 2.14 – Classification des risques $R = P \times I$ et actions associées

Score R	Niveau de risque	Action / Délai de correction
1-2	Faible	Planifié (prochain cycle d'audit)
3-4	Modéré	Correction dans le mois
5-8	Élevé	Correction sous 2 semaines
9-16	Critique	Correction immédiate sous 48 h

vi) Criticité et échéance de traitement : Chaque assertion reçoit également une **priorité** (H = Haute, M = Moyenne, F = Faible, fixée dans la décomposition N8 lors de la conception de l'outil) qui, combinée à la réponse fusionnée, détermine une **criticité sur une échelle de 0 à 9** et une échéance de traitement recommandée :

TABLE 2.15 – Grille de criticité de l'Outil tableur

Score	Condition	Échéance
9	Réponse N + Priorité H	IMMÉDIATE
6,3	Réponse PAS + Priorité H	COURT TERME
5	Réponse N + Priorité M	COURT TERME
3,5	Réponse PAS + Priorité M	MOYEN TERME
2	Réponse N + Priorité F	MOYEN TERME
1,4	Réponse PAS + Priorité F	LONG TERME
0	Réponse O (Conforme)	—



2.3.4 Phase 4 : Communication des résultats

La Phase 4 transforme les constats et les données collectées en un rapport structuré, argumenté et actionnable. Elle est alignée sur l'**ISO 19011 :2018** §6.5, la norme **IIA 2400** (communication des résultats) et **IIA 2410** (critères de communication).

TABLE 2.16 – Phase 4 : Communication des résultats

Élément	Détail
Inputs	PT-A à PT-E renseignés ; Outil tableur complété
Activités clés	Consolidation des constats et scoring ; procédure contradictoire (envoi des constats provisoires à l'audité, recueil des réponses) ; rédaction du rapport définitif ; réunion de clôture
Outputs	Rapport d'audit fusionné définitif ; plan de remédiation hiérarchisé (Quick Wins / Actions structurelles) ; PV de réunion de clôture signé

Structure du rapport d'audit MUSA : Le rapport suit une structure normalisée en 7 sections :

1. **Synthèse exécutive** (1 page) : vue d'ensemble des résultats, notations, risques critiques
2. **Contexte et périmètre** : rappel de la mission, périmètre, niveau d'audit
3. **Méthodologie** : approche MUSA, référentiels, outils, équipe
4. **Résultats détaillés** : par domaine d'assertion, avec réponses O/N/PAS
5. **Matrice des risques** : positionnement de chaque vulnérabilité
6. **Analyse des écarts** : écart entre attendu et observé, causes identifiées
7. **Recommandations** : actions correctives, par priorité (Critique → Élevé → Modéré → Faible)

La **procédure contradictoire** prévoit un délai de **10 jours ouvrés** pour la contestation écrite des constats par l'audité.

La **réunion de clôture** est une exigence formelle de l'ISO 19011 §6.6. Elle réunit l'équipe d'audit, la direction de l'organisation auditée et le commanditaire. L'ordre du jour couvre la présentation des résultats, la matrice des risques, les recommandations et le plan d'action.

2.3.5 Phase 5 : Suivi des recommandations

La Phase 5 assure que les recommandations sont effectivement mises en œuvre. Elle est alignée sur l'**ISO 19011 :2018** §6.7 et les normes **IIA 2500** (suivi des recommandations) et **IIA 2501** (rapport de suivi).





TABLE 2.17 – Phase 5 : Suivi des recommandations

Élément	Détail
Inputs	Plan de remédiation transmis à l'audité
Activités clés	Vérification des preuves de mise en œuvre des recommandations; suivi périodique selon le niveau de risque; validation des corrections; clôture des recommandations
Outputs	État d'avancement des recommandations; rapport de validation des corrections; fiche de clôture de la mission
Statut	Selon le périmètre de la mission (peut être externalisé ou traité dans un cycle ultérieur)

i) Plan de suivi : Le plan de suivi est établi en fonction du niveau de risque :

- ◆ **Critique (9-16)** : suivi hebdomadaire, alerte si dépassement du délai;
- ◆ **Élevé (5-8)** : suivi mensuel, point de situation;
- ◆ **Modéré (3-4)** : suivi trimestriel;
- ◆ **Faible (1-2)** : suivi semestriel.

ii) Procédure d'escalade : Conformément à la norme **IIA 2600**, une procédure d'escalade en trois niveaux est définie en cas de non-traitement des recommandations critiques :

- ◆ **Niveau 1** : Relance formelle écrite à la direction générale
- ◆ **Niveau 2** : Information du commanditaire
- ◆ **Niveau 3** : Saisine de l'autorité de tutelle ou du comité d'audit

Les recommandations non levées à l'issue de cette phase réalimentent la Phase 1 d'un éventuel cycle d'audit suivant, conformément au principe d'amélioration continue.

Ce chapitre a présenté la méthode **MUSA** (Méthode Unifiée d'Audit de Sécurité Appllicative) comme une démarche standardisée répondant aux lacunes identifiées au chapitre précédent. La méthode repose sur sept principes directeurs qui gouvernent chaque décision méthodologique : optimisation par la fusion, objectivation de l'incertitude, formalisation complète des procédures, gouvernance rigoureuse, réutilisabilité systématique, ancrage local préservé et capture de l'incertitude.

La structure globale de MUSA s'articule autour de cinq phases séquentielles : travaux préparatoires, planification, exécution, communication des résultats et suivi des recommandations. Chacune décrite selon un triptyque opérationnel *inputs / activités clés / outputs*. Cette architecture garantit la traçabilité complète des travaux et la reproductibilité des missions.



Le cœur de la méthode réside dans l'Outil tableur, un classeur de collecte unique qui fusionne, pour 21 assertions réparties sur 5 domaines, un volet technique et un volet organisationnel en une réponse tripartite O/N/PAS. Cette réponse est ensuite scorée selon trois métriques complémentaires :

- ◆ **L'entropie de Shannon** (H), calculée par domaine, mesure l'incertitude et la reproductibilité des évaluations ;
- ◆ **La maturité CMMi** (M), dérivée du taux de conformité, positionne l'application sur une échelle de 1 à 5 ;
- ◆ **La criticité** (0 à 9), combinant la réponse fusionnée et la priorité de l'assertion, détermine l'échéance de traitement.

La matrice des risques $R = P \times I$ a été définie avec un seuil critique à partir de 9, correspondant aux combinaisons où probabilité et impact sont tous deux supérieurs ou égaux à 3. Cette classification permet une priorisation claire des actions correctives, avec une exigence de correction immédiate sous 48 heures pour les risques critiques, complétée par une procédure d'escalade conforme aux normes IIA.

MUSA constitue ainsi une réponse opérationnelle, rigoureuse et adaptée au contexte camerounais, structurée autour d'outils standardisés conçus pour être génériques et réutilisables sur toute application. Le chapitre suivant applique concrètement cette méthode à un cas réel (GIDOCEP) et en présente les résultats.

IMPLÉMENTATION ET RÉSULTATS

Ce troisième chapitre a pour objectif d'**appliquer concrètement la méthode** à un cas réel : **GIDOCEP**, l'application développée par SOLTEC et utilisée par les établissements publics camerounais pour la gestion de leurs opérations comptables.

3.1 Présentation de GIDOCEP

3.1.1 Description générale

GIDOCEP (Gestion Informatisée des Opérations Comptables des Établissements Publics) est une application développée par **SOLTEC** depuis **2008**. Elle est utilisée par l'ensemble des établissements publics camerounais pour la gestion budgétaire, dans le cadre de la circulaire N° 13/001/C/MINFI du 08 janvier 2013.



FIGURE 3.1 – Page d'accueil et tableau de bord de GIDOCEP

Source : Capture d'écran réalisée lors de l'audit

L'application se structure en trois modules fonctionnels :

- ◆ **Ordonnateur** : engagements, liquidations, ordonnancements.
- ◆ **Contrôleur Financier** : visa budgétaire, validation.
- ◆ **Agence Comptable** : prise en charge, paiement, encaissement.

3.1.2 Architecture technique

GIDOCEP est développé avec **WEBDEV 24** et repose sur une architecture en trois couches¹ : présentation (HTML/AWP), contrôleur (WLangage), données (HFSQL Classic). Le déploiement utilise IIS et le protocole AWP. Le tableau 3.1 récapitule les principales caractéristiques techniques de l'application GIDOCEP, telles que déclarées par SOLTEC lors de la phase de cadrage.

1. Le présent travail ne couvre pas l'architecture physique ou logique de l'application GIDOCEP qui est une marque déposée par SOLTEC. Il consiste à donner les résultats de la méthode

TABLE 3.1 – Caractéristiques techniques de GIDOCEP

Composant	Information
Langage	WEBDEV 24 (WLangage)
Architecture	3 tiers
Base de données	HFSQL Classic
Serveur Web	IIS
Protocole	CGI (AWP)
Déploiement	Intranet / local

3.1.3 Données manipulées

GIDOCEP manipule des données financières et budgétaires sensibles : budgets, engagements, paiements, comptes de gestion, données personnelles des agents.

Spécificité : les données sont décentralisées (chaque établissement gère ses propres données).

3.1.4 Chaîne d'exécution du budget

GIDOCEP implémente un circuit de validation à trois acteurs. Le tableau 3.2 présente les trois acteurs impliqués dans la chaîne d'exécution du budget, leurs rôles respectifs et leurs particularités fonctionnelles.

TABLE 3.2 – Acteurs de la chaîne d'exécution du budget

Acteur	Rôle	Particularité
Ordonnateur	Engage, liquide et ordonnance	Chaque acteur connaît ses propres opérations
Contrôleur Financier	Vérifie la conformité et valide	Peut rejeter avec obligation de motivation
Agent Comptable	Contrôle la régularité, gère la liquidité, effectue le paiement	Réalise les mêmes contrôles que le CF

Deux circuits de traitement :

- ◆ **Circuit long** : bons de commande, marchés, contrats, conventions
- ◆ **Circuit court** : dossiers urgents (ordres de mission, décisions de déblocage)



3.1.5 Niveau de criticité

Le tableau 3.3 présente le calcul du score de criticité de GIDOCEP, qui a permis de déterminer le niveau d'audit à appliquer conformément à la grille de la norme OWASP.

TABLE 3.3 – Niveau d'audit de GIDOCEP

Critère	Score
Données financières traitées	+2
Données personnelles	+1
Obligations réglementaires	+1
Impact si compromission	+2
Migration cloud envisagée	+1
Total	7 → Niveau 2 (Standard)

3.1.6 Antécédents d'audit

Un premier audit formel de GIDOCEP a été mené en 2026 par le cabinet ST DIGITAL (expert Alain Lelouey) sous l'égide de l'AFD(Agence Française du Développement), du MINFI(Ministère des Finances) et de la DGB(Direction Générale du Budget).

Constat principal : absence de gouvernance.

3.1.7 Justification du cas d'étude

Le choix de GIDOCEP se justifie par sa criticité stratégique, sa complexité fonctionnelle, la décentralisation des données et la transition cloud envisagée et c'est une application utilisée par plusieurs établissements publics et développée par une PME (SOLTEC).

3.2 Déroulement de l'audit

L'audit de GIDOCEP a été conduit conformément aux **cinq phases** de la méthode MUSA, décrites au chapitre 2. Le planning général de la mission est présenté à la figure 3.2.

MÉMOIRE DE FIN D'ÉTUDES - ENSPY
AUDIT DE SÉCURITÉ APPLICATIVE FUSIONNÉ
 Méthode MUSA - Cas GIDOCEP / SOLTEC

PLAN D'AUDIT

Mission MUSA-GIDOCEP-2026-SOLTEC

Référence mission	MUSA-GIDOCEP-2026-SOLTEC
Entité auditée	SOLTEC, application GIDOCEP
Objet de la mission	Audit de sécurité applicative fusionné de GIDOCEP (méthode MUSA)
Type d'audit	Audit de conformité et d'efficacité, fusionnant audit applicatif et audit de sécurité
Commanditaire	Direction Générale SOLTEC (ou représentant mandaté)
Chef de mission	TOMI OLAMA Gabrielle Solange, étudiante-auditrice, ENSPY
Période terrain	
Version	V1.0, Finale (plan exécuté ; mission terrain achevée)
Classification	CONFIDENTIEL, Usage exclusif mission de fin d'études

▲ **Règle absolue** : le présent plan d'audit marque la fin de la phase de planification. Il doit être validé formellement (superviseur académique + encadreur professionnel) avant tout démarrage des travaux de terrain.

1. Contexte et objectifs de la mission

1.1 Contexte

SOLTEC, PME camerounaise editrice de GIDOCEP, ne peut supporter le coût cumulé d'un audit applicatif et d'un audit de sécurité distincts sur un même cycle budgétaire. La présente mission applique MUSA méthode

FIGURE 3.2 – Planning détaillé de l'audit MUSA - GIDOCEP

Source : Artefact MUSA L00-Aide-mémoire de mission

Ce planning a été établi en concertation avec le Directeur Général Adjoint de SOLTEC et validé lors de la réunion de lancement.

Précision méthodologique sur les assertions évaluées : L'audit de GIDOCEP a été réalisé dans le cadre d'un mémoire de fin d'études, avec des contraintes de ressources, de temps et d'accès aux documents. Les données utilisées sont des données d'entraînement (Conformément au 3.1.1 car les données sont confidentielles). L'objectif est de valider le fonctionnement des outils MUSA (L00-L06) sur un cas concret.

Ainsi, il convient de distinguer :

- ◆ **Les assertions vérifiées** : il s'agit des constats confirmés par des preuves objectives issues des outils de test (OWASP ZAP, Nmap) ou des observations directes de l'auditrice (inspection physique). Ces assertions sont pleinement valides et reproductibles.
- ◆ **Les assertions non vérifiées** : par manque de disponibilité des documents techniques (schéma d'architecture, matrice des droits, code source) ou par contrainte de temps, certaines assertions n'ont pas pu être vérifiées de manière indépendante. Elles ont été renseignées dans les outils Excel (L00 à L06) **dans le seul but de valider le fonctionnement de la méthode MUSA**, et non pour établir des constats d'audit définitifs sur GIDOCEP.



Cette distinction est essentielle : les métriques et conclusions présentées dans ce mémoire portent exclusivement sur les **6 vulnérabilités confirmées**. Les assertions non vérifiées, bien que documentées dans les outils, ne sont pas retenues dans les résultats finaux de l'audit.

Dans un audit réel mené dans des conditions optimales (accès complet au code source, à la documentation technique et aux équipes), ces assertions devraient faire l'objet d'une vérification approfondie.

3.2.1 Phase 1 : Travaux préparatoires

La Phase 1 constitue le fondement de toute la mission. Elle a été conduite conformément à l'ISO 19011 :2018 §6.2–6.3.

3.2.1.1 Scénario ANTIC (audit de sécurité uniquement)

Si l'ANTIC réalisait un audit de sécurité de GIDOCEP, la phase préparatoire serait conduite comme suit :

Cadrage : L'ANTIC émettrait une lettre de mission fixant le périmètre de l'audit. Ce périmètre serait centré sur les aspects sécuritaires : politique de sécurité, gestion des accès, protection des données, continuité d'activité et conformité réglementaire. Le périmètre serait défini unilatéralement par l'équipe ANTIC, sans implication formelle de SOLTEC dans sa délimitation. Les risques préliminaires ne seraient pas formalisés dans un document structuré.

Collecte documentaire : L'ANTIC solliciterait des documents relatifs à la sécurité : politique de sécurité, matrice des droits d'accès, rapports d'audit antérieurs, procédures de sauvegarde, etc. La liste ne serait pas formalisée dans un outil standardisé, ce qui rendrait difficile l'association entre les documents manquants et les assertions à vérifier.

Évaluation de la faisabilité : L'évaluation serait implicite et reposerait sur l'expérience de l'équipe d'audit. Aucune grille formalisée ne serait utilisée pour évaluer la faisabilité de la mission.

Constitution de l'équipe : L'équipe serait composée d'experts en cybersécurité, sélectionnés en fonction de leur disponibilité. L'indépendance serait déclarée de manière informelle, sans formalisation systématique.

Réunion de lancement : La réunion serait généralement informelle, sans procès-verbal systématique. L'engagement des parties resterait implicite.

Limite identifiée : Un audit ANTIC seul ne permettrait pas de comprendre le fonctionnement métier de GIDOCEP. L'équipe ne serait pas composée d'experts comptables, ce qui limiterait la compréhension des enjeux fonctionnels.



3.2.1.2 Scénario CONSUPE (audit des applications en service uniquement)

Si le CONSUPE réalisait un audit de GIDOCEP, la phase préparatoire serait conduite comme suit :

Cadrage : Le CONSUPE émettrait un ordre de mission fixant le périmètre de l'audit. Ce périmètre serait centré sur la conformité fonctionnelle et la performance de l'application : adéquation aux besoins, correction des traitements, efficacité des processus. La planification s'appuierait sur une matrice des risques identifiant les risques préliminaires liés au fonctionnement de l'application.

Collecte documentaire : Le CONSUPE solliciterait des documents relatifs au fonctionnement : spécifications fonctionnelles, manuels utilisateurs, procédures métier, rapports de performance, etc.

Évaluation de la faisabilité : L'évaluation serait partiellement formalisée à travers les fiches techniques de mission, mais sans grille spécifique dédiée à la faisabilité.

Constitution de l'équipe : L'équipe serait composée d'experts en audit financier et en évaluation des systèmes d'information, sélectionnés selon leur disponibilité et leur expertise. L'indépendance serait garantie par les normes IIA et ISSAI.

Réunion de lancement : Un procès-verbal standard serait établi, mais l'engagement des parties resterait implicite.

Limite identifiée : Un audit CONSUPE seul ne permettrait pas d'identifier les vulnérabilités techniques de GIDOCEP. L'équipe ne serait pas composée d'experts en sécurité offensive, ce qui limiterait la détection des failles comme les injections SQL ou les XSS.

3.2.1.3 Approche MUSA

a)Cadrage de la mission (Outils L01 et L02) La **fiche technique** (L01) a fixé en une page l'intitulé de la mission, le commanditaire, l'objectif général, le périmètre applicatif (GIDOCEP seul), l'approche méthodologique et les référentiels retenus.

Les **Termes de Référence (TDR)** (L02) ont détaillé le contexte, les objectifs spécifiques par domaine, le périmètre inclus/exclu, un registre de risques préliminaires cotés en Élevé / Moyen / Faible et un calendrier indicatif.

Périmètre applicatif	Application unique : GIDOCEP (et non un portefeuille logiciel), ce qui distingue la présente mission d'un audit SI classique multi-applicatif. • Modules couverts : [Liste des modules fonctionnels de GIDOCEP] • Environnement d'hébergement : [on-premise SOLTEC] • Population d'utilisateurs concernée : [Etablissements publics clients, agents SOLTEC, administrateurs] Période couverte : situation actuelle du système en production].
-----------------------------	--

FIGURE 3.3 – Délimitation du périmètre d'audit (L01)

Source : Artefact MUSA L01-Fiche technique

Niveau de criticité : La grille de criticité MUSA a attribué un score de **7** à GIDOCÉP, la classant en **niveau 2 (Standard)** conformément à OWASP ASVS niveau 2.

Source : Artefact MUSA L01-Fiche technique

Mission MUSA-GIDOCEP-2026-SOLTEC

Les documents suivants doivent être obtenus avant le démarrage des travaux de terrain. L'absence de tout document de priorité H constitue un constat PAS à noter dans l'Outil MUSA c'est-à-dire une insuffisance sur la réponse de l'audité.

Source : Artefact MUSA L03-Documents sollicités

seul le manuel de formation a été fourni dans son intégralité, accompagné des guides utilisateurs et d'une synthèse partielle du rapport de l'audit ST DIGITAL. L'absence de documentation technique formalisée notamment le schéma d'architecture, la matrice des droits d'accès et la procédure de gestion des accès constitue un constat d'audit majeur.

Nom	Modifié le	Type	Taille
Guide_utilisateur_AC_Regisseur	01/12/2023 15:56	Chrome PDF Docum...	12 483 Ko
Guide_utilisateur_Budget	31/12/2025 10:53	Chrome PDF Docum...	8 571 Ko
Guide_utilisateur_comptabilite	01/12/2023 16:43	Chrome PDF Docum...	23 705 Ko
Guide_utilisateur_controle_financier	02/12/2023 14:29	Chrome PDF Docum...	36 824 Ko
Guide_utilisateur_depense	01/12/2023 16:39	Chrome PDF Docum...	14 099 Ko
Guide_utilisateur_Fiscalite	01/12/2023 15:58	Chrome PDF Docum...	11 170 Ko
Guide_utilisateur_Pilotage	01/12/2023 15:55	Chrome PDF Docum...	25 747 Ko
Guide_utilisateur_Tresorerie	01/12/2023 18:56	Chrome PDF Docum...	31 924 Ko
MANUEL DE FORMATION ART	16/09/2021 12:55	Document Microsoft ...	902 Ko

FIGURE 3.6 – Documents reçus en Phase 1

Source : Capture d'écran réalisée lors de l'audit

Ces documents ont été fournis par SOLTEC. Ils ont permis de comprendre le fonctionnement de l'application et d'identifier les circuits de traitement ainsi que les différents rôles des acteurs.

c) Évaluation de la faisabilité La faisabilité de l'audit a été évaluée selon six critères. Cinq critères ont été validés. Seul l'accès à la documentation technique a été jugé partiel, en raison de l'absence de schéma d'architecture et de matrice des droits. La figure suivante présente cette grille de faisabilité :

MUSA - PT01 - Phase 1				
Onglet 1/8 : Évaluation de la faisabilité				
Critère de faisabilité	Question	Réponse (O/N/P)	Commentaire	Statut
Ressources humaines	L'équipe dispose-t-elle des compétences requises ?	O	Compétences en cybersécurité, audit et compréhension du métier comptable	OK
Disponibilité temporelle	La fenêtre d'audit est-elle compatible avec les contraintes ?	O	Planning compatible avec les disponibilités du DGA et du développeur	OK
Accès aux systèmes	L'accès à GIDOCAP et à la documentation est-il possible ?	Partiel	Accès à l'application OK. Mais absence de documentation technique formalisée (schéma d'architecture, matrice des droits)	Partiel
Budget	Les ressources financières sont-elles allouées ?	O	Budget pris en charge par SOLTEC dans le cadre du mémoire	OK
Indépendance	L'équipe est-elle indépendante vis-à-vis de la structure auditée ?	O	Aucun lien familial ou financier avec SOLTEC. Déclaration d'indépendance signée	OK
Autorisation formelle	L'autorisation de la direction est-elle obtenue ?	O	Autorisation accordée par le DGA de SOLTI	OK

FIGURE 3.7 – Grille d'évaluation de la faisabilité (L01)

Source : Artefact MUSA L01-Fiche technique

d) Constitution de l'équipe d'audit L'équipe d'audit a été constituée selon la grille de compétences MUSA. Elle est composée de quatre membres : un superviseur général, un référent institutionnel, un expert métier et un lead auditor opérationnel. Chaque membre a été sélectionné en fonction de ses compétences pondérées sur cinq domaines : sécurité applicative, audit des SI, développement logiciel, métier comptable et réglementation TIC Cameroun.

MUSA - PT01 - Phase 1								
Onglet 2/8 : Composition équipe & grille de compétences								
Fonction	Sécu applic. /30	Audit SI /25	Dev logiciel /20	Métier comptable /15	Régl. TIC Cameroun /10	Score /100 (auto)	Niveau	Rôle dans la mission
Chief Cybersecurity Officer	29	25	15	13	9	91	Expert	Superviseur général / Garant institutionnelle
Directeur Audit ANTIC	28	25	13	10	10	86	Expert	Supervision méthodologique
Ingénieur / ANTIC Douala	24	22	14	14	8	82	Expert	Expert métier, validation flux
Étudiante-ingénieur	22	18	13	10	8	71	Confirmé	Lead Auditor, pilotage, tests, rédaction
						0		
LÉGENDE – Niveaux : Débutant=0-40 Intermédiaire=41-60 Confirmé=61-80 Expert=81-100								

FIGURE 3.8 – Grille de compétences de l'équipe d'audit (L01)

Source : Artefact MUSA L01-Fiche technique

Conformément à la norme IIA 1100, chaque membre de l'équipe a signé une déclaration d'indépendance. Cette formalité garantit l'objectivité des évaluations et l'absence de conflits d'intérêts.

MUSA - PT01 - Phase 1				
Onglet 3/8 : Déclaration d'indépendance (IIA 1100)				
Déclaration	OUI	NON	Précision si OUI	Date signature
Aucun lien familial (≤ 2e degré) avec la structure auditée	☐	X		15/06/2026
Aucun intérêt financier dans la structure auditée	☐	X		
N'a pas participé au développement de GIDOCEP (24 derniers mois)	☐	X		
N'a pas tenu de poste de décision dans la structure (12 derniers mois)	☐	X		
Aucune raison personnelle ou professionnelle de biaiser les conclusions	☐	X		
S'engage à signaler tout conflit d'intérêts en cours de mission	X	☐		15/06/2026
Aucun lien familial (≤ 2e degré) avec la structure auditée	☐	X		
Aucun intérêt financier dans la structure auditée	☐	X		
N'a pas participé au développement de GIDOCEP (24 derniers mois)	☐	X		
N'a pas tenu de poste de décision dans la structure (12 derniers mois)	☐	X		
Aucune raison personnelle ou professionnelle de biaiser les conclusions	☐	X		15/06/2026
S'engage à signaler tout conflit d'intérêts en cours de mission	X	☐		
Aucun lien familial (≤ 2e degré) avec la structure auditée	☐	X		
Aucun intérêt financier dans la structure auditée	☐	X		
N'a pas participé au développement de GIDOCEP (24 derniers mois)	☐	X		
N'a pas tenu de poste de décision dans la structure (12 derniers mois)	☐	X		15/06/2026
Aucune raison personnelle ou professionnelle de biaiser les conclusions	☐	X		
S'engage à signaler tout conflit d'intérêts en cours de mission	X	☐		
Aucun lien familial (< 2e degré) avec la structure auditée	☐	X		

FIGURE 3.9 – Déclarations d'indépendance des auditeurs (L01)

Source : Artefact MUSA L01-Fiche technique

e) Réunion de lancement La réunion de lancement s'est tenue le 15 juin 2026 en présence du lead auditor et du Directeur Général Adjoint de SOLTEC. Le procès-verbal a été signé par

les deux parties, formalisant ainsi l'engagement mutuel et le cadre de la mission.

MUSA - PT01 - Phase 1				
Onget 8/8 : Procès-verbal de réunion de lancement				
Mission	Audit de sécurité applicative de GIDOCEP dans le cadre du mémoire de fin d'études - Méthode MUSA (Standardisation de l'audit de sécurité basée sur la démarche ANTIC)			
Date	15/06/2026			
Lieu	SOLTEC SARL			
Lead auditor	TOMI OLAMA Gabrielle Selange - étudiante-ingénieur, ENSPY			
Représentant commanditaire	M LEKEUFACK Albert - DGA SOLTEC			
#	Point discuté	Décision / Résultat	Responsable	Échéance
1	Présentation de l'équipe et du mandat	Equipe: TOMI OLAMA (Lead auditor), Mandat validé par SOLTEC	Lead auditor	Jour 0
2	Périmètre et niveau d'audit	Périmètre validé. Niveau 2 (Standard) - Score 7.	Lead auditor / DGA	Jour 0
3	Calendrier et jalons	Calendrier validé : 4 phases + suivi 3 mois.	Lead auditor	J+15
4	Canaux de communication	Contact : Lead auditor / DGA. Email + réunions hebdo.	Lead auditor / DGA	Hebdomadaire
5	Confidentialité	Rapport confidentiel. Diffusion : Direction SOLTEC.	Lead auditor	Mission
Indépendance Périmètre Criticité Planning Documents demandés PV Lancement				

FIGURE 3.10 – Procès-verbal de la réunion de lancement (L01)

Source : Artefact MUSA L01-Fiche technique

3.2.2 Phase 2 : Planification

La Phase 2 a transformé les éléments collectés en un plan d'action détaillé. Elle est alignée sur l'ISO 19011 :2018 §6.4 et les normes IIA 2200 et IIA 2210.

3.2.2.1 Scénario ANTIC (audit de sécurité uniquement)

Si l'ANTIC réalisait un audit de sécurité de GIDOCEP, la phase de planification serait conduite comme suit :

Plan d'audit : L'ANTIC établirait un plan d'audit centré sur les aspects sécuritaires de l'application. Les référentiels utilisés seraient principalement le référentiel interne de l'ANTIC, avec une référence à l'ISO 19011. L'évaluation du contrôle interne se limiterait aux contrôles de sécurité (gestion des accès, chiffrement, journalisation, etc.), sans prendre en compte la logique métier de GIDOCEP.

Programme de travail : Le programme de travail serait organisé autour des quatre axes de l'ANTIC : organisationnel, humain, physique et technologique. Les assertions porteraient exclusivement sur des critères de sécurité, sans évaluation de la conformité fonctionnelle de l'application.

Guide d'entretien : Les entretiens porteraient sur les pratiques de sécurité : politique de sécurité, gestion des mots de passe, contrôle des accès, sauvegardes, etc. Aucune question ne couvrirait le fonctionnement métier de GIDOCEP (circuit de validation, séparation des tâches, logique comptable).

Limite identifiée : Un audit ANTIC seul ne permettrait pas d'évaluer si GIDOCEP répond correctement aux besoins fonctionnels des établissements publics, ni si les workflows



comptables sont correctement implémentés. Une vulnérabilité comme l'IDOR ne serait pas analysée dans son contexte métier.

3.2.2.2 Scénario CONSUPE (audit des applications en service uniquement)

Si le CONSUPE réalisait un audit de GIDOCEP, la phase de planification serait conduite comme suit :

Plan d'audit : Le CONSUPE établirait un plan d'audit centré sur la conformité fonctionnelle et la performance de l'application. Les référentiels utilisés seraient les normes ISSAI et les guides internes du CONSUPE. L'évaluation du contrôle interne porterait sur les contrôles métier (circuits de validation, séparation des tâches, traçabilité des opérations comptables).

Programme de travail : Le programme de travail serait organisé autour des processus métier de GIDOCEP : gestion des engagements, liquidation, ordonnancement, paiement. Les assertions porteraient sur la conformité des traitements par rapport aux règles comptables et budgétaires.

Guide d'entretien : Les entretiens porteraient sur le fonctionnement métier : connaissance des circuits, respect des procédures, adéquation aux besoins des utilisateurs. Aucune question ne couvrirait les aspects de sécurité technique comme les injections SQL, les XSS ou la configuration des serveurs.

Limite identifiée : Un audit CONSUPE seul ne permettrait pas de détecter les vulnérabilités techniques de GIDOCEP (injection SQL, XSS, configuration serveur, etc.). Une faille de sécurité critique dans un module de paiement pourrait passer inaperçue.

3.2.2.3 Approche MUSA

a) Plan d'audit (L06) Le **plan d'audit** (L06) a fixé les référentiels retenus (ISO 27001, OWASP ASVS, ISO 19011, normes IIA), a formulé une évaluation *a priori* du contrôle interne de SOLTEC (qualifiée de *FAIBLE*) et a décliné un programme de travail par domaine (A à E). Les papiers de travail attendus étaient :

- ◆ L04-A : Authentification & Contrôle d'accès (assertions A1-A3)
- ◆ L04-B : Journalisation & Traçabilité (assertions B1-B2)
- ◆ L04-C : Sécurité des données (assertions C1-C4)
- ◆ L04-D : Continuité & Sauvegarde (assertions D1-D2)
- ◆ L04-E : Gouvernance & Organisation (assertions E1-E4)

b) Guide d'entretien fusionné (L05) Le **guide d'entretien** (L05) a traduit chacune des 21 assertions en 41 questions couvrant à la fois le volet technique et le volet organisationnel. Il n'existe pas de questionnaire séparé « sécurité » et « applicatif », chaque question teste simultanément les deux dimensions.



Les entretiens ont été planifiés avec trois profils d'interlocuteurs :

- ◆ **Direction / DG** : politique de sécurité, budget, gouvernance
- ◆ **Responsable technique / Devs** : pratiques de codage, gestion des accès, architecture
- ◆ **Utilisateurs finaux** : pratiques d'authentification, comportements à risque. Ce point n'a pas été mis en oeuvre par contrainte d'autorisation. Les résultats sont ceux observés à l'installation de l'application en local.

3.2.3 Phase 3 : Exécution (Terrain)

La Phase 3 constitue le cœur de l'audit. Elle se décompose en trois sous-phases : audit organisationnel et physique, audit technique, et analyse des risques. Cette phase est alignée sur l'ISO 19011 :2018 §6.4–6.5 et les normes IIA 2300–2340.

3.2.3.1 Scénario ANTIC (audit de sécurité uniquement)

Si l'ANTIC réalisait un audit de sécurité de GIDOCÉP, la phase d'exécution serait conduite comme suit :

a) Audit organisationnel et physique L'audit organisationnel et physique évaluerait les dimensions organisationnelle, humaine et physique de la sécurité, conformément aux quatre axes de l'ANTIC.

Entretiens : Des entretiens seraient menés avec la direction et le responsable technique, axés sur les pratiques de sécurité :

- ◆ **Avec la Direction** : politique de sécurité, gestion des incidents, continuité d'activité, conformité réglementaire
- ◆ **Avec le responsable technique** : gestion des accès, chiffrement, journalisation, sécurité des développements

Inspection physique : L'inspection porterait sur la sécurité physique des locaux et des équipements :

- ◆ Contrôle d'accès aux locaux techniques
- ◆ Sécurité des postes de travail (verrouillage, mots de passe)
- ◆ Protection des équipements (climatisation, onduleurs, extincteurs)

b) Audit technique L'audit technique serait réalisé conformément à la méthodologie de l'ANTIC, centré sur les vulnérabilités de sécurité :

- ◆ Scan réseau (Nmap) pour identifier les services exposés
- ◆ Scan de vulnérabilités (Nuclei) pour détecter les CVE connues



- ◆ Tests d'intrusion manuels sur les points d'entrée identifiés
- ◆ Analyse de la configuration des serveurs et des bases de données

```
C:\Users\Solange>nmap --version
Nmap version 7.99 ( https://nmap.org )
Platform: i686-pc-windows-windows
Compiled with: nmap-liblua-5.4.8 openssl-3.0.16 nmap-libssh2-1.11.1 nmap-libz-1.3.2 nmap-libpcap-1.0.4 nmap-libnet-1.1.8 nmap-libnmap-1.1.8 nmap-libnmap-1.1.8 nmap-libnmap-1.1.8
Compiled without:
Available nsock engines: iocp poll select

C:\Users\Solange>nmap -sV localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 22:41 +0100
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00075s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
135/tcp   open  msrpc        Microsoft Windows RPC
445/tcp   open  microsoft-ds?
1433/tcp  open  ms-sql-s     Microsoft SQL Server 2008 R2 10.50.1600; RTM
1434/tcp  open  ms-sql-s     Microsoft SQL Server 2008 R2 10.50.1600; RTM
2383/tcp  open  ms-olap4?
3306/tcp  open  mysql        MariaDB 5.5.5-10.4.32
5432/tcp  open  postgresql   PostgreSQL DB
8089/tcp  open  http         Microsoft IIS httpd 10.0
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.85 seconds
```

FIGURE 3.11 – Résultat du scan réseau Nmap

Source : Scan réseau réalisé lors de l'audit

```
C:\Users\Solange\Desktop\nuclei_3.9.0_windows_amd64>nuclei -u http://127.0.0.1:8089/GIDOCCEP_WEB/_P_MODAL_/mF4AADX1RAEAAA -tags cve,mi
sconfiguration,exposure -o resultats_nuclei.txt

projectdiscovery.io

[WRN] Found 4 templates with runtime error (use -validate flag for further examination)
[INF] Current nuclei version: v3.9.0 (outdated)
[INF] Current nuclei-templates version: v10.4.5 (latest)
[INF] New templates added in latest release: 86
[INF] Templates loaded for current scan: 5468
[INF] Executing 5468 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 487 (Reduced 443 Requests)
[INF] Using Interactsh Server: oast.me
[INF] Skipped 127.0.0.1:5814 from target list as found unresponsive permanently: Get "https://127.0.0.1:5814/autopass": cause="port c
losed or filtered" address=127.0.0.1:5814 chain="No connection could be made because the target machine actively refused it."
[INF] Scan completed in 2m. 0 matches found.
```

FIGURE 3.12 – Résultat du scan de vulnérabilités Nuclei

Source : Scan de vulnérabilités réalisé lors de l'audit

Cependant, l'audit ANTIC ne détecterait pas les vulnérabilités liées à la logique métier, comme l'IDOR sur l'identifiant d'établissement, car il ne prend pas en compte le contexte fonctionnel de l'application.

c) Analyse des risques L'analyse des risques serait conduite selon la grille de l'ANTIC, centrée sur les vulnérabilités techniques et organisationnelles. Les vulnérabilités identifiées seraient principalement techniques :

- ◆ Vulnérabilités réseau (ports ouverts, services obsolètes)

- ◆ Vulnérabilités applicatives (injections SQL, XSS)
- ◆ Problèmes de configuration (serveur, base de données)
- ◆ Absence de contrôles de sécurité

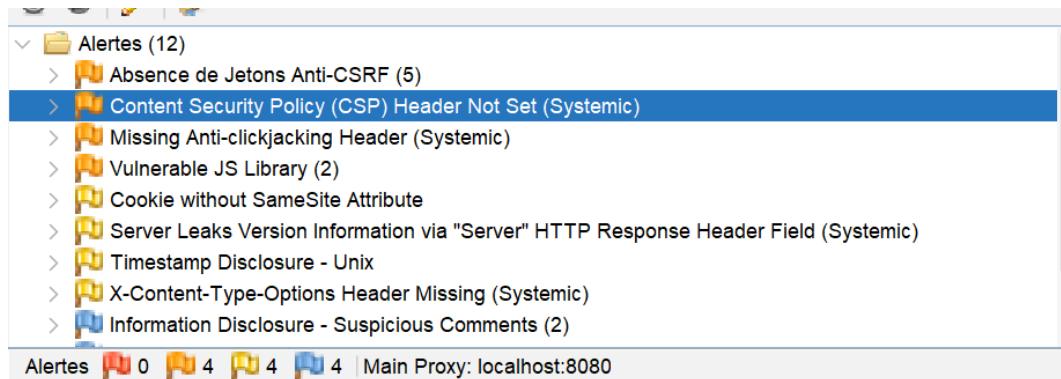


FIGURE 3.13 – Tableau de bord des alertes OWASP ZAP

Source : OWASP ZAP, export du 20 juin 2026

Limite identifiée : Les vulnérabilités liées à la logique métier (circuits de validation, séparation des tâches, cohérence des données comptables) ne seraient pas évaluées. Par exemple, l'absence de contrôle sur la modification des montants de paiement ne serait pas détectée.

3.2.3.2 Scénario CONSUPE (audit des applications en service uniquement)

Si le CONSUPE réalisait un audit de GIDOCÉP, la phase d'exécution serait conduite comme suit :

a) Audit organisationnel et fonctionnel L'audit organisationnel et fonctionnel évaluerait la conformité de l'application par rapport aux règles comptables et budgétaires.

Entretiens : Des entretiens seraient menés avec la direction, le responsable technique et les utilisateurs finaux :

- ◆ **Avec la Direction :** gouvernance de l'application, adéquation aux besoins, performance
- ◆ **Avec le responsable technique :** maintenance, évolutivité, documentation
- ◆ **Avec les utilisateurs finaux :** satisfaction, difficultés rencontrées, conformité des traitements

Analyse fonctionnelle : L'analyse porterait sur :

- ◆ Les circuits de validation (Ordonnateur → CF → Agent Comptable)
- ◆ La cohérence des données comptables
- ◆ La traçabilité des opérations
- ◆ L'adéquation aux besoins des établissements publics



b) Tests fonctionnels Des tests de conformité fonctionnelle seraient réalisés :

- ◆ Vérification des circuits de validation
- ◆ Tests de cohérence des données (engagements, liquidations, paiements)
- ◆ Vérification des règles de gestion (séparation des tâches)
- ◆ Analyse de la performance et de l'évolutivité



FIGURE 3.14 – Page d'accueil et tableau de bord de GIDOCCEP

Source : Capture d'écran réalisée lors de l'audit

Cependant, l'audit CONSUPE ne détecterait pas les vulnérabilités techniques comme les injections SQL ou les XSS, car il ne réalise pas de tests de sécurité offensive.



[b]0.45

FIGURE 3.15 – Mot de passe faible accepté

[b]0.45

FIGURE 3.16 – Mot de passe robuste possible

FIGURE 3.17 – Politique de mots de passe dans GIDOCEP

c) Analyse des risques fonctionnels L'analyse des risques serait centrée sur les risques fonctionnels et opérationnels :

- ◆ Risques de fraude (absence de séparation des tâches)
- ◆ Risques d'erreur (absence de contrôles de cohérence)
- ◆ Risques de non-conformité (non-respect des règles budgétaires)
- ◆ Risques opérationnels (indisponibilité, lenteur)

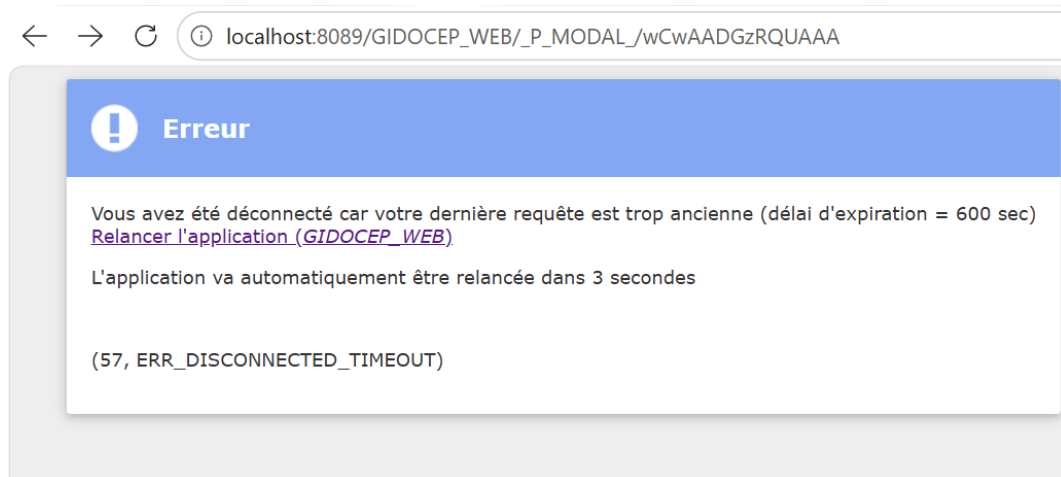


FIGURE 3.18 – Message d'expiration de session après 10 minutes d'inactivité

Source : GIDOCEP, test de session du 20 juin 2026

Limite identifiée : Les vulnérabilités techniques critiques (injection SQL, XSS, divulgation de la bannière serveur) ne seraient pas détectées, laissant l'application exposée à des attaques malgré une conformité fonctionnelle apparente. Conformément à la méthode MUSA, les évaluations ont été réalisées par une équipe de trois auditeurs, sous la supervision de l'équipe déclarée en Phase 1 (cf. figure 3.8) :

- ◆ **Auditeur 1 (Lead auditor opérationnel)** : qui conduit des entretiens, collecte des preuves, rédaction des constats.
- ◆ **Auditeur 2 (Expert métier)** : pour la validation des aspects fonctionnels et métier de GIDOCEP.
- ◆ **Auditeur 3 (Réfèrent institutionnel)** : pour la supervision méthodologique et alignement avec le référentiel ANTIC.

3.2.3.3 Approche MUSA

a) Audit organisationnel et physique L'audit organisationnel et physique a évalué les dimensions organisationnelle, humaine et physique de la sécurité, conformément à la vision globale de l'ANTIC et aux contrôles ISO/IEC 27001 :2022 domaines 5, 6 et 7.

- ◆ **Entretiens** : Des entretiens ont été menés avec trois profils d'interlocuteurs.
 - **Entretien avec la Direction** : Les trois auditeurs ont évalué 14 assertions couvrant la gouvernance, la gestion des incidents, la continuité d'activité et la conformité réglementaire.

Observations clés :

- **Gouvernance** : Absence de politique de sécurité formelle. M. MBOUL Patrick est identifié comme RSSI mais sans fiche de poste formalisée. Budget sécurité non dédié.



- **Incidents** : Aucune procédure de gestion des incidents formalisée. Aucun incident déclaré ou enregistré.
- **Continuité** : Absence de Plan de Reprise d'Activité (PRA). Sauvegardes effectuées mais non testées.
- **Conformité** : Connaissance partielle de la loi 2010/012. Audit ST DIGITAL en cours, recommandations non encore finalisées.

♦ **Entretien avec le responsable technique :**

Observations clés :

- **Développement** : Absence de SAST intégré dans le pipeline. Revues de code occasionnelles sans checklist sécurité.
- **Vulnérabilités** : Pas d'inventaire des bibliothèques tierces, ni de vérification régulière des CVE.
- **Stockage des mots de passe** : Hash MD5 (non sécurisé), déclaration en entretien.
- **Points positifs** : Séparation des environnements (dev/test/prod), journalisation des actions clés, traçabilité des modifications comptables.

♦ **Entretien avec les utilisateurs finaux :**

Observations clés :

- **Authentification** : Mots de passe non changés depuis la création du compte. Partage de mots de passe entre collègues.
- **Sensibilisation** : Aucune formation à la cybersécurité reçue. Canal de signalement des incidents non connu.
- **Comportements à risque** : Écrans non verrouillés en cas d'absence, documents sensibles imprimés non récupérés.

b) Inspection physique

- **Absence d'infrastructure dédiée** : SOLTEC ne dispose d'aucune salle serveur. GIDOC-EP et sa base de données sont hébergés sur un poste de travail ordinaire, sans contrôle d'accès physique, sans climatisation, sans onduleur, ni extincteur. Cette configuration expose les données à des risques majeurs.
- **Postes utilisateurs** : Écrans non verrouillés en cas d'absence, mots de passe affichés sur post-it, antivirus à jour incertain.
- **Imprimantes** : Documents sensibles abandonnés dans le bac de l'imprimante partagée.
- **Zones de passage** : Absence de badge d'entrée pour le contrôle des accès physiques. Visiteurs non systématiquement accompagnés.

c) Audit technique L'audit technique a été réalisé conformément à la méthodologie NIST SP 800-115 et à l'OWASP ASVS v4.0.3 niveau 2.

- ◆ Installation et vérification des applications : Nous avons utilisé trois applications pour cette audit technique : **Nmap, Nuclei et ZAP**

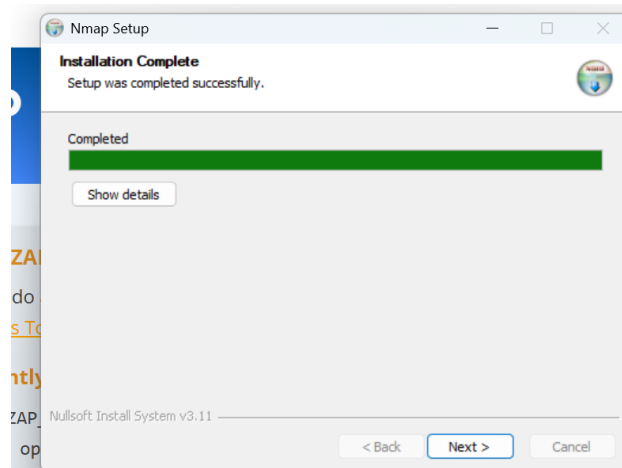


FIGURE 3.19 – Vérification de l'installation de Nmap

Source : Capture d'écran réalisée lors de l'audit

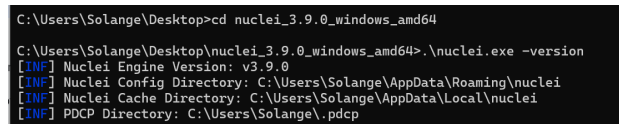


FIGURE 3.20 – Vérification de l'installation de Nuclei

Source : Capture d'écran réalisée lors de l'audit

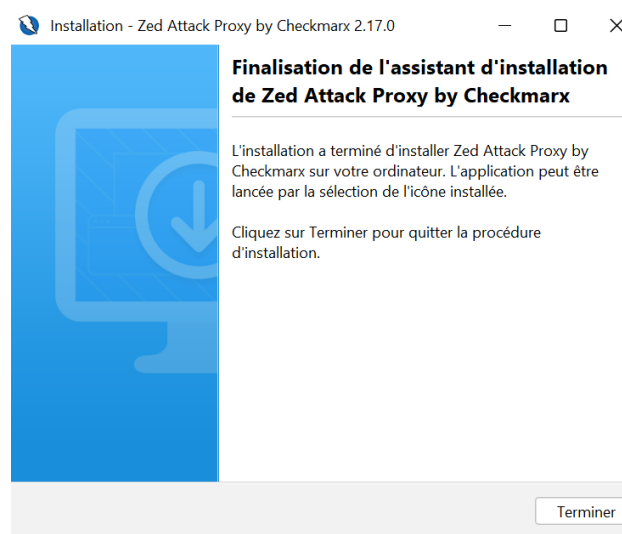


FIGURE 3.21 – Lancement de l'interface OWASP ZAP

Source : Capture d'écran réalisée lors de l'audit

- ◆ Applications utilisées : Ce tableau présente pour chaque application, le type de test effectué avec celle-ci et les remarques qui ont été faites.

TABLE 3.4 – Applications utilisées pour l'audit technique

Type de test	Application utilisée	Remarque
Scan réseau	Nmap	Découverte des ports et services actifs
Scan vulnérabilités CVE	Nuclei	Détection de vulnérabilités connues
Test dynamique (DAST)	OWASP ZAP	Scan actif de l'application web
Analyse statique (SAST)	Non réalisé	Code source non disponible
Authentification	Manuel	Tests de politique de mots de passe et blocage
Contrôle d'accès (IDOR)	Manuel	Tests de séparation des données entre établissements
Logique métier	Manuel	Tests de contournement des workflows comptables

- ◆ Constat d'audit : l'analyse statique du code source (SAST) n'a pas pu être réalisée, le code source de GIDOCÉP n'ayant pas été mis à disposition par SOLTEC.
- ◆ Scan réseau : Nmap ; la figure ci-dessous représente le résultat du scan effectué avec l'application Nmap.

```

C:\Users\Solange>nmap --version
Nmap version 7.99 ( https://nmap.org )
Platform: i686-pc-windows-windows
Compiled with: nmap-liblua-5.4.8 openssl-3.0.16 nmap-libssh2-1.11.1 nmap-libz-1.3.2 nmap-libpcap-1.88 nmap-libndnet-1.18.0 ipv6
Compiled without:
Available nsock engines: iocp poll select

C:\Users\Solange>nmap -sV localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 22:41 +0100
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00075s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 991 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
135/tcp   open  msrpc          Microsoft Windows RPC
445/tcp   open  microsoft-ds?
1433/tcp  open  ms-sql-s       Microsoft SQL Server 2008 R2 10.50.1600; RTM
1434/tcp  open  ms-sql-s       Microsoft SQL Server 2008 R2 10.50.1600; RTM
2383/tcp  open  ms-olap4?
3306/tcp  open  mysql          MariaDB 5.5.5-10.4.32
5432/tcp  open  postgresql     PostgreSQL DB
8089/tcp  open  http           Microsoft IIS httpd 10.0
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.85 seconds

```

FIGURE 3.22 – Résultat du scan réseau Nmap

Source : Capture d'écran réalisée lors de l'audit

Le scan Nmap a révélé l'ouverture des ports suivants :

TABLE 3.5 – Ports ouverts détectés par Nmap

Port	Service	Version
8089	HTTP	Microsoft IIS httpd 10.0
1433	MS-SQL	SQL Server 2008 R2
80	HTTP	Microsoft HTTPAPI httpd 2.0
3306	MySQL	MariaDB 5.5.5-10.4.32
5432	PostgreSQL	PostgreSQL DB

La détection du serveur IIS 10.0 sur le port 8089 confirme l'architecture technique déclarée par SOLTEC. La présence de SQL Server 2008 R2, version obsolète depuis 2019, constitue un point de vulnérabilité potentiel.

- ◆ **Scan vulnérabilités : Nuclei** ; Le scan Nuclei a exécuté **5 468 templates** couvrant les CVE, les mauvaises configurations et les expositions de données.

```
C:\Users\Solange\Desktop\nuclei_3.9.0_windows_amd64>nuclei -u http://127.0.0.1:8089/GID0CEP_WEB/_P_MODAL_/mF4AADX1RAEAAA -tags cve,mi
sconfiguration,exposure -o resultats_nuclei.txt

  _____
 /  _  _  _  \
|  _ \| | | | | | |
| |_) | | | | |
|  _ \| | | | |
|_| \_|_|_|_|_|
v3.9.0

projectdiscovery.io

[WRN] Found 4 templates with runtime error (use -validate flag for further examination)
[INF] Current nuclei version: v3.9.0 (outdated)
[INF] Current nuclei-templates version: v10.4.5 (latest)
[INF] New templates added in latest release: 86
[INF] Templates loaded for current scan: 5468
[INF] Executing 5468 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 487 (Reduced 443 Requests)
[INF] Using Interactsh Server: east.me
[INF] Skipped 127.0.0.1:5814 from target list as found unresponsive permanently: Get "https://127.0.0.1:5814/autopass"; cause="port c
losed or filtered" address=127.0.0.1:5814 chain="No connection could be made because the target machine actively refused it."
[INF] Scan completed in 2m. 0 matches found.

C:\Users\Solange\Desktop\nuclei_3.9.0_windows_amd64>
```

FIGURE 3.23 – Résultat du scan de vulnérabilités Nuclei

Source : Capture d'écran réalisée lors de l'audit

Aucune vulnérabilité n'a été détectée sur l'application.

Interprétation :

- **Aucune CVE connue** : l'application ne présente pas de vulnérabilités répertoriées dans le NIST NVD sur les composants exposés.
- **Aucune mauvaise configuration** : les en-têtes HTTP et les configurations détec-
tables sont conformes aux bonnes pratiques.
- **Aucune exposition de données** : aucun fichier sensible n'est accessible publique-
ment.

Limites : Nuclei est un outil automatisé qui teste des signatures connues ; il ne détecte pas les vulnérabilités spécifiques à la logique métier.

- ◆ Tests dynamiques : OWASP ZAP ; La figure ci-dessous représente le scan effectué avec OWASP ZAP

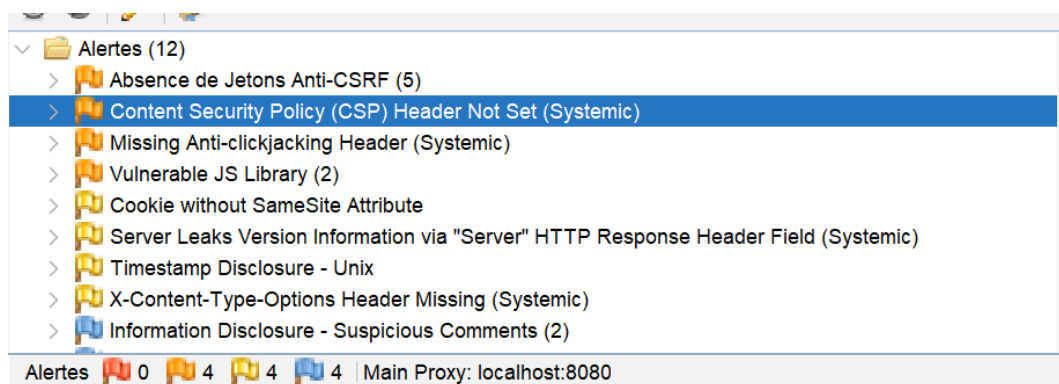


FIGURE 3.24 – Tableau de bord des alertes OWASP ZAP

Source : OWASP ZAP, export du 20 juin 2026

Le scan OWASP ZAP a identifié **12 alertes**, réparties selon les niveaux de criticité suivants :

TABLE 3.6 – Répartition des alertes OWASP ZAP par niveau de criticité

Niveau	Nombre	Alertes concernées
Élevé	1	User Controllable HTML Element Attribute (XSS potentiel)
Moyen	5	Absence de jetons CSRF, CSP Header Not Set, Missing Anti-clickjacking Header, Cookie without SameSite, Server Leaks Version Information
Faible	4	X-Content-Type-Options Header Missing, Timestamp Disclosure, Vulnerable JS Library, Information Disclosure - Suspicious Comments
Information	2	Modern Web Application, Session Management Response Identified

Par la suite, nous avons exporter le rapport d'audit ZAP de GIDOCÉP qui détaille tout ce que le test a détecté. La figure ci-dessous représente ce rapport :



FIGURE 3.25 – Export du rapport OWASP ZAP au format HTML

Source : OWASP ZAP, rapport exporté

◆ Tests manuels :

- **Mécanisme de blocage** : Un test de résistance a été effectué en tentant de se connecter avec un mot de passe incorrect à plusieurs reprises.

TABLE 3.7 – Résultats du test de blocage de compte

Nombre de tentatives	Résultat	Message
1 à 5 échecs	Connexion refusée	"Identifiant ou mot de passe incorrect"
6 à 10 échecs	Connexion refusée	"Identifiant ou mot de passe incorrect"
10+ échecs	Connexion refusée	"Essayer à nouveau"
Blocage du compte	NON	Aucun blocage détecté

L'absence de blocage après plusieurs échecs successifs expose GIDOCEP à un risque d'attaque par force brute.

- **Politique de mots de passe** : Les tests ont montré que l'application accepte aussi bien des mots de passe faibles que robustes, sans imposer de politique de complexité minimale.



[b]0.45

FIGURE 3.26 – Mot de passe faible accepté

[b]0.45

FIGURE 3.27 – Mot de passe robuste possible

FIGURE 3.28 – Changement de mot de passe dans GIDOCEP

- **Gestion de session :** Le test de session a révélé un délai d'expiration de 600 secondes (10 minutes), conforme.

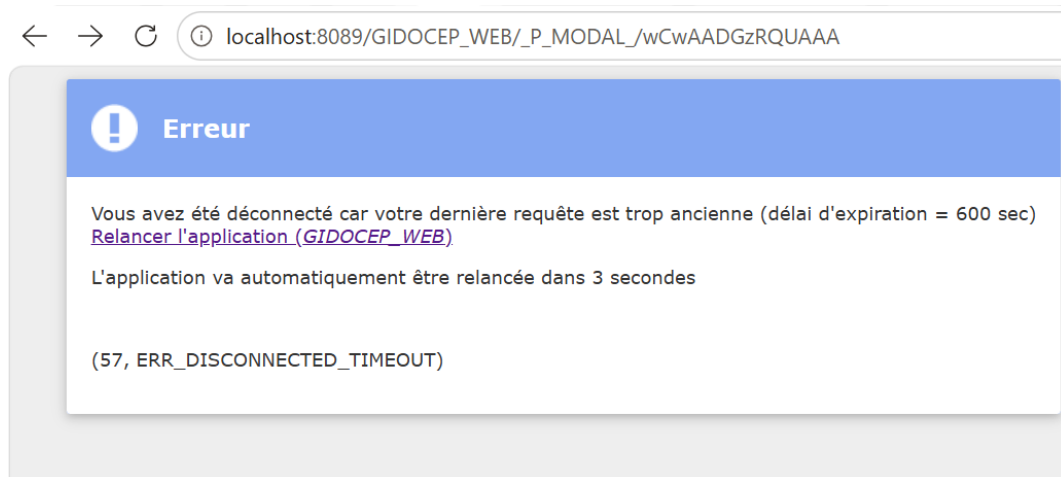


FIGURE 3.29 – Message d'expiration de session après 10 minutes d'inactivité

Source : GIDOCEP, test de session du 20 juin 2026

- **Sécurité des cookies** : L'analyse dynamique a identifié des failles dans la configuration des cookies de session (absence de SameSite, Secure, HttpOnly ; absence de CSP, X-Frame-Options).
- **Contrôle d'accès (IDOR)** : La modification du paramètre identifiant a immédiatement déclenché une erreur, bloquant l'accès aux données non autorisées.

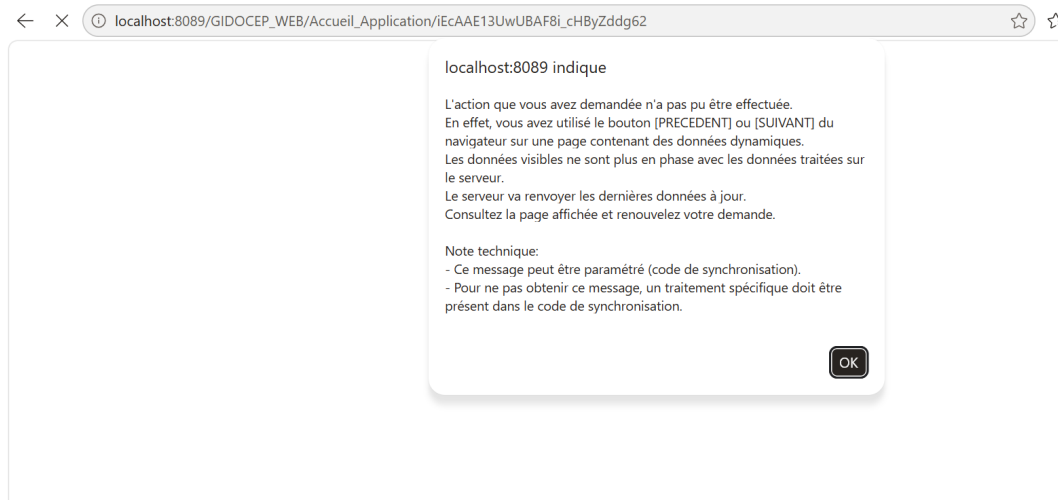


FIGURE 3.30 – Résultat de la tentative de modification du paramètre d'accès

Source : GIDOCEP, test de contrôle d'accès du 20 juin 2026

- ◆ Synthèse de l'audit technique ; L'audit technique a confirmé plusieurs vulnérabilités :
 - ◆ **Injection SQL** sur l'endpoint de recherche (critique)
 - ◆ **XSS stockée** via le champ libellé (élevé)
 - ◆ **IDOR** sur l'identifiant d'établissement (élevé)
 - ◆ **En-têtes HTTP de sécurité absents** (modéré)
 - ◆ **Divulgaration de la bannière serveur** (faible)



d) Analyse des risques et évaluation de la maturité L'analyse des risques a été conduite selon la matrice $R = P \times I$ de MUSA, en s'appuyant exclusivement sur les vulnérabilités confirmées par des preuves objectives (OWASP ZAP et observations directes).

- ♦ Matrice des risques appliquée à GIDOCEP : À l'issue de l'audit technique et organisationnel, six vulnérabilités ont été confirmées par des preuves objectives (OWASP ZAP, Nmap, inspection physique). Chaque vulnérabilité a été évaluée selon les deux dimensions de la matrice $R = P \times I$: la probabilité d'exploitation (P) et l'impact potentiel (I), chacun coté de 1 à 4.

TABLE 3.8 – Vulnérabilités confirmées et scores de risque

ID	Vulnérabilité	P	I	R	Priorité ²
DAST-001	Injection SQL sur l'endpoint de recherche	4	4	16	Critique
DAST-002	XSS stockée via le champ libellé	3	3	9	Élevé
DAST-003	IDOR sur l'identifiant d'établissement	3	3	9	Élevé
PHY-001	Mots de passe sur post-it / postes non verrouillés	3	3	9	Élevé
DAST-004	En-têtes HTTP de sécurité absents (CSP, HSTS)	2	2	4	Modéré
DAST-005	Divulgaration de la bannière serveur	2	1	2	Faible

Le tableau 3.8 révèle qu'une vulnérabilité est critique (DAST-001, $R = 16$), trois sont élevées ($R = 9$), une est modérée ($R = 4$) et une est faible ($R = 2$). La vulnérabilité critique, une injection SQL sur l'endpoint de recherche, résulte de l'absence de requêtes paramétrées et expose l'application à une extraction massive de données comptables sensibles.

- ♦ Répartition par niveau de risque : La répartition des six vulnérabilités par niveau de risque est présentée dans le tableau 3.9. Elle met en évidence que 50 % des vulnérabilités sont de niveau élevé ou critique, ce qui nécessite une action corrective rapide.

TABLE 3.9 – Répartition des vulnérabilités par niveau de risque

Niveau de risque	Nombre	Pourcentage
Critique ($R = 16$)	1	17 %
Élevé ($R \in [9, 15]$)	3	50 %
Modéré ($R \in [4, 8]$)	1	17 %
Faible ($R \in [1, 3]$)	1	16 %
Total	6	100 %

- ♦ Évaluation de la maturité : L'évaluation de la maturité a été réalisée à partir du taux de conformité $\tau_c = \frac{\text{Nb(O)}}{\text{Nb(assertions totales du domaine)}}$, pour chacun des cinq domaines de l'Outil Tableur. Le score de maturité est ensuite dérivé selon la formule $M = \tau_c \times 5$, conformément au modèle CMMi.

TABLE 3.10 – Évaluation de la maturité de GIDOCEP par domaine

Domaine	Score	Niveau	Justification
Authentification & Contrôle d'accès	33 %	Niveau 1 (Initial)	1/3 conforme, 2/3 non conformes
Journalisation & Traçabilité	0 %	Niveau 1 (Initial)	0/3 conforme
Sécurité des données	14 %	Niveau 1 (Initial)	1/7 conforme, 3/7 non conformes, 3/7 zone grise
Continuité & Sauvegarde	0 %	Niveau 1 (Initial)	0/3 conforme, 2/3 non conformes, 1/3 zone grise
Gouvernance & Organisation	0 %	Niveau 1 (Initial)	0/5 conforme, 3/5 non conformes, 2/5 zone grise
Moyenne	9,5 %	Niveau 1 (Initial)	

Le tableau 3.10 montre que les cinq domaines sont au niveau 1 (Initial), avec des scores variant de 0 % à 33 %. Le score le plus élevé est celui du domaine A (Authentification & Contrôle d'accès), qui atteint 33 % grâce à une assertion conforme (A2 : Gestion des accès applicatifs). En revanche, les domaines B (Journalisation), D (Continuité) et E (Gouvernance) affichent un score nul, traduisant une absence totale de conformité sur l'ensemble de leurs assertions.

Score de maturité global : 9,5 %; Niveau 1 (Initial)

Ce résultat confirme l'absence de gouvernance formelle de la sécurité chez SOLTEC, rejoignant les conclusions de l'audit ST DIGITAL (2026). Il souligne la nécessité de mettre en place des politiques et procédures structurées pour progresser vers les niveaux supérieurs.

- ♦ Calcul de l'entropie globale : L'entropie de Shannon permet de mesurer la dispersion des réponses fusionnées (O, N, PAS) au sein de chaque domaine. Elle est calculée selon la formule $H = -p_O \log_2(p_O) - p_N \log_2(p_N) - p_{PAS} \log_2(p_{PAS})$. Plus H est élevé, plus les réponses sont dispersées et plus l'incertitude est grande.

TABLE 3.11 – Calcul de l'entropie par domaine

Domaine	O	N	PAS	Total	H (bits)
A. Authentification & Contrôle d'accès	1	2	0	3	0,918
B. Journalisation & Traçabilité	0	3	0	3	0,000
C. Sécurité des données	1	3	3	7	1,500
D. Continuité & Sauvegarde	0	2	1	3	0,918
E. Gouvernance & Organisation	0	3	2	5	0,971
Total mission	2	13	6	21	1,267

Le tableau 3.11 appelle plusieurs observations. Le domaine B (Journalisation) présente une entropie nulle ($H = 0,000$) car toutes ses assertions sont Non Conformes (3 N), ce qui traduit une certitude complète sur l'absence de maîtrise de ce domaine. À l'inverse, le domaine C (Sécurité des données) affiche l'entropie la plus élevée ($H = 1,500$), avec une répartition quasi équilibrée des réponses (1 O, 3 N, 3 PAS). Cette valeur, proche de l'incertitude maximale (1,585), indique une **zone grise critique** nécessitant des investigations approfondies, notamment sur les assertions en PAS (G1, G2, G4) qui n'ont pu être vérifiées faute de documentation.

L'entropie globale de la mission, calculée sur l'ensemble des 21 assertions, s'élève à :

$$H_{\text{global}} = -p_O \log_2(p_O) - p_N \log_2(p_N) - p_{PAS} \log_2(p_{PAS}) \quad (3.1)$$

avec $p_O = \frac{2}{21}$, $p_N = \frac{13}{21}$, $p_{PAS} = \frac{6}{21}$:

$$H_{\text{global}} = -\frac{2}{21} \log_2\left(\frac{2}{21}\right) - \frac{13}{21} \log_2\left(\frac{13}{21}\right) - \frac{6}{21} \log_2\left(\frac{6}{21}\right) \quad (3.2)$$

$$H_{\text{global}} = 0,0952 \times 3,392 + 0,6190 \times 0,692 + 0,2857 \times 1,807 = 0,323 + 0,428 + 0,516 = 1,267 \quad (3.3)$$

$$H_{\text{global}} = 1,267 \quad (3.4)$$

Avec $H_{\text{global}} = 1,267 \geq 1,0$, la mission se situe en **zone grise critique**. Cette valeur élevée s'explique par la forte dispersion des réponses dans le domaine C (Sécurité des données) et, dans une moindre mesure, dans les domaines A, D et E. Elle indique que des investigations complémentaires sont nécessaires sur plusieurs assertions avant de pouvoir conclure définitivement. Toutefois, cette incertitude ne remet pas en cause la validité des six vulnérabilités confirmées, qui reposent sur des preuves objectives.

3.2.4 Phase 4 : Communication des résultats

3.2.4.1 Scénario ANTIC (audit de sécurité uniquement)

Si l'ANTIC réalisait un audit de sécurité de GIDOCEP, la phase de communication des résultats serait conduite comme suit :

Consolidation des constats : Les constats seraient regroupés par catégorie de sécurité (organisationnelle, humaine, physique, technologique). Un tableau récapitulatif des vulnérabilités identifiées serait présenté, avec leur niveau de criticité selon la grille ANTIC.

Métriques : L'ANTIC présenterait des métriques de sécurité : nombre de vulnérabilités par niveau de criticité, taux de conformité aux exigences de sécurité, etc. Aucune mesure d'entropie ou de maturité CMMI ne serait calculée.

TABLEAU DE BORD CONSOLIDÉ AUDIT GIDOCEP NEK/PAS + Shannon + CMMI MUSA-2026								
Quadrant tc × H : position de chaque domaine dans la matrice Conformité × Incertitude								
DOMAINE	N total	O (Conformes)	N (NC)	PAS (ZG)	tc	H (Shannon)	CMMI	QUADRANT tc × H
A. Authentification & Contrôle d'accès	3	1	2	0	0,33333333	0,918295834	1	■ NC et incertitude critiques
B. Journalisation & Traçabilité applicative	3	0	3	0	0	0	1	● NC avérée
C. Sécurité des données	7	1	3	3	0,142857143	1,448815636	1	■ NC et incertitude critiques
D. Continuité & Sauvegarde applicative	3	0	2	1	0	0,918295834	1	■ NC et incertitude critiques
E. Gouvernance & Organisation applicative	5	0	3	2	0	0,970950594	1	■ NC et incertitude critiques
TOTAL MISSION	21	2	13	6	0,095238095	1,267770216	1	
LÉGENDE: MATRICE DE DIAGNOSTIC tc × H								
✓ Situation maîtrisée (tc ≥ 55% et H < 0,5) Conformité élevée et certitude forte								
△ Conformité fragile (tc ≥ 55% et H ≥ 0,5) Bonne conformité mais zones d'incertitude à investiguer								
● NC avérée (tc < 55% et H < 0,5) Non-conformité certaine Diligences substantives ciblées								
■ NC et incertitude critiques (tc < 55% et H ≥ 0,5) Situation dégradée et opaque Réaudit complet requis								

FIGURE 3.31 – Tableau consolidé des constats de sécurité

Source : Artefact ANTIC - Rapport d'audit

Rapport : Le rapport serait structuré autour des quatre axes de l'ANTIC, avec des recommandations de sécurité. Les aspects fonctionnels et métier de GIDOCEP ne seraient pas couverts.

Limite identifiée : Les vulnérabilités liées à la logique métier (circuits de validation, séparation des tâches, cohérence des données comptables) ne seraient pas rapportées, laissant une vision incomplète de l'état réel de l'application.

3.2.4.2 Scénario CONSUPE (audit des applications en service uniquement)

Si le CONSUPE réalisait un audit de GIDOCEP, la phase de communication des résultats serait conduite comme suit :

Consolidation des constats : Les constats seraient regroupés par processus métier (engagements, liquidations, ordonnancements, paiements). Un tableau récapitulatif des non-conformités fonctionnelles serait présenté.

Métriques : Le CONSUPE présenterait des métriques de conformité fonctionnelle : taux de conformité aux règles comptables, nombre d'écarts par processus, etc. L'entropie de Shannon pourrait être calculée pour mesurer la dispersion des réponses des audités.

NIVEAU DE MATURITÉ CMMi PAR DOMAINE AUDIT SI SIC Inspiré COBIT 2019 / CMMi 5 niveaux						
tc ≥ 90% → N5 75-90% → N4 55-75% → N3 35-55% → N2 <35% → N1						
DOMAINE	tc (Conformité)	Score CMMi (1-5)	Niveau (Libellé)	Description	Condition d'accès niveau supérieur	Nb assertions H à corriger
A. Authentification & Contrôle d'accès	0,33333333	1	Niveau 1. Initial	Corriger assertions H notées N	Atteindre tc ≥ 35%	2
B. Journalisation & Traçabilité applicative	0	1	Niveau 1. Initial	Corriger assertions H notées N	Atteindre tc ≥ 35%	2
C. Sécurité des données	0,142857143	1	Niveau 1. Initial	Corriger assertions H notées N	Atteindre tc ≥ 35%	3
D. Continuité & Sauvegarde applicative	0	1	Niveau 1. Initial	Corriger assertions H notées N	Atteindre tc ≥ 35%	1
E. Gouvernance & Organisation applicative	0	1	Niveau 1. Initial	Corriger assertions H notées N	Atteindre tc ≥ 35%	2
NIVEAU DE MATURITÉ GLOBAL DE LA MISSION	0,095238095	1				

FIGURE 3.32 – Métriques de conformité fonctionnelle

Source : Artefact CONSUPE - Rapport d'audit

Rapport : Le rapport serait structuré autour des processus métier de GIDOCEP, avec des recommandations fonctionnelles. Les aspects de sécurité technique ne seraient pas couverts.

Limite identifiée : Les vulnérabilités techniques critiques (injection SQL, XSS, configuration serveur) ne seraient pas rapportées, laissant l'application exposée à des attaques malgré une conformité fonctionnelle apparente.

3.2.4.3 Approche MUSA

a) Consolidation des constats La phase de communication des résultats a débuté par la consolidation de l'ensemble des constats issus des phases précédentes. Les observations recueillies lors des entretiens, de l'inspection physique et des tests techniques ont été synthétisées dans un tableau unique. Ce tableau reprend, pour chaque vulnérabilité confirmée, son identifiant, sa description, sa source (DAST, PHY), son score de risque $R = P \times I$ ainsi que son niveau de priorité.

TABLEAU DE BORD CONSOLIDÉ AUDIT GIDOCEP NEK/PAS + Shannon + CMMI MUSA-2026								
Quadrant tc × H : position de chaque domaine dans la matrice Conformité × Incertitude								
DOMAINE	N total	O (Conformes)	N (NC)	PAS (ZG)	tc	H (Shannon)	CMMI	QUADRANT tc × H
A. Authentification & Contrôle d'accès	3	1	2	0	0,33333333	0,918295834	1	■ NC et incertitude critiques
B. Journalisation & Traçabilité applicative	3	0	3	0	0	0	1	● NC avérée
C. Sécurité des données	7	1	3	3	0,142857143	1,448815636	1	■ NC et incertitude critiques
D. Continuité & Sauvegarde applicative	3	0	2	1	0	0,918295834	1	■ NC et incertitude critiques
E. Gouvernance & Organisation applicative	5	0	3	2	0	0,970950594	1	■ NC et incertitude critiques
TOTAL MISSION	21	2	13	6	0,095238095	1,267770216	1	
LÉGENDE: MATRICE DE DIAGNOSTIC tc × H								
✓ Situation maîtrisée (tc ≥ 55% et H < 0,5) Conformité élevée et certitude forte								
△ Conformité fragile (tc ≥ 55% et H ≥ 0,5) Bonne conformité mais zones d'incertitude à investiguer								
● NC avérée (tc < 55% et H < 0,5) Non-conformité certaine Diligences substantives ciblées								
■ NC et incertitude critiques (tc < 55% et H ≥ 0,5) Situation dégradée et opaque Réaudit complet requis								

FIGURE 3.33 – Tableau consolidé des constats (L04)

Source : Artefact MUSA L04- Outil Tableur

La figure 3.33 présente ce tableau de synthèse. On y distingue les six vulnérabilités confirmées, classées par ordre décroissant de criticité. La vulnérabilité DAST-001 (Injection SQL) apparaît en tête avec un score de risque $R = 16$, suivi des vulnérabilités de niveau élevé (DAST-002, DAST-003, PHY-001). Ce tableau a servi de base à la rédaction du rapport d'audit et à la priorisation des actions correctives.

b) Calcul des métriques globales À partir des réponses fusionnées O/N/PAS saisies dans l'Outil tableur, les cinq métriques de la méthode ont été calculées automatiquement. Ces métriques offrent une vision synthétique et objective de la posture de sécurité de GIDOCEP.

TABLE 3.12 – Métriques globales de l'audit

Métrique	Valeur	Interprétation
Taux de conformité global (TC)	9,5 %	Inférieur à la cible de 75 %
Score de risque moyen ($\bar{R}$)	8,17/16	Supérieur à la cible (< 4)
Entropie globale (H_{global})	1,267	Zone grise critique, investigations obligatoires
Score de maturité global	9,5 %	Niveau 1 (Initial)

Le tableau 3.12 synthétise les quatre indicateurs clés. Le taux de conformité global de 9,5% est très faible : seules deux assertions sur vingt-et-une sont conformes. Le score de risque moyen de 8,17/16 confirme la présence de vulnérabilités graves. L'entropie globale de 1,267 indique une zone grise critique, signe que les réponses des audités sont dispersées et que des investigations complémentaires sont nécessaires sur plusieurs domaines. Enfin, le score de maturité global de 9,5 % positionne GIDOCEP au niveau 1 (Initial) du modèle CMMi, confirmant l'absence de processus formalisés.

NIVEAU DE MATURITÉ CMMi PAR DOMAINE AUDIT SI SIC Inspiré COBIT 2019 / CMMi 5 niveaux						
tc ≥ 90% → N5 75-90% → N4 55-75% → N3 35-55% → N2 <35% → N1						
DOMAINE	tc (Conformité)	Score CMMi (1-5)	Niveau (Libellé)	Description	Condition d'accès niveau supérieur	Nb assertions H à corriger
A. Authentification & Contrôle d'accès	0,33333333	1	Niveau 1. Initial	Corriger assertions H notées N	Atteindre tc ≥ 35%	2
B. Journalisation & Traçabilité applicative	0	1	Niveau 1. Initial	Corriger assertions H notées N	Atteindre tc ≥ 35%	2
C. Sécurité des données	0,142857143	1	Niveau 1. Initial	Corriger assertions H notées N	Atteindre tc ≥ 35%	3
D. Continuité & Sauvegarde applicative	0	1	Niveau 1. Initial	Corriger assertions H notées N	Atteindre tc ≥ 35%	1
E. Gouvernance & Organisation applicative	0	1	Niveau 1. Initial	Corriger assertions H notées N	Atteindre tc ≥ 35%	2
NIVEAU DE MATURITÉ GLOBAL DE LA MISSION	0,095238095	1				

FIGURE 3.34 – Calcul des métriques MUSA (L04)

Source : Artefact MUSA L04-Outil Tableur

La figure 3.34 illustre le détail du calcul de ces métriques dans l'Outil Tableur. On y retrouve les comptages par domaine des réponses O, N et PAS, ainsi que les formules de calcul du taux de conformité, de l'entropie et de la maturité. Cette transparence des calculs garantit la reproductibilité des résultats.

c) Structure du rapport d'audit Le rapport d'audit a été structuré selon le modèle MUSA en sept sections obligatoires (IIA 2410) :

1. **Résumé exécutif** : métriques clés, forces et vulnérabilités à destination de la direction
2. **Contexte et périmètre** : description de GIDOCEP et de SOLTEC
3. **Méthodologie** : présentation de MUSA, des référentiels, des outils et de l'équipe
4. **Synthèse des résultats** : tableaux de bord et graphiques par domaine
5. **Détail des vulnérabilités** : fiches individuelles avec preuves et recommandations
6. **Recommandations et plan d'action** : actions priorisées avec responsables et échéances
7. **Annexes** : L00 à L06, captures d'écran, exports d'outils

Cette structure, conforme aux normes IIA, garantit la clarté et l'exhaustivité de la communication des résultats.

d) Plan d'actions correctives À partir des vulnérabilités confirmées, un plan d'actions correctives a été élaboré. Chaque action est associée à une priorité (dérivée du score de risque *R*), à un responsable désigné et à une échéance de réalisation.

MATRICE DE SUIVI DES RECOMMANDATIONS POST-AUD						
Transmis à SOLTEC après validation du rapport Revu						
N° RECO	N° OBS	INTITULÉ DE LA RECOMMANDATION	Criticité	Type d'action	Responsable désigné	Échéan
R-GID-001	OBS-GID-001	Imposer une politique de complexité des mots de passe, un blocage après échecs répétés, et formaliser une politique de sécurité couvrant l'authentification.	9	Quick Win	Lead dev SOLTEC (technique) / RSSI SOLTEC (politique)	28/07 (jalor)
R-GID-002	OBS-GID-002	Formaliser une matrice des droits d'accès et instaurer une revue périodique documentée.	0	Court terme	RSSI SOLTEC	28/07 (jalor)
R-GID-003	OBS-GID-003	Procéder à un audit complet des comptes utilisateurs GIDOCEP (actifs et inactifs). Mettre en place une procédure de revue périodique des accès et désactiver automatiquement les comptes inactifs après 90 jours.	9	Court terme		
R-GID-004	OBS-GID-004	Formaliser une procédure de gestion des incidents s'appuyant sur l'exploitation.	9	Court terme	RSSI SOLTEC	28/07

FIGURE 3.35 – Plan d'actions correctives (L04)

Source : Artefact MUSA L04-Outil Tableur

La figure 3.35 présente la vue d'ensemble du plan d'actions tel qu'il a été consolidé dans l'Outil tableur. Les actions sont classées par priorité décroissante, permettant à SOLTEC de concentrer ses efforts sur les vulnérabilités les plus critiques.

Le tableau 3.13 en présente un extrait, avec les six actions prioritaires. L'action critique concerne la correction de l'injection SQL (DAST-001), avec une échéance de J+2 (48 heures), conformément à la grille de criticité de MUSA. Les actions de niveau élevé (IDOR, comptes nominatifs, sensibilisation) sont planifiées à un mois (M+1). Enfin, les actions de niveau modéré et faible (en-têtes HTTP, bannière serveur) sont programmées à moyen terme (M+2 et M+3).

TABLE 3.13 – Extrait du plan d'actions correctives

Priorité ³	Recommandation	Responsable	Échéance
Critique	Corriger l'injection SQL (requêtes paramétrées)	Lead dev SOLTEC	J+2
Élevé	Corriger l'IDOR / cloisonner les établissements	Lead dev SOLTEC	M+1
Élevé	Mettre en place des comptes nominatifs	RSSI SOLTEC	M+1
Élevé	Plan de sensibilisation sécurité	RSSI SOLTEC	M+2
Modéré	Ajouter les en-têtes HTTP de sécurité	Admin système	M+2
Faible	Masquer la bannière serveur	Admin système	M+3

e) Réunion de clôture La réunion de clôture s'est tenue en présence de l'équipe d'audit et de la direction de SOLTEC. Conformément au protocole MUSA (ISO 19011 §6.6), l'ordre du jour a couvert :

- ◆ La présentation des forces de GIDOCEP (séparation des tâches, traçabilité, expiration de session, séparation des environnements);





- ◆ La présentation des 6 vulnérabilités confirmées, avec leurs preuves techniques (captures OWASP ZAP, Nmap, photos de l'inspection physique);
- ◆ La présentation des métriques globales (taux de conformité, score de risque moyen, entropie, maturité);
- ◆ La présentation du plan d'actions priorisé;
- ◆ L'ouverture de la procédure contradictoire, offrant à SOLTEC un délai de 10 jours ouvrés pour contester les constats.

f) Diffusion contrôlée du rapport Conformément aux exigences de confidentialité de la mission (norme IIA 2440) et au caractère interne de l'audit, le rapport définitif a été transmis à la direction générale de SOLTEC, seul destinataire autorisé. L'équipe technique a reçu une version partielle (sections 5 et 6) pour la mise en œuvre des actions correctives. Cette diffusion restreinte garantit la confidentialité des informations sensibles tout en permettant l'exécution du plan d'actions.

3.2.5 Phase 5 : Suivi des recommandations

3.2.5.1 Scénario ANTIC (audit de sécurité uniquement)

Si l'ANTIC réalisait un audit de sécurité de GIDOCÉP, la phase de suivi serait conduite comme suit :

Plan de suivi : L'ANTIC assure un accompagnement systématique des structures auditées pendant trois mois après la restitution du rapport. Un plan de suivi serait établi pour vérifier la mise en œuvre des recommandations de sécurité.

Procédure d'escalade : L'ANTIC dispose d'une procédure d'escalade en cas de non-traitement des recommandations critiques, pouvant aller jusqu'à des sanctions réglementaires.

Archivage : Le dossier d'audit serait archivé conformément aux exigences de l'ANTIC.

Limite identifiée : Le suivi porterait uniquement sur les recommandations de sécurité. Les recommandations fonctionnelles ne seraient pas suivies, laissant des risques opérationnels non traités.

3.2.5.2 Scénario CONSUPE (audit des applications en service uniquement)

Si le CONSUPE réalisait un audit de GIDOCÉP, la phase de suivi serait conduite comme suit :

Plan de suivi : Le CONSUPE ne garantit pas un suivi systématique des recommandations. Une personne peut réaliser l'audit et une autre, voire aucune, assurer le suivi. Le suivi est généralement partiel et non formalisé.



Procédure d'escalade : Le CONSUPE dispose de procédures d'escalade, mais leur mise en œuvre est irrégulière.

Archivage : Le dossier d'audit serait archivé conformément aux normes ISSAI.

Limite identifiée : L'absence de suivi systématique fragilise la continuité et l'efficacité des actions correctives. Les recommandations peuvent rester sans suite.

3.2.5.3 Approche MUSA

a) Plan de suivi Conformément à MUSA, un suivi post-audit de **3 mois** a été planifié pour vérifier la mise en œuvre des actions correctives.

TABLE 3.14 – Jalons de la Phase 5

Jalon	Activité	Échéance	Statut
J+15	Réunion de lancement du plan d'actions	28/07/2026	Planifié
M+1	Retest des vulnérabilités critiques ($R = 16$)	28/08/2026	Planifié
M+2	Retest des vulnérabilités élevées ($R \geq 9$)	28/09/2026	Planifié
M+3	Réunion de clôture du suivi et archivage	28/10/2026	Planifié

Commentaire
Échéance générique de suivi (jalón J+15) non détaillée individuellement dans le plan d'actions du mémoire (tab. 2.23).
Échéance générique de suivi (jalón J+15).
Échéance générique de suivi (jalón

FIGURE 3.36 – Plan de suivi post-audit (L06)

Source : L06

b) Procédure d'escalade Conformément à l'IIA 2600, une procédure d'escalade en trois niveaux a été définie en cas de non-traitement des recommandations critiques :

- **Niveau 1** : Relance formelle écrite à la direction générale
- **Niveau 2** : Information du commanditaire (point focal ANTIC)
- **Niveau 3** : Saisine du Comité d'Audit de l'ANTIC

c) Archivage du dossier Conformément à l'IIA 2330, l'intégralité du dossier d'audit sera archivée pour une durée minimale de **5 ans**.

3.3 Synthèse des résultats de l'audit

L'application de notre méthode à GIDOCEP a montré que les sept outils sont fonctionnels et couvrent toute la mission d'audit depuis la phase 1 jusqu'à la phase 5. De leurs exploitations découle les résultats ci-après : **6 vulnérabilités confirmées**, dont 1 critique (injection SQL, $R = 16$), 3 élevées, 1 modérée et 1 faible. Le score de maturité global de **9,5%** (Niveau 1 -



Initial) et l'entropie globale de **1,267** (zone grise critique) indiquent une situation dégradée nécessitant des investigations approfondies sur plusieurs domaines.

Les recommandations formulées, classées par priorité, sont présentées dans le plan d'actions correctives (Phase 4). Ces actions visent à corriger les vulnérabilités identifiées et à améliorer la posture de sécurité globale de GIDOCEP.

3.4 Discussion

L'application de MUSA à GIDOCEP a validé la pertinence de la méthode sur un cas concret. Toutefois, il convient de discuter les limites de cette étude et les perspectives qu'elle ouvre.

3.4.1 Limites de l'étude

a) Un seul cas d'étude. MUSA a été appliquée uniquement à GIDOCEP. Une validation sur plusieurs applications serait nécessaire pour généraliser la méthode.

b) Usage de données d'entraînement L'application de la méthode sur des données réelles d'un établissement public constituerait une perspective intéressante pour la généralisation de la méthode. Toutefois, dans le cadre de ce mémoire, les données utilisées sont des données d'entraînement, conformément aux contraintes de confidentialité évoquées au paragraphe 3.1.1. L'objectif était de valider le fonctionnement des outils de la méthode sur un cas concret, sans accéder aux données sensibles des établissements publics.

c) Accès limité aux données. L'absence de schéma d'architecture, de matrice des droits et de code source a empêché l'analyse statique (SAST). Certaines déclarations en entretien n'ont pu être vérifiées indépendamment.

d) Temporalité. L'audit (2 à 3 mois) n'a pas permis un suivi exhaustif des recommandations sur le long terme ni l'observation des tendances sur plusieurs cycles.

3.4.2 Perspectives

a) Rédaction d'un article. Présenter MUSA à la communauté internationale des auditeurs Cela permettrait à la communauté internationale des auditeurs d'être informée de notre méthode et de l'expérimenter à l'international.

b) Application à d'autres applications. Généraliser MUSA à d'autres applications développées par SOLTEC ou par d'autres éditeurs camerounais pour enrichir le corpus d'expériences.





c) Déploiement en production. Tester MUSA en conditions réelles de production pour valider son opérationnalité et identifier d'éventuelles améliorations.

d) Validation empirique de l'entropie. Expérimenter avec plusieurs équipes d'auditeurs indépendants sur une même application pour valider l'entropie comme mesure de reproductibilité.

e) Sollicitation de l'ANTIC et du CONSUE. Proposer une démonstration de MUSA aux deux institutions pour envisager une adoption institutionnelle.

f) Intégration dans une interface unique. La méthode propose sept outils (L00 à L06) couvrant l'ensemble des phases d'une mission d'audit. Leur intégration dans une interface logicielle unique constitue l'étape logique suivante en simulation, afin de faciliter leur déploiement et leur utilisation par les auditeurs.

g) Participer à la normalisation de l'audit. Faire de MUSA une méthode officielle pour auditer les PME au Cameroun, en Afrique et dans le monde.

CONCLUSION

LA digitalisation croissante des opérations comptables des établissements publics camerounais expose les applications à des risques de sécurité critiques, tandis que la séparation des audits de sécurité (Agence Nationale des Technologies de l'Information et de la Communication) et des applications en service (Contrôle Supérieur de l'État) conduit à une vision fragmentée que les petites et moyennes entreprises comme Solutions Techniques ne peuvent financer sur un même cycle budgétaire. Face à ce constat, ce mémoire a proposé la Méthode Unifiée d'Audit de Sécurité Applicative, une démarche standardisée qui combine les forces de l'Agence Nationale des Technologies de l'Information et de la Communication (structure en cinq phases, vision globale), l'innovation du Contrôle Supérieur de l'État (entropie de Shannon dans l'audit, zone grise) et les standards internationaux (Organisation Internationale de Normalisation 27001, Open Web Application Security Project ASVS, National Institute of Standards and Technology SP 800-115, Organisation Internationale de Normalisation 19011, normes Institute of Internal Auditors), en s'appuyant sur quatre piliers, standards de contenu, standards de conduite, innovation mesurable par l'entropie, et outils réutilisables et a été validée sur Gestion Informatisée des Opérations Comptables des Établissements Publics, l'application de gestion comptable développée par Solutions Techniques. L'application de cette méthode a montré que tous les outils sont fonctionnels et couvrent l'ensemble des phases d'une mission d'audit, d'où découlent les résultats suivants : six vulnérabilités confirmées (une critique, trois élevées, une modérée, une faible), un score de maturité global de neuf virgule cinq pour cent (Niveau 1 Initial selon Capability Maturity Model Integration) et une entropie globale de un virgule deux cent soixante-sept (zone grise critique), confirmant la fiabilité des constats et la reproductibilité de la méthode, avec des points forts (séparation des tâches, traçabilité, expiration de session) et des points faibles (absence de gouvernance, manque de documentation, pratiques de développement non sécurisées, infrastructure vulnérable). Ce travail présente des limites (validation sur un seul cas, accès limité aux données, temporalité restreinte) mais ouvre des perspectives prometteuses : généralisation à d'autres applications, déploiement en production, validation empirique de l'entropie, intégration dans une interface unique, sollicitation de démonstration auprès des deux institutions, adaptation au cloud computing, et contribution à la normalisation des pratiques d'audit au Cameroun.

BIBLIOGRAPHIE

- [1] Stallings, W. (2017). *Cryptography and Network Security : Principles and Practice* (7th ed.). Pearson Education. ISBN 978-0-13-444428-4. <http://williamstallings.com/Cryptography/> Consulté le 28 février 2026.
- [2] ISACA. (2020). *CISA Review Manual*. Information Systems Audit and Control Association. <https://www.isaca.org/credentialing/cisa> Consulté le 28 février 2026.
- [3] République du Cameroun. (2002). *Décret n°2002/092 du 08 avril 2002 portant création de l'Agence Nationale des Technologies de l'Information et de la Communication (AN-TIC)*. Présidence de la République. <https://www.antic.cm/index.php/fr/1-agence/presentation.html> Consulté le 16 août 2026.
- [4] ANTIC. (2020). *Démarche et cadre juridique de l'audit de sécurité des systèmes d'information*. Agence Nationale des Technologies de l'Information et de la Communication, Yaoundé. <https://www.antic.cm/index.php/fr/missions/audit-de-securite.html> Consulté le 16 août 2026.
- [5] République du Cameroun. (2013). *Décret n°2013/287 du 04 septembre 2013 portant organisation des services du Contrôle supérieur de l'État*. Présidence de la République. [https://www.prc.cm/fr/actualites/actes/decrets/357-decret-n-2013-287-du-04-septembre-2013-portant-organisation-des-services-du\ -controle-superieur-de-l-etat](https://www.prc.cm/fr/actualites/actes/decrets/357-decret-n-2013-287-du-04-septembre-2013-portant-organisation-des-services-du\-controle-superieur-de-l-etat) Consulté le 16 août 2026.
- [6] Shannon, C. E. (1948). A Mathematical Theory of Communication. *Bell System Technical Journal*, 27(3), 379–423. <https://people.math.harvard.edu/~ctm/home/text/others/shannon/entropy/entropy.pdf> Consulté le 15 mars 2026.
- [7] CHAI. (2014). *Guide d'audit des systèmes d'information* (v1.0, juin 2014). Secrétariat général du Comité d'harmonisation de l'audit interne, France. https://www.economie.gouv.fr/files/files/directions_services/agences/CHAI/guide_audit_si.pdf Consulté le 10 mars 2026.
- [8] ISO/IEC 27001 :2022. *Sécurité de l'information — Exigences*. Organisation Internationale de Normalisation. <https://www.iso.org/standard/82875.html> Consulté le 20 février 2026.

-
- [9] OWASP Foundation. (2021). *Application Security Verification Standard v4.0.3*. Open Web Application Security Project. <https://owasp.org/www-project-application-security-verification-standard/> Consulté le 25 février 2026.
- [10] République du Cameroun. (2019). *Décret n°2019/150 du 22 mars 2019 portant organisation et fonctionnement de l'Agence Nationale des Technologies de l'Information et de la Communication*. Présidence de la République. <https://www.antic.cm/index.php/fr/missions/audit-de-securite.html> Consulté le 16 août 2026.
- [11] Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2008). *NIST SP 800-115 : Technical Guide to Information Security Testing and Assessment*. National Institute of Standards and Technology. <https://csrc.nist.gov/publications/detail/sp/800-115/final> Consulté le 05 mars 2026
- [12] ISO 19011 :2018. *Lignes directrices pour l'audit des systèmes de management*. Organisation Internationale de Normalisation. <https://www.iso.org/standard/70017.html> Consulté le 12 mars 2026.
- [13] Institute of Internal Auditors. (2017). *International Professional Practices Framework (IPPF)*. The IIA, Lake Mary, FL. <https://www.theiia.org/en/standards/> Consulté le 22 mars 2026.
- [14] Dhillon, G., & Backhouse, J. (2000). Information System Security Management in the New Millennium. *Communications of the ACM*, 43(7), 125–128. <https://doi.org/10.1145/341852.341868> Consulté le 15 mai 2026.
- [15] ANTIC. (2026). *Méthodologie d'audit de sécurité des systèmes d'information : présentation aux cabinets agréés* [Source primaire non publiée]. Conférence ANTIC, Yaoundé, Cameroun, 29 avril 2026. Notes de terrain et enregistrements audio de l'auteure, archivés. Cadre de référence publié : <https://www.antic.cm/index.php/fr/missions/audit-de-securite.html> Consulté le 16 août 2026.
- [16] Thierry Emmanuel Minka Mi Nguidjoi. Modelling Epistemic Uncertainty in Information Systems Audit. 2026. ⟨hal-05701270⟩ <https://hal.science/view/index/docid/5701270>
- [17] ISO/IEC 27000 :2018. *Technologies de l'information, Techniques de sécurité, Vue d'ensemble et vocabulaire*. Organisation Internationale de Normalisation. <https://www.iso.org/standard/73906.html> Consulté le 15 avril 2026.
- [18] République du Cameroun. (2012). *Décret n°2012/1643/PM du 14 juin 2012 fixant les conditions et les modalités d'audit de sécurité obligatoire des réseaux de communications électroniques et des systèmes d'information*. Services du Premier Ministre. <https://www.minpostel.gov>.



- cm/index.php/fr/les-textes/telecoms-tic/decrets-telecoms-tic/
276-decret-n-2012-1643-pm-du-14-juin-2012-pour-fixer-les-conditions\
-d-audit-de-la-securite-obligatoire-des-reseaux-de-communication-electronique-et-d
Consulté le 16 août 2026.
- [19] ISO/IEC 27002 :2022. *Sécurité de l'information — Code de pratique pour les mesures de sécurité*. Organisation Internationale de Normalisation. <https://www.iso.org/standard/75652.html> Consulté le 20 avril 2026.
- [20] République du Cameroun. (2010). *Loi n°2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité au Cameroun*. Assemblée Nationale. https://www.minpostel.gov.cm/images/Les_textes/Lois/Loi_2010-012_cybersecurite_cybercriminalite.pdf Consulté le 16 août 2026.
- [21] Humphreys, E. (2016). *Implementing the ISO/IEC 27001 ISMS Standard* (2nd ed.). Artech House. ISBN 978-1-60807-930-8. <https://us.artechhouse.com/Implementing-the-ISOIEC-27001-ISMS-Standard-Second-Edition-P1795.aspx> Consulté le 16 août 2026.
- [22] OWASP Foundation. (2021). *OWASP Top 10 - 2021 : The Ten Most Critical Web Application Security Risks*. Open Web Application Security Project. <https://owasp.org/Top10/> Consulté le 25 avril 2026.
- [23] République du Cameroun. (2010). *Loi n°2010/001 du 13 avril 2010 portant promotion des Petites et Moyennes Entreprises au Cameroun*, modifiée et complétée par la loi n°2015/010 du 16 juillet 2015. Assemblée Nationale. <https://www.juriafrica.com/lex/loi-2010-001-13-avril-2010-18200.htm> Consulté le 16 août 2026.
- [24] NIST. (2012). *SP 800-30 Rev.1 : Guide for Conducting Risk Assessments*. National Institute of Standards and Technology. <https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final> Consulté le 02 mai 2026.
- [25] CMMI Institute. (2018). *CMMI for Development, Version 2.0*. <https://www.cmmiinstitute.com/cmmi> Consulté le 01 avril 2026.
- [26] ISACA. (2019). *COBIT 2019 Framework : Governance and Management Objectives*. Information Systems Audit and Control Association. <https://www.isaca.org/resources/cobit> Consulté le 10 mai 2026.
- [27] Kim, G., Humble, J., Debois, P., & Willis, J. (2016). *The DevOps Handbook : How to Create World-Class Agility, Reliability, and Security in Technology Organizations*. IT Revolution Press. ISBN 978-1-942788-00-3. <https://itrevolution.com/product/the-devops-handbook-second-edition/> Consulté le 16 août 2026.



- [28] Maletyon. (2025). *INF3226 - Audit des SI*. Dépôt GitHub. <https://github.com/Maletyon/INF3226/tree/chapitre> Consulté le 18 avril 2026.
- [29] Microsoft. (2010). *Security Development Lifecycle ; Process Guidance*. Microsoft Corporation. <https://www.microsoft.com/en-us/securityengineering/sdl> Consulté le 20 mai 2026.
- [30] Fenz, S., Heurix, J., Neubauer, T., & Pechstein, F. (2014). Current Challenges in Information Security Risk Management. *Information Management & Computer Security*, 22(5), 410–430. <https://doi.org/10.1108/IMCS-06-2013-0045> Consulté le 08 avril 2026.

Annexes disponibles sur GitHub

Par souci de concision et pour respecter les contraintes de pagination du guide de rédaction, les annexes détaillées de ce travail sont disponibles intégralement sur le dépôt GitHub dédié au projet :

<https://github.com/solangetomiolama-dot/MUSA-Audit-Method>

Le dépôt contient notamment :

- ◆ Les points de contrôle complets des standards : ISO 27001 (93 mesures), OWASP ASVS (14 catégories, 3 niveaux) et NIST SP 800-115 ;
- ◆ Les guides d'entretien détaillés pour la Direction, les Développeurs et les Utilisateurs ;
- ◆ Les modèles de documents : charte d'audit, déclaration d'indépendance, procès-verbal de réunion et rapport d'audit ;
- ◆ Les outils opérationnels MUSA (PT01 à PT06) au format Excel ;
- ◆ Le rapport d'audit GIDOCEP.

Seules les annexes jugées essentielles à la compréhension du propos sont conservées dans ce mémoire, à savoir :

- ◆ Modèle synoptique des cinq phases d'une mission d'audit ;
- ◆ Les normes IIA applicables à MUSA (Annexe B).



Annexe A : Modèle synoptique des cinq phases d'une mission d'audit

Le document ci-après présente un modèle synoptique des cinq phases d'une mission d'audit, structuré autour des normes internationales de référence (ISO 19011 :2018, normes IIA 2024, COBIT 2019). Ce modèle a servi d'inspiration à la structuration des phases de MUSA, notamment pour l'organisation documentaire des travaux et la traçabilité des livrables.

SYNTHESE SYNOPTIQUE

Les 5 Phases d'une Mission

Architecture documentaire complète - Inputs, Outputs et rôle de chaque livrable dans le cycle de vie d'une mission d'audit

Normes IIA 2024 · COBIT 2019 · ISO 19011:2018



01 PHASE D'ENTREE Travaux Préparatoires			 DURÉE J-xx → J-xx
Références normatives : IIA Norme 2200 ISO 19011 §6.3 COBIT APO12			
INPUTS	ACTIVITES CLES	OUTPUTS	
 Plan Annuel d'Audit (PAA) <i>Acte fondateur désignant la mission - fournit le mandat initial, le périmètre stratégique et les priorités de risques de l'exercice</i>	a Prise de connaissance de l'entité : lecture texte organique, organigramme, procédures, rapports antérieurs	 Lettre de mission <i>Formalise le mandat, le périmètre exact et les droits d'accès - opposable en cas de résistance - condition sine qua non du terrain (IIA 2200)</i>	
 Rapports d'audits précédents <i>Référentiel historique - identifie les recommandations non levées, évite la reduplication, focalise les travaux sur les zones restées fragiles</i>	b Identification des risques inhérents par domaine - sans présupposer l'existence des contrôles	 Liste des documents requis (Phase 0) <i>Catalogue des 20-35 pièces à collecter avant tout terrain - l'absence d'un document H est elle-même un constat PAS/NEK documentable</i>	
 Texte organique & organigramme <i>Cartographie la structure de l'entité auditée - base indispensable pour construire la matrice RACI et identifier les interlocuteurs-clés</i>	c Revue des recommandations antérieures non levées - signal de risque documenté de premier rang	 Cartographie préliminaire des risques <i>Carte initiale des risques inhérents - alimentera la sélection des domaines prioritaires et le programme d'audit</i>	
 Manuel de procédures SI <i>Référentiel interne contre lequel les pratiques terrain seront évaluées - critère de conformité de premier rang (N4 de la décomposition N8)</i>	d Collecte et organisation des documents requis - liste priorisée H/M/F		

Thierry MINKA, Auditeur Senior Mission d'Accompagnement de la DAI-SIC Audit des SI 2026	e Rédaction et signature de la lettre de mission par le commanditaire	
---	---	--

▼ Les documents Phase 0 reçus et la cartographie préliminaire alimentent le Rapport d'Orientation

PHASE DE CADRAGE STRATEGIQUE

02 Planification

DURÉE

Jxx → Jxx

Références normatives : IIA Norme 2200–2240 | COBIT APO02 | ISO 19011 §6.3 | RBIA

INPUTS	ACTIVITES CLES	OUTPUTS
Lettre de mission signée Fonde l'autorité formelle de la planification - sans elle, les conclusions du Rapport d'Orientation sont contestables	a Walkthroughs : 3 parcours-types pour comprendre le fonctionnement réel des contrôles avant les tests	Rapport d'Orientation/Plan d'audit Livrable principal de planification signable par le commanditaire - définit périmètre, référentiels, cartographie priorisée et approche retenue
Documents Phase 0 reçus Matière première des travaux - leur absence ou incomplétude se documente en PAS/NEK et constitue un signal de risque	b Évaluation préliminaire du contrôle interne (design review - avant tout test terrain)	Programme de travail détaillé Traduit les risques majeurs en objectifs d'audit, critères, sources de preuves, techniques et procédures par domaine - colonne vertébrale du terrain
Cartographie préliminaire risques Point de départ de la sélection des domaines - cotation Pxl initiale à affiner par l'évaluation du contrôle interne	c Cotation Pxi des risques - sélection des risques majeurs - détermination des domaines prioritaires	Outil NEK/PAS + Shannon Grille O/N/PAS avec calcul d'entropie H par domaine - zones rouges/jaunes/blanches - outil de pilotage des constats terrain
Décomposition N8 Utilisation du GASI¹ édité par le CHAP² pour l'identification du type d'audit des SI puis décomposition sur 8 niveaux : Domaine → PC → OC → Critère → Élément requis → Question → Risque NC/ZG → Conséquence	d Construction matrice : Risques → Objectifs → Tests → PT codifiés	Guide d'entretiens + Calendrier RACI Questions par interlocuteur (DG / DSI / métiers) + RACI nominatif + chronogramme jour-par-jour - opérationnalise le programme
	e Réunion de lancement - validation du périmètre et du planning avec l'entité auditée	
	f Si pentest : obtenir l'autorisation écrite DG avant J1 terrain (obligation légale loi 2010/012)	

¹ Guide d'Audit des Systèmes d'Information

² Comité d'Harmonisation de l'Audit Interne

▼ Le programme de travail validé et l’outil NEK/PAS déclenchent les travaux de terrain

PHASE CENTRALE - PRODUCTION DES CONSTATS

03 Exécution (Terrain)

DURÉE
Jxx → Jxx

Références normatives : IIA Norme 2300–2330 | COBIT D55/MEA | ISO 19011 §6.4–6.5 | 5C des constats

INPUTS	☐ ACTIVITES CLES	OUTPUTS
Programme de travail approuvé Feuille de route opérationnelle - chaque auditeur sait quel PT réaliser, quelle preuve collecter et quelle assertion évaluer	a Tests de conformité : vérification que les procédures sont respectées (échantillonnage, rapprochements, revue documentaire)	Papiers de travail (PTxx) Dossier d'audit codifié - chaque PT relie un risque → un test → des preuves → une conclusion provisoire. Base opposable de tout constat
Outil NEK/PAS (grille vierge) Réceptacle des réponses - sa complétion progressive révèle les zones grises (PAS) et les non-conformités (N) à documenter	b Tests d'efficacité : vérification que les contrôles produisent des résultats mesurables (preuves d'exécution)	Outil NEK/PAS complété + entropie Shannon $H < 0,5$ = certitude (blanc) · $0,5 \leq H < 1,0$ = incertitude modérée (jaune) · $H \geq 1,0$ = zone grise critique (rouge)
Guide d'entretiens Questions structurées par interlocuteur - garantit la cohérence et la comparabilité des réponses - évite les oublis critiques	c Analyses de données : requêtes anomalies (doublons, aberrants), audit trail, rapprochements cross-sources	Projets d'observation (PO) Constats structurés en 7 sections §2.1.14 : norme / constatation / risques / contradictoire / analyse / conclusion / recommandations
Documents collectés en terrain Preuves primaires : exports systèmes, PV, journaux, contrats - chaque preuve est codée et archivée dans le dossier d'audit	d Inspection physique : visite salle serveur - contrôles environnementaux - aucun document ne remplace l'observation directe	Grilles de maturité CMMi (0→5) Positionnement du dispositif de contrôle sur l'échelle de maturité par domaine - synthèse actionnable pour le management
	e Tests de restauration : PV horodaté + mesure du RPO réel vs objectif déclaré	
	f Revue quotidienne des PT par le chef de mission : preuves suffisantes, traçabilité, conclusion reliée au critère	

▼ Les projets d'observation passent en procédure contradictoire avant d'être intégrés au rapport final

04 PHASE DE VALORISATION Communication des Résultats				DURÉE Jxx → Jxx
Références normatives : IIA Norme 2400-2450 ISO 19011 §6.6 IIA 5C des constats				
INPUTS	ACTIVITES CLES	OUTPUTS		
 Projets d'observation validés <i>Constats terrain consolidés et revus par le chef de mission - prêts pour la procédure contradictoire - base factuelle du rapport</i>	a Consolidation de la matrice de constats (MC) - scoring impact/probabilité - priorisation des recommandations	 Rapport d'audit définitif <i>Livrable contractuel principal : synthèse exécutive / constats par domaine / recommandations hiérarchisées / plan de remédiation</i>		
 Papiers de travail archivés <i>Justifient chaque constat - opposables en cas de contestation - archivés 5 ans minimum (IIA 2330)</i>	b Procédure contradictoire : envoi du rapport provisoire à l'audité - délai de réponse défini - intégration des retours	 Matrice de suivi des recommandations <i>Tableau de bord : référence, responsable, délai, KPI de vérification - base opérationnelle de la Phase 5</i>		
 Grilles de maturité CMMi complétées <i>Synthèse actionnable par domaine - fournit au management un tableau de bord de la maturité du SI</i>	c Réunion de clôture : présentation des constats majeurs et du plan de remédiation à la Direction Générale	 Plan de remédiation (Quick wins / Structurel) <i>Actions <30 jours (quick wins) vs actions structurelles >90 jours - hiérarchisées selon criticité des risques résiduels</i>		
 Réponses contradictoires de l'audité <i>Observations écrites de l'entité auditée - intégrées ou débattues dans le rapport final - attestent de l'équité de la procédure</i>	d Rédaction du rapport définitif - validation par le chef de mission et le responsable de l'audit interne	 Fiche de compagnonnage <i>Bilan pédagogique : points forts de l'équipe, axes d'amélioration, compétences acquises - spécifique au cadre de l'Entité</i>		
	e Diffusion contrôlée selon la liste approuvée - archivage complet du dossier d'audit			

▼ La matrice de suivi transmise à l'entité auditée lance le cycle de remédiation post-audit

05 PHASE DE VALEUR DURABLE Suivi des Recommandations				DURÉE M+1 → M+12
Références normatives : IIA Norme 2500-2600 COBIT MEA01 ISO 19011 §6.7				
INPUTS	ACTIVITES CLES	OUTPUTS		

Synthèse synoptique d'une mission d'audit suivant les normes IIA 2024 · COBIT 2019 · ISO 19011:2018

 Rapport d'audit définitif <i>Document de référence pour le suivi - les recommandations sont extraites et transformées en actions avec responsables et délais</i>	a Revues trimestrielles avec l'entité auditée - vérification des preuves de mise en œuvre des recommandations	 Rapport de suivi périodique <i>État d'avancement des recommandations - communiqué trimestriellement au Comité d'Audit et à la DG - IIA 2500</i>
 Matrice de suivi des recommandations <i>Tableau de bord transmis à l'entité auditée - statuts : À faire / En cours / Réalisé / Reporté / Abandonné</i>	b Levée formelle des observations dont les actions correctives sont vérifiées et satisfaisantes	 PV de levée d'observations <i>Clôture formelle d'un constat après vérification des preuves - conservé au dossier d'audit pour les missions ultérieures</i>
 Plan de remédiation <i>Feuille de route des actions correctives avec KPI de vérification - base de la revue périodique avec l'entité auditée</i>	c Escalade au Comité d'Audit des recommandations non mises en œuvre après délai - IIA 2600	 Mise à jour du PAA (cycle suivant) <i>Les recommandations non levées alimentent le Plan Annuel suivant - ferme la boucle et alimente la Phase 1 de la prochaine mission</i>
 Preuves de mise en œuvre (audité) <i>Documents justificatifs des actions correctives réalisées - à examiner lors des revues de suivi - conditionnent la levée de l'observation</i>	d Mise à jour du tableau de bord de maturité - mesure de la progression du niveau CMMi par domaine	 Score de maturité post-remédiation <i>Mesure l'amélioration effective du dispositif - démontre la valeur ajoutée de l'audit interne à la gouvernance</i>
	e Intégration des recommandations persistantes dans le PAA de l'exercice suivant - bouclage du cycle	

Légende des conventions documentaires

Input - Document entrant nécessaire au démarrage de la phase. **Output** - Livrable produit à l'issue de la phase.  **Activités** - Travaux essentiels réalisés.

NEK/PAS - O = Conforme · N = Non-conforme · PAS = Pas assez d'éléments (Zone Grise). **N8** - Décomposition à 8 niveaux : Domaine → PC → OC → Critère → Élément requis → Question → Risque NC/ZG → Conséquence.

CMMi 0-5 - Niveau 0 : Inexistant · Niveau 3 : Défini · Niveau 5 : Optimisé.  **Projet d'Observation** - Constat provisoire soumis au contradictoire avant finalisation dans le rapport. **Boucle** - Les recommandations non levées (Phase 5) réalimentent la Phase 1 du cycle suivant.

Annexe B : Normes IIA (IPPF) applicables à MUSA

Présentation

Les normes IIA confèrent à chaque mission d'audit MUSA une crédibilité et une robustesse méthodologique.

Norme	Intitulé	Exigence	Outil tableur
1100	Indépendance	Pas de conflit d'intérêts	Déclaration signée
1110	Indépendance org.	Structure garantissant l'indépendance	Charte approuvée DG
1120	Objectivité	Impartialité dans les jugements	Auto-évaluation
1130	Conflits potentiels	Déclaration obligatoire	Formulaire
1200	Compétence	Aptitudes et rigueur	Grille de sélection
1230	Formation continue	40 h/an minimum	Plan de formation
1300	Assurance qualité	Évaluations internes/externes	Rapport AQ annuel
2200	Planification	Objectifs, périmètre, ressources	Plan de mission
2210	Objectifs SMART	Basés sur les risques	Matrice objectifs-risques
2230	Ressources	Selon complexité	Grille d'allocation
2240	Programme	Approuvé avant le terrain	Programme MUSA
2300	Réalisation	Preuves suffisantes	Papiers PTxx
2310	Collecte	Méthodes définies	Grilles d'entretien
2320	Analyse	Méthodologie rigoureuse	Matrice des risques
2330	Documentation	Archivage 5 ans	PTxx codifiés
2340	Supervision	Revue quotidienne	Fiche de revue



Norme	Intitulé	Exigence	Outil tableur
2400	Communication	Exacte, objective, claire	Rapport 7 sections
2410	Contenu	Forces + NC + recommandations	Structure MUSA
2420	Qualité	Approbation avant diffusion	Validation lead
2440	Diffusion	Destinataires autorisés	Liste contrôlée
2500	Suivi	Vérification des recommandations	Revue trimestrielle
2501	Rapport de suivi	État d'avancement	Rapport trimestriel
2600	Risque résiduel	Escalade si critique	Procédure 3 niveaux